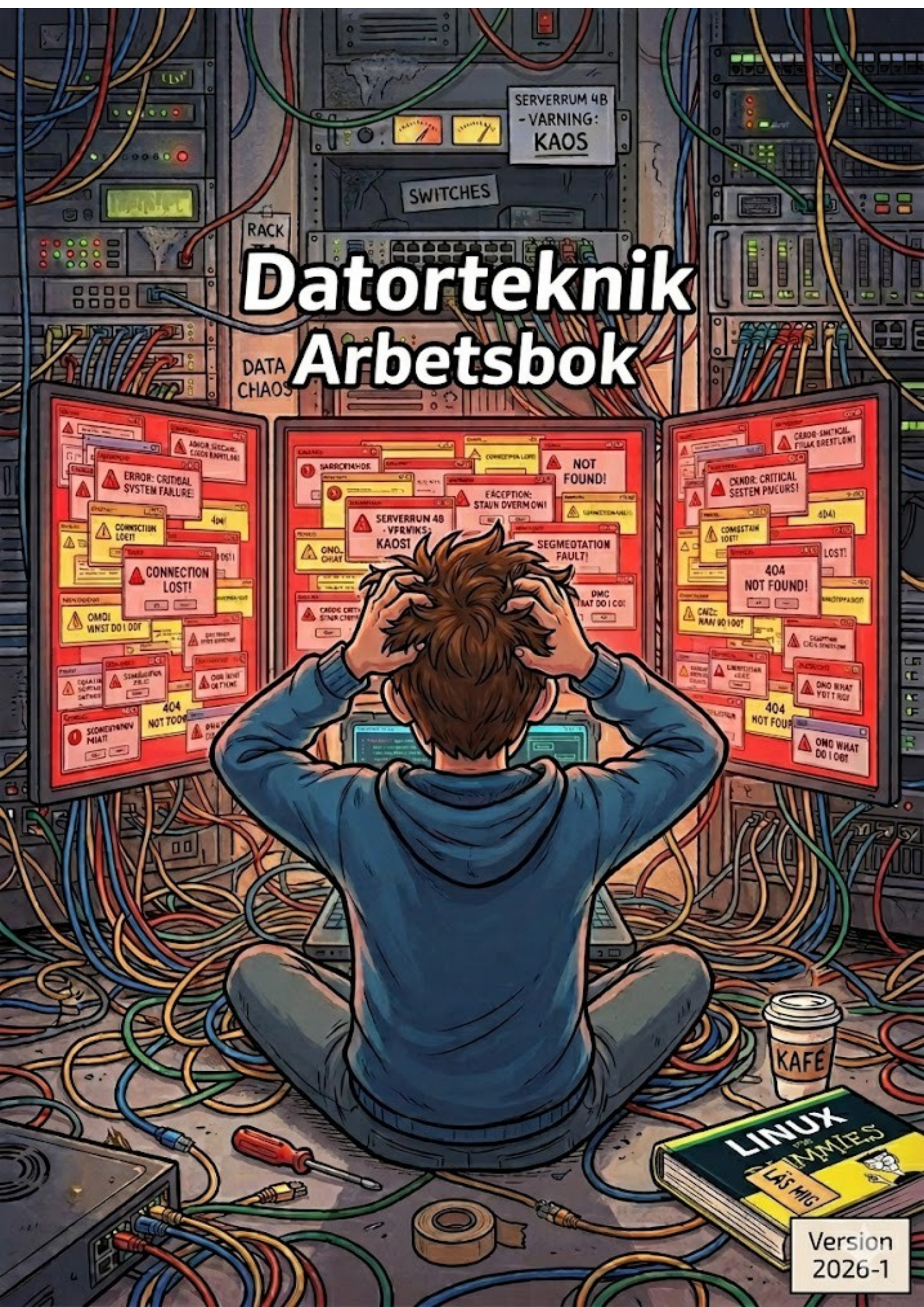


# Datorteknik Arbetsbok



Version  
2026-1

## **Licensinformation**

© 2025 Robin Bräck. Detta verk, inklusive text och illustrationer, är skyddat enligt lag om upphovsrätt. Illustrationerna i boken är framtagna med hjälp av artificiell intelligens (AI) under författarens redaktionella överseende och utgör en integrerad del av det samlade verket.

Verket tillhandahålls under licensen Creative Commons Erkännande-Ickekommersiell-DelaLika 4.0 Internationell (CC BY-NC-SA 4.0). Detta innebär att du har frihet att dela och anpassa innehållet så länge du anger källan på ett korrekt sätt, inte använder materialet för kommersiella ändamål och sprider eventuella bearbetningar under samma licensvillkor. Fullständiga licensvillkor finns tillgängliga på <https://creativecommons.org/licenses/by-nc-sa/4.0/>.

## Table of Contents

### 1 Hårdvara

#### 1.1 Moderkortet

Kontrollfrågor  
Fördjupningslänkar

#### 1.2 Processorn (CPU)

Kontrollfrågor  
Fördjupningslänkar

#### 1.3 RAM (Arbetsminne)

Kontrollfrågor  
Fördjupningslänkar

#### 1.4 Långtidslagring

Kontrollfrågor  
Fördjupningslänkar

#### 1.5 PSU (Nätaggregat)

Kontrollfrågor  
Fördjupningslänkar

#### 1.6 GPU (Grafikkort)

Kontrollfrågor  
Fördjupningslänkar

#### 1.7 Portar och bussar

Kontrollfrågor  
Fördjupningslänkar

### 2 Uppstart

Kontrollfrågor  
Fördjupningslänkar

### 3 Virtualisering

Kontrollfrågor  
Fördjupningslänkar

### 4 Lagring

Kontrollfrågor  
Fördjupningslänkar

### 5 RAID och LVM

Kontrollfrågor  
Fördjupningslänkar

### 6 Windows

#### 6.1 Microsofts OS-historia

Kontrollfrågor  
Fördjupningslänkar

#### 6.2 Windows uppbyggnad

Kontrollfrågor  
Fördjupningslänkar

#### 6.3 Fördelar och nackdelar med Windows

Kontrollfrågor  
Fördjupningslänkar

#### 6.4 Installation av Windows 11 i fysisk maskin/VM

Kontrollfrågor

## **6.5 Konfiguration och hantering av Windows**

Kontrollfrågor

Fördjupningslänkar

## **6.7 Workgroup, Domain och Active Directory**

Kontrollfrågor

Fördjupningslänkar

# **7 Linux - Historia, filosofi och ekosystem**

## **7.1 Vad är Linux?**

Kontrollfrågor

Fördjupningslänkar

## **7.2 Linuxkärnans grenar (distributioner)**

Kontrollfrågor

Fördjupningslänkar

## **7.3 Fördelar och nackdelar med Linuxsystem**

Kontrollfrågor

Fördjupningslänkar

## **7.4 Installation av Ubuntu Desktop**

Kontrollfrågor

Fördjupningslänkar

## **7.5 Konfiguration av Ubuntu Desktop**

Kontrollfrågor

Fördjupningslänkar

## **7.6 Installation av Ubuntu Server och Webmin**

Kontrollfrågor

Fördjupningslänkar

## **7.7 Linux grundläggande kommandon**

Kontrollfrågor

Fördjupningslänkar

# **8 Systemhärdning och säkerhet**

## **8.1 Säkerhet i Windowsmiljö**

### **8.1.1 Grundläggande säkerhetsprinciper och Windows Security**

Kontrollfrågor

Fördjupningslänkar

### **8.1.2 UAC och Integrity Levels**

Kontrollfrågor

Fördjupningslänkar

### **8.1.3 Microsoft Defender & Ransomware-skydd**

Kontrollfrågor

Fördjupningslänkar

### **8.1.4 Group policy och säkerhetsmallar**

Kontrollfrågor

Fördjupningslänkar

### **8.1.5 Avancerad NTFS-behörighet**

Kontrollfrågor

Fördjupningslänkar

### **8.1.6 BitLocker och EFS - Kryptering på disk- och filnivå**

Kontrollfrågor

Fördjupningslänkar

### **8.1.7 Windows-brandväggen med avancerad säkerhet**

Kontrollfrågor

Fördjupningslänkar

### **8.1.8 Autentisering: Kerberos, NTLM, Windows Hello och SSO**

Kontrollfrågor

Fördjupningslänkar

### **8.1.9 Revision och Loggning (Auditing)**

Kontrollfrågor

Fördjupningslänkar

### **8.1.10 Skydd mot skadlig kod (Malware) och nätfiske (Phishing)**

Kontrollfrågor

Fördjupningslänkar

### **8.1.11 PowerShell - Arkitektur, användning och säkerhet**

Kontrollfrågor

Fördjupningslänkar

### **8.1.12 Användarkonton och grupper**

Kontrollfrågor

Fördjupningslänkar

## **8.2 Säkerhet i Linuxmiljö**

### **8.2.1 Grundläggande säkerhetsprinciper**

Kontrollfrågor

Fördjupningslänkar

### **8.2.2 Linux root, sudo och användarbehörighet**

Kontrollfrågor

Fördjupningslänkar

### **8.2.3 Linux OS-härdning (Operating System Hardening)**

Kontrollfrågor

Fördjupningslänkar

### **8.2.4 Linux paketuppdatering och patchhantering**

Kontrollfrågor

Fördjupningslänkar

### **8.2.5 Linux systemövervakning och loggning**

Kontrollfrågor

Fördjupningslänkar

### **8.2.6 Linux härdning av tjänster (SSH, brandvägg, TLS/SSL)**

Kontrollfrågor

Fördjupningslänkar

### **8.2.7 Linux automatisera säkerhetsuppgifter (cron, script, loggning)**

Kontrollfrågor

Fördjupningslänkar

### **8.2.8 Linux backup och återställning**

Kontrollfrågor

Fördjupningslänkar

### **8.2.9 Linux Säkerhetsverktyg**

Kontrollfrågor

Fördjupningslänkar

### **8.2.10 Sammanfattning: Säkerhet som rutin**

Kontrollfrågor

Fördjupningslänkar

## **8.3 Jämförelse: Säkerhet i Windows och Linux**

### **8.3.1 Säkerhetsfilosofi: Helhetslösning kontra Modulär uppbyggnad**

Kontrollfrågor

Fördjupningslänkar

### **8.3.2 Behörighetsmodeller: Administrativ eskalering och filsystems rättigheter**

Kontrollfrågor

Fördjupningslänkar

### **8.3.3 Malware och hotbild: Olika mål, olika metoder**

Kontrollfrågor

Fördjupningslänkar

### **8.3.4 Antivirus och säkerhetsverktyg: Inbyggd automatisering kontra manuell kontroll**

Kontrollfrågor

Fördjupningslänkar

### **8.3.5 Loggning och övervakning: Loggboken mot Journalctl**

Kontrollfrågor

Fördjupningslänkar

### **8.3.6 Användningsområden och sårbarheter: Rätt verktyg för rätt uppgift**

Kontrollfrågor

Fördjupningslänkar

### **8.3.7 Sammanfattning: Perspektiv på säkerhet**

Kontrollfrågor

Fördjupningslänkar

## **9 OSI-modellen**

### **9.1 Uppkomst - Bakgrunden till OSI**

Kontrollfrågor

Fördjupningslänkar

### **9.2 Arkitektur - Lagren och PDU**

Kontrollfrågor

Fördjupningslänkar

### **9.3 Användningsområde - Felsökning och kommunikation**

Kontrollfrågor

Fördjupningslänkar

### **9.4 OSI-modellen i praktiken**

Kontrollfrågor

Fördjupningslänkar

### **9.5 Sammanfattning: OSI-modellen som kompass**

Kontrollfrågor

Fördjupningslänkar

## **10 Dataöverföring och Fjärradministration**

### **10.1 Filöverföring i praktiken (FTP, SFTP och SCP)**

Kontrollfrågor

Fördjupningslänkar

### **10.2 Webbens protokoll (HTTP och HTTPS)**

Kontrollfrågor

Fördjupningslänkar

### **10.3 Fjärrstyrning av system (SSH och RDP)**

Kontrollfrågor  
Fördjupningslänkar

#### **10.4 Filutdelning i lokala nätverk (SMB och NFS)**

Kontrollfrågor  
Fördjupningslänkar

#### **10.5 E-postens infrastruktur (SMTP, IMAP och POP3)**

Kontrollfrågor  
Fördjupningslänkar

#### **10.6 VPN (Virtual Private Network)**

Kontrollfrågor  
Fördjupningslänkar

#### **10.7 Peer-to-Peer (P2P) och BitTorrent**

Kontrollfrågor  
Fördjupningslänkar

### **11 Introduktion till IT-säkerhet**

Kontrollfrågor  
Fördjupningslänkar

#### **11.1 Vad är IT-säkerhet?**

Kontrollfrågor  
Fördjupningslänkar

#### **11.2 Grundläggande arkitekturprinciper**

Kontrollfrågor  
Fördjupningslänkar

#### **11.3 Autentisering och auktorisering**

Kontrollfrågor  
Fördjupningslänkar

#### **11.4 Riskhantering - Sårbarhet, Hot och Risk**

Kontrollfrågor  
Fördjupningslänkar

#### **11.5 IT-säkerhet ur ett verksamhetsperspektiv**

Kontrollfrågor  
Fördjupningslänkar

#### **11.6 Vanliga angrepp mot klienter och system**

Kontrollfrågor  
Fördjupningslänkar

#### **11.7 Säkerhetskultur och den operativa vardagen**

Kontrollfrågor  
Fördjupningslänkar

#### **11.8 Moderna hot och skydd: En digital kapprustning**

Kontrollfrågor  
Fördjupningslänkar

#### **11.9 Verktyg, övervakning och loggning**

Kontrollfrågor  
Fördjupningslänkar

#### **11.10 Incidenthantering och katastrofplanering**

Kontrollfrågor  
Fördjupningslänkar

### **12 Etisk hacking och hackingkultur**

#### **12.1 Introduktion och etik: Hackingens hjärta**

Kontrollfrågor

Fördjupningslänkar

## **12.2 Penetrationstestning som yrke**

Kontrollfrågor

Fördjupningslänkar

## **12.3 Metodik: Cyber Kill Chain & PTES**

Kontrollfrågor

Fördjupningslänkar

## **12.4 Social Engineering - Den mänskliga vektorn**

Kontrollfrågor

Fördjupningslänkar

## **12.5 Tekniska angrepp: Från Webb till Kod**

Kontrollfrågor

Fördjupningslänkar

## **12.6 Trådlös säkerhet (WLAN-hacking)**

Kontrollfrågor

Fördjupningslänkar

## **12.7 Reverse Engineering & Forensik**

Kontrollfrågor

Fördjupningslänkar

## **12.8 Molnsäkerhet (Cloud Pentesting)**

Kontrollfrågor

Fördjupningslänkar

## **12.9 Rapportering och åtgärdsförslag**

Kontrollfrågor

Fördjupningslänkar

## **12.10 Lagar, etik och dataskydd**

Kontrollfrågor

Fördjupningslänkar

## **12.11 Verktyg och specialiserade operativsystem**

Kontrollfrågor

Fördjupningslänkar

## **12.12 Historiska attacker och deras betydelse**

Kontrollfrågor

Fördjupningslänkar

# **13 Incidenthantering och digitalt försvar**

Kontrollfrågor

Fördjupningslänkar

## **13.1 Grunderna i incidenthantering**

Kontrollfrågor

Fördjupningslänkar

## **13.2 Planering och organisation (IRP & IRT)**

Kontrollfrågor

Fördjupningslänkar

## **13.3 Detektering och övervakning**

Kontrollfrågor

Fördjupningslänkar

## **13.4 Logganalys - Spåren i snön**

Kontrollfrågor

Fördjupningslänkar

### **13.5 Isolering och begränsning (Containment)**

Kontrollfrågor

Fördjupningslänkar

### **13.6 Eliminering och återställning**

Kontrollfrågor

Fördjupningslänkar

### **13.7 Digital Forensik vid incidenter**

Kontrollfrågor

Fördjupningslänkar

### **13.8 Kriskommunikation och lagstadgad rapportering**

Kontrollfrågor

Fördjupningslänkar

### **13.9 Business Continuity & Disaster Recovery (BCDR)**

Kontrollfrågor

Fördjupningslänkar

### **13.10 Post-incident och ständiga förbättringar**

Kontrollfrågor

Fördjupningslänkar

## **14 Framtidens teknik och hållbarhet**

### **14.1 Artificiell Intelligens (AI) och Maskininlärning**

Kontrollfrågor

### **14.2 Kvantdatorer och framtidens beräkningskraft**

Kontrollfrågor

Fördjupningslänkar

### **14.3 Hållbar IT och den cirkulära ekonomin**

Kontrollfrågor

Fördjupningslänkar

### **14.4 Edge Computing och sakernas internet (IoT)**

Kontrollfrågor

Fördjupningslänkar

### **14.5 Den föränderliga yrkesrollen och livslångt lärande**

Kontrollfrågor

Fördjupningslänkar

# 1 Hårdvara

## 1.1 Moderkortet

### Kontrollfrågor

1. Vad är en formfaktor och varför är den avgörande vid ett datorbygge?
2. Förklara chipsetets uppgift. Varför kan man säga att det är datorns trafikpolis?
3. Vad är skillnaden mellan Northbridge och Southbridge i äldre arkitekturer jämfört med idag?
4. Vad gör en VRM och vad kan hända om den blir för varm under tung belastning?
5. Beskriv vad CMOS-batteriet har för funktion på moderkortet.
6. Du ska installera en ny processor men den passar inte i sockeln trots att den ser nästan likadan ut. Vad har troligen gått fel?
7. Varför är det viktigt för en tekniker att kunna navigera i UEFI/BIOS?

## Fördjupningslänkar

Intel (Vad är ett moderkort?) -

<https://www.intel.se/content/www/se/sv/gaming/resources/what-is-a-motherboard.html>

MSI (Grundläggande guide för moderkort) -

<https://www.msi.com/blog/motherboard-basics-beginners-guide>

ASUS (FAQ om moderkort och grunder) -

<https://www.asus.com/us/support/FAQ/1044664/>

Wikipedia (Moderkort på svenska) - <https://sv.wikipedia.org/wiki/Moderkort>

PCPartPicker (Verktyg för komponentval) - <https://pcpartpicker.com>

Hardware Unboxed (Hårdvarutester och analyser) -

<https://www.youtube.com/@HardwareUnboxed>

Intel Ark (Produktspecifikationer) - <https://ark.intel.com>

Buildzoids (Actually Hardcore Overclocking) -

<https://www.youtube.com/@ActuallyHardcoreOverclocking>

GamersNexus (Djupgående moderkortstester) -

<https://www.youtube.com/watch?v=3-pZ07S1mSg>

WikiChip (Teknisk wiki för hårdvaruarkitektur) - <https://en.wikichip.org>

## 1.2 Processorn (CPU)

### Kontrollfrågor

1. Beskriv de tre stegen i CPU-cykeln: Fetch, Decode och Execute.
2. Förklara varför en processor med lägre klockfrekvens (GHz) ibland kan vara snabbare än en med högre klockfrekvens. Vad spelar IPC för roll här?
3. Vad är skillnaden mellan en fysisk kärna (core) och en tråd (thread)?
4. Varför är cacheminnet uppdelat i olika nivåer (L1, L2, L3) och varför hämtar inte CPU:n all data direkt från RAM-minnet?
5. Vad innebär en 5 nm tillverkningsteknik i praktiken för en processor jämfört med en äldre på 14 nm?
6. Förklara skillnaden mellan arkitekturerna x86 (CISC) och ARM (RISC). Ge exempel på enheter där respektive arkitektur oftast används.
7. Du läser specifikationerna för en ny dator och ser "TDP: 65W". Vad betyder det och varför är det viktigt för dig som tekniker att veta?
8. Vad är "Thermal Throttling"? Beskriv ett scenario där en tekniker kan misstänka att detta är orsaken till en långsam dator.
9. Tolka modellnamnet: Vad kan du utläsa om en processor som heter "Intel Core i7-13700K"?

## Fördjupningslänkar

Intel (Hur processorer fungerar) -

<https://www.intel.com/content/www/us/en/gaming/resources/how-processors-work.html>

AMD (Ryzen-processorer och produktöversikt) -

<https://www.amd.com/en/products/ryzen-processors>

TechPowerUp (Omfattande CPU-databas) -

<https://www.techpowerup.com/cpudb/>

GamersNexus (Teknisk genomgång av CPU-tester) -

[https://www.youtube.com/watch?v=vVbcshM\\_3As](https://www.youtube.com/watch?v=vVbcshM_3As)

CPUID (CPU-Z mjukvara för processorinformation) -

<https://www.cpubid.com/software/cpu-z.html>

Tom's Hardware (CPU-hierarki och prestandatester) -

<https://www.tomshardware.com/reviews/cpu-hierarchy,4312.html>

Linus Tech Tips (CPU-grunder och förklaringar) -

[https://www.youtube.com/watch?v=cNN\\_tTXABUA](https://www.youtube.com/watch?v=cNN_tTXABUA)

Wikipedia (Central Processing Unit - CPU) -

[https://en.wikipedia.org/wiki/Central\\_processing\\_unit](https://en.wikipedia.org/wiki/Central_processing_unit)

## 1.3 RAM (Arbetsminne)

### Kontrollfrågor

1. Vad innebär det att RAM är ett *volatilt* minne?
2. Förklara liknelsen om processorn, arbetsbänken och arkivskåpet.
3. Vad betyder förkortningen DDR och vad innebär tekniken?
4. Varför kan man inte blanda olika DDR-generationer på samma moderkort?
5. Vad är skillnaden mellan DIMM och SO-DIMM?
6. Varför körs snabba RAM-minnen ofta i en lägre hastighet (JEDEC) precis när de har installerats?
7. Vad är fördelen med att använda *Dual Channel* istället för en enda minnesmodul?
8. Vad är *virtuellt minne* och när börjar datorn använda det?
9. När är det viktigt att använda ECC-minne?

## Fördjupningslänkar

Crucial (Vad är datorminne?) - <https://www.crucial.com/articles/about-memory/what-is-computer-memory>

Kingston (RAM-minne för stationära och bärbara datorer) - <https://www.kingston.com/en/memory/desktop-laptop-memory>

GamersNexus (Allt du behöver veta om hur RAM fungerar) - [https://www.youtube.com/watch?v=D\\_Yt4vSZKVk](https://www.youtube.com/watch?v=D_Yt4vSZKVk)

TechPowerUp (Databas över minnesmoduler) - <https://www.techpowerup.com/memdb/>

Wikipedia (DDR SDRAM och minnesteknik) - [https://en.wikipedia.org/wiki/DDR\\_SDRAM](https://en.wikipedia.org/wiki/DDR_SDRAM)

## 1.4 Långtidslagring

### Kontrollfrågor

1. Varför är en HDD billigare per gigabyte än en SSD?
2. Vad är den största risken med att använda en mekanisk hårddisk i en bärbar dator som flyttas mycket?
3. Förklara varför man aldrig ska defragmentera en SSD. Vad ska man använda istället?
4. Vad är skillnaden mellan M.2 och NVMe? (Ledtråd: formfaktor vs protokoll).
5. Du ska bygga en dator för videoredigering och behöver 20 TB total lagring. Hur skulle du fördela detta mellan NVMe och HDD för att få både snabbhet och plats?
6. Vad innebär det att en SSD använder "NAND-flash"?

## Fördjupningslänkar

Seagate (How Hard Drives Work) –

[https://www.seagate.com/content/dam/seagate/migrated-assets/www-content/product-content/enterprise-performance-savvio-fam/enterprise-performance-15k-hdd/\\_shared/docs/how-hard-drives-work.pdf](https://www.seagate.com/content/dam/seagate/migrated-assets/www-content/product-content/enterprise-performance-savvio-fam/enterprise-performance-15k-hdd/_shared/docs/how-hard-drives-work.pdf)

Kingston (NVMe vs SATA Explained) – <https://www.kingston.com/en/blog/pc-performance/nvme-vs-sata>

TechQuickie (SSD NAND Types (SLC, MLC, TLC, QLC) –

[https://www.youtube.com/watch?v=5M-2V\\_V\\_h8c](https://www.youtube.com/watch?v=5M-2V_V_h8c)

Crucial (Explanation) – <https://www.crucial.com/articles/about-ssd/what-is-nvme-ssd>

Backblaze (HDD vs SSD Failure Rates) – <https://www.backblaze.com/blog/ssd-edition-2023-drive-stats-review/>

## 1.5 PSU (Nätaggregat)

### Kontrollfrågor

1. Varför är nätaggregatet en så kritisk komponent vid ett datorbygge?
2. Beskriv omvandlingen från AC till DC och nämna de tre viktigaste spänningsnivåerna.
3. Varför bör man inte köpa ett nätaggregat som ligger precis på gränsen av datorns maxförbrukning?
4. Vad innebär en 80 PLUS Gold-certifiering i praktiken när det gäller värme och energi?
5. Vilka är fördelarna med att välja ett modulärt nätaggregat framför ett icke-modulärt?
6. Vad kan hända med datorns stabilitet om spänningslinorna inte levererar jämn ström?

## Fördjupningslänkar

Corsair (PSU Buying Guide) - <https://www.corsair.com/ww/en/explorer/diy-builder/power-supply-units/how-to-choose-a-psu/>

80 PLUS (Clearinghouse) - <https://www.clearinghouse.org/>

GamersNexus (How PSUs are Made and Tested) - <https://www.youtube.com/watch?v=f67eQU7Y8wM>

OuterVision (Power Supply Calculator) - <https://outervision.com/power-supply-calculator>

Wikipedia (Power Supply Unit, Computer) - [https://en.wikipedia.org/wiki/Power\\_supply\\_unit\\_\(computer\)](https://en.wikipedia.org/wiki/Power_supply_unit_(computer))

## 1.6 GPU (Grafikkort)

### Kontrollfrågor

1. Vad är den principiella skillnaden mellan hur en CPU och en GPU arbetar?
2. Varför har grafikkort eget minne (GDDR) istället för att bara använda datorns vanliga RAM?
3. Förklara vad minnesbussens bredd (bit) har för betydelse för prestandan i höga upplösningar.
4. Vad är Ray Tracing och varför kräver det speciella kärnor i grafikkortet?
5. Beskriv skillnaden mellan MSAA och TAA. Vilka är fördelarna och nackdelarna med respektive metod?
6. Hur fungerar upscaling-tekniker som DLSS och FSR, och varför vill man använda dem?
7. Varför har man nästan helt slutat använda lösningar med dubbla grafikkort (SLI/CrossFire)?

## Fördjupningslänkar

Nvidia (What is Ray Tracing?) -

<https://www.nvidia.com/en-us/geforce/news/graphics-explained-ray-tracing/>

AMD (FidelityFX Super Resolution (FSR)) -

<https://www.amd.com/en/technologies/fidelityfx-super-resolution>

TechPowerUp (GPU Database) - <https://www.techpowerup.com/gpudb/>

Hardware Unboxed (Graphics Settings Explained) -

<https://www.youtube.com/watch?v=eP9T45UfTbg>

Wikipedia - (Graphics Processing Unit) -

[https://en.wikipedia.org/wiki/Graphics\\_processing\\_unit](https://en.wikipedia.org/wiki/Graphics_processing_unit)

## 1.7 Portar och bussar

### Kontrollfrågor

1. Vad är den praktiska skillnaden mellan en intern "header" och en extern port?
2. Beskriv funktionen hos de olika anslutningarna i en front panel header.
3. Varför har PCIe nästan helt ersatt den gamla PCI-standarderna?
4. Vad menas med "lanes" (banor) när man pratar om PCIe-anslutningar?
5. M.2 kan användas till mycket mer än bara lagring. Ge två exempel på andra moduler som kan sitta i en M.2-port.
6. Vilka var de främsta fördelarna med USB när det introducerades jämfört med de äldre portarna?
7. Hur har USB-C och USB Power Delivery förändrat sättet vi laddar och ansluter våra enheter på?
8. När bör man välja DisplayPort framför HDMI, och vice versa?

## Fördjupningslänkar

Intel (What is PCI Express?) – <https://www.intel.com/content/www/us/en/io/pci-express/pci-express-technology.html>

SATA-IO (About SATA) – <https://sata-io.org/sata-overview>

USB.org (USB Explained) – <https://www.usb.org/>

HDMI Forum (HDMI Specifications) – <https://www.hdmi.org/spec/index>

VESA (DisplayPort Standard) – <https://displayport.org/>

Wikipedia (Computer Bus) – [https://en.wikipedia.org/wiki/Computer\\_bus](https://en.wikipedia.org/wiki/Computer_bus)

## 2 Uppstart

### Kontrollfrågor

1. Vad är syftet med "Power Good"-signalen från nätaggregatet
2. Beskriv vad som händer under ett POST (Power-On Self Test). Vad händer om ett fel upptäcks?
3. Vilka är de viktigaste fördelarna med UEFI jämfört med det äldre BIOS-systemet?
4. Förklara skillnaden mellan hur en bootloader lagras i ett BIOS-system (MBR) jämfört med ett UEFI-system (GPT/ESP).
5. Vad är Secure Boot och hur skyddar det datorn mot skadlig kod som rootkits?
6. Ge exempel på två olika bootloaders och beskriv deras roll som "stafettpinne".
7. Om en dator stannar vid Windows-logotypen men aldrig når inloggningsskärmen, i vilket steg i uppstartssekvensen ligger sannolikt felet?
8. Varför kan man inte använda en disk på 4 TB som startdisk i ett gammalt BIOS-system med MBR?
9. Vad är en "Reset Vector" och varför är den viktig för processorns allra första steg?
10. Vilka felsökningssteg skulle du ta om du möts av felmeddelandet "No bootable device found"?

## Fördjupningslänkar

UEFI Forum (Official Specifications) – <https://uefi.org/specifications>

Microsoft Learn (Secure Boot Overview) –  
<https://learn.microsoft.com/en-us/windows-hardware/design/device-experiences/oem-secure-boot>

GNU GRUB (Manual) –  
<https://www.gnu.org/software/grub/manual/grub/grub.html>

AdamW's blog (UEFI boot: how does it work?) –  
<https://www.happyassassin.net/posts/2014/01/25/uefi-boot-how-does-it-actually-work/>

HowStuffWorks (How BIOS Works) –  
<https://computer.howstuffworks.com/bios.htm>

Wikipedia (Unified Extensible Firmware Interface) –  
[https://en.wikipedia.org/wiki/Unified\\_Extensible\\_Firmware\\_Interface](https://en.wikipedia.org/wiki/Unified_Extensible_Firmware_Interface)

Wikipedia (Power-on self-test) – [https://en.wikipedia.org/wiki/Power-on\\_self-test](https://en.wikipedia.org/wiki/Power-on_self-test)

## 3 Virtualisering

### Kontrollfrågor

1. Vad menas med virtualisering inom IT?
2. Vad är en hypervisor?
3. Nämn två fördelar med att använda virtualisering.
4. Vad är skillnaden mellan en bare-metal hypervisor och en hosted hypervisor?
5. Ge ett exempel på en bare-metal hypervisor.
6. Ge ett exempel på en hosted hypervisor.
7. Vilka är några fördelar med att använda virtualisering i molnet?
8. Vad är en container, och hur skiljer den sig från en virtuell maskin?
9. Varför är isolering viktigt när man kör flera system på samma hårdvara?
10. Nämn en plattform eller tjänst som använder virtualisering i molnet.

## Fördjupningslänkar

Vmware (What is a Hypervisor?) –

<https://www.vmware.com/topics/glossary/content/hypervisor.html>

Docker (What is a Container?) – <https://www.docker.com/resources/what-container/>

Oracle (VirtualBox User Manual) – <https://www.virtualbox.org/manual/ch01.html>

Proxmox (Proxmox VE Introduction) – [https://pve.proxmox.com/wiki/Main\\_Page](https://pve.proxmox.com/wiki/Main_Page)

Wikipedia (OS-level virtualization (Containers)) –

[https://en.wikipedia.org/wiki/OS-level\\_virtualization](https://en.wikipedia.org/wiki/OS-level_virtualization)

## 4 Lagring

### Kontrollfrågor

1. Förklara relationen mellan disk → partition → volym → filsystem med egna ord och ett konkret exempel.
2. Varför är GPT att föredra framför MBR på moderna datorer, och vad innebär “upp till 128 partitioner i Windows”?
3. Vad innebär att en disk exponeras som en blockenhet och varför bryr sig inte den nivån om vilket filsystem som används?
4. Ge två tydliga exempel där FAT32 är ett dåligt val och två där exFAT är ett lämpligt val.
5. Beskriv formfaktor vs gränssnitt (t.ex. 2,5” SATA-SSD vs M.2 NVMe-SSD) och hur det påverkar prestanda.
6. En fil är 10 GiB och nätverket är 100 Mbit/s. Räkna fram rimlig överföringstid och nämn minst två källor till overhead.
7. Varför kräver Windows vanligtvis NTFS på systempartitionen, och varför kan Windows inte läsa ext4 utan extra drivrutiner?
8. Vad är wear-levelling och TBW, och hur påverkar det val och användning av SSD i olika miljöer (t.ex. klassrumsdator vs server)?
9. Ge ett exempel på när du i Windows hellre skulle montera en volym i en mapp än ge den en enhetsbokstav.
10. Förklara varför 1 TB på förpackningen inte visas som exakt 1,00 TiB i operativsystemet, och vad skillnaden betyder i praktiken.

## Fördjupningslänkar

MBR vs GPT (Microsoft Docs) –

<https://learn.microsoft.com/en-us/windows/win32/fileio/mbr-vs-gpt>

NTFS (Technical Reference ) –

<https://learn.microsoft.com/en-us/windows/win32/fileio/ntfs-technical-reference>

APFS (Overview) – <https://support.apple.com/en-us/HT208018>

kernel.org (Kernel Documentation) –

<https://www.kernel.org/doc/html/latest/filesystems/ext4/index.html>

OpenZFS (Documentation) – <https://openzfs.github.io/openzfs-docs/>

File systems (översikt och jämförelser) –

[https://wiki.archlinux.org/title/File\\_systems](https://wiki.archlinux.org/title/File_systems)

DigitalOcean (An Introduction to Filesystems) –

<https://www.digitalocean.com/community/tutorials/an-introduction-to-filesystems>

How-To Geek (Partitioning Explained) – <https://www.howtogeek.com/192772>

Physics.nist.gov (Binary prefixes - GiB vs GB)–

<https://physics.nist.gov/cuu/Units/binary.html>

## 5 RAID och LVM

### Kontrollfrågor

1. Vad står RAID för och vad är syftet?
2. Hur skiljer sig mjukvaru-RAID från hårdvaru-RAID?
3. Vad är för- och nackdelar med RAID 0?
4. Hur fungerar RAID 5 och vad händer om en disk går sönder?
5. Vad menas med att RAID inte är en backup?
6. Hur skiljer sig ZFS från traditionell RAID?
7. Vad är RAID-Z2?
8. Vad är LVM och vad är fördelen med att använda det?
9. Vad är en volymgrupp inom LVM?
10. Ge exempel på någon verklig situation där man använder ZFS.

## Fördjupningslänkar

Linux RAID Wiki (Dokumentation för Software RAID) –  
<https://raid.wiki.kernel.org/>

Ubuntu Community (Guide till Software RAID-installation) –  
<https://help.ubuntu.com/community/Installation/SoftwareRAID>

Proxmox VE (Dokumentation för lagring och virtualisering) –  
<https://docs.proxmox.com/>

OpenZFS Wiki (Huvudsida för ZFS-projektet) –  
[https://openzfs.org/wiki/Main\\_Page](https://openzfs.org/wiki/Main_Page)

ArchWiki (Djupgående guide till Logical Volume Management) –  
<https://wiki.archlinux.org/title/LVM>

TrueNAS (Resurser om ZFS och avancerad lagring) –  
<https://www.truenas.com/zfs/>

Red Hat (Professionell guide till hantering av Logical Volumes) –  
[https://docs.redhat.com/en/documentation/red\\_hat\\_enterprise\\_linux/9/html/configuring\\_and\\_managing\\_logical\\_volumes/index](https://docs.redhat.com/en/documentation/red_hat_enterprise_linux/9/html/configuring_and_managing_logical_volumes/index)

## 6 Windows

### 6.1 Microsofts OS-historia

#### Kontrollfrågor

1. Vad var de mest betydelsefulla skillnaderna mellan Windows 95 och dess föregångare (som Windows 3.11)?
2. Varför valde Microsoft att utveckla den separata Windows NT-linjen parallellt med konsumentversionerna?
3. Vilken teknisk milstolpe nåddes i och med Windows XP när det gäller de olika produktlinjerna (9x och NT)?
4. Beskriv varför Windows Vista fick utstå mycket kritik trots sina ambitioner kring ökad säkerhet.
5. Varför anses Windows 7 ofta vara den mest framgångsrika och stabila versionen i Windows-historien?
6. Vilka var de främsta anledningarna till att Windows 8 fick ett negativt mottagande av traditionella PC-användare?
7. Vad innebär konceptet "Windows as a Service" som introducerades i och med Windows 10?
8. Hur skiljer sig Windows 11 från Windows 10 när det gäller både det visuella gränssnittet och kraven på hårdvara?
9. Vilka är de primära skillnaderna i fokus och funktionalitet mellan en Desktop-version och en Server-version av Windows?
10. Vilken roll spelade MS-DOS i de tidiga versionerna av Windows, och när slutade Windows att vara ett grafiskt skal ovanpå DOS för konsumenterna?

## Fördjupningslänkar

Microsoft (Windows historia och vad som är nytt) -

<https://learn.microsoft.com/en-us/windows/whats-new/windows-history>

Wikipedia (Djupgående historik om Microsoft Windows) -

[https://en.wikipedia.org/wiki/History\\_of\\_Microsoft\\_Windows](https://en.wikipedia.org/wiki/History_of_Microsoft_Windows)

How-To Geek (En kortfattad historik över Windows operativsystem) -

<https://www.howtogeek.com/721525/a-brief-history-of-microsoft-windows/>

Microsoft (Windows Server-dokumentation och arkitektur) -

<https://learn.microsoft.com/en-us/windows-server/>

Computer Hope (Översikt över alla Windows-versioner genom tiderna) -

<https://www.computerhope.com/issues/ch000088.htm>

Version Museum (Visuell historik över Windows gränssnitt och design) -

<https://www.versionmuseum.com/history-of/microsoft-windows>

The Verge (En visuell guide till 35 år av Windows-utveckling) -

<https://www.theverge.com/2020/11/20/21577484/microsoft-windows-35th-anniversary-history-visual-guide>

Microsoft (Livscykel och supportdatum för olika Windows-versioner) -

<https://learn.microsoft.com/en-us/lifecycle/faq/windows>

PCMag (En grafisk resa genom Windows-versioner från 1.0 till idag) -

<https://www.pcmag.com/news/35-years-of-windows-a-graphical-history>

WinWorld (Arkiv över historiska och nedlagda operativsystem) -

<https://winworldpc.com/library/operating-systems>

## 6.2 Windows uppbyggnad

### Kontrollfrågor

1. Vad är enhetsbokstäver (t.ex. C: eller D:) i Windows och vad används de till rent praktiskt för användaren?
2. Vilka är de främsta fördelarna med att använda NTFS jämfört med det äldre filsystemet FAT32?
3. Beskriv steg för steg hur du ändrar rättigheter för en fil eller mapp via Windows grafiska gränssnitt.
4. Vad är Windows-registret och vilken typ av information lagras i denna centrala databas?
5. Varför är det kritiskt att vara extremt försiktig när man gör manuella ändringar i registret?
6. Vad innebär begreppet "arv" (Inheritance) när det kommer till behörigheter för mappar och undermappar?
7. Vad är skillnaden mellan NTFS-behörigheter och utdelningsbehörigheter (Share permissions) när man delar ut en mapp på ett nätverk?
8. Vad är ReFS (Resilient File System) och i vilka sammanhang är det mer lämpligt att använda än NTFS?
9. Vilket verktyg (program) använder man för att redigera registret manuellt, och vad heter den körbara filen för detta program?
10. Var på hårddisken lagras registrets filer (så kallade hives) rent fysiskt i Windows-installationen?

## Fördjupningslänkar

Microsoft (File Systems in Windows) -

<https://learn.microsoft.com/en-us/windows/win32/fileio/file-systems>

Microsoft (NTFS Technical Reference) -

<https://learn.microsoft.com/en-us/windows/win32/fileio/ntfs-technical-reference>

Microsoft (Change Permissions for Files and Folders) -

<https://support.microsoft.com/en-us/windows/change-permissions-for-files-and-folders-in-windows-8bfef146-0b22-47f6-9f77-5ef9f4e6a9d4>

Microsoft (Introduction to the Windows Registry) -

<https://support.microsoft.com/en-us/windows/what-is-the-windows-registry-776707f4-66f0-7f80-0285-3c6441d04d46>

Wikipedia (Windows Registry Overview) -

[https://en.wikipedia.org/wiki/Windows\\_Registry](https://en.wikipedia.org/wiki/Windows_Registry)

Microsoft (Resilient File System - ReFS Overview) -

<https://learn.microsoft.com/en-us/windows-server/storage/refs/refs-overview>

Microsoft (How Security Descriptors and Permissions Work) -

<https://learn.microsoft.com/en-us/windows/win32/secauthz/how-it-works--aces-and-acls>

BleepingComputer (Guide to Windows Registry Editor for Beginners) -

<https://www.bleepingcomputer.com/tutorials/how-to-use-the-windows-registry-editor/>

Lifewire (A Complete Guide to NTFS Permissions) -

<https://www.lifewire.com/ntfs-permissions-explained-4053913>

Wikipedia (New Technology File System - NTFS) -

<https://en.wikipedia.org/wiki/NTFS>

## 6.3 Fördelar och nackdelar med Windows

### Kontrollfrågor

1. Varför är Windows så dominerande som operativsystem på den globala marknaden jämfört med sina konkurrenter?
2. Nämn två specifika fördelar med Windows som gör att det ofta anses vara lättare för nybörjare att lära sig än till exempel Linux?
3. Varför blir Windows en så pass stor säkerhetsrisk om det inte underhålls och uppdateras kontinuerligt?
4. Vad innebär det rent praktiskt för en avancerad användare att Windows har stängd källkod, och vilken nackdel kan det medföra?
5. Varför kan licenskostnaden vara en betydande nackdel för både privatpersoner och stora organisationer?
6. På vilket sätt är Windows enorma stöd för hårdvara och drivrutiner en av dess absolut största styrkor i praktiken?
7. Varför anses Windows fortfarande vara den ledande plattformen för gaming och tunga grafiska applikationer?
8. Vad menas med begreppet "Legacy Support" (bakåtkompatibilitet) och varför är detta en avgörande fördel för många företag?
9. Vilka nackdelar finns det med Windows inbyggda "telemetri" (datainsamling) ur ett integritetsperspektiv?
10. Hur påverkar Microsofts ekosystem av tjänster, som Office 365 och Teams, användarens upplevelse av att använda Windows i arbetslivet?

## Fördjupningslänkar

Microsoft (Windows 11 Overview och funktioner) –  
<https://www.microsoft.com/en-us/windows/windows-11>

Wikipedia (Usage share of operating systems) –  
[https://en.wikipedia.org/wiki/Usage\\_share\\_of\\_operating\\_systems](https://en.wikipedia.org/wiki/Usage_share_of_operating_systems)

Microsoft Learn (What is Windows? – Nyheter och arkitektur) –  
<https://learn.microsoft.com/en-us/windows/whats-new/>

How-To Geek (Pros and Cons of Windows vs Linux) –  
<https://www.howtogeek.com/117635/windows-vs.-linux-which-operating-system-is-better/>

TechRadar (Windows 11 review och omfattande analys) –  
<https://www.techradar.com/reviews/windows-11>

StatCounter (Global Desktop OS Market Share Statistics) –  
<https://gs.statcounter.com/os-market-share/desktop/worldwide>

Microsoft Learn (Windows 11 System Requirements och kompatibilitet) –  
<https://learn.microsoft.com/en-us/windows/whats-new/windows-11-requirements>

PCMag (Windows 11 vs. Windows 10: En teknisk jämförelse) –  
<https://www.pcmag.com/news/windows-11-vs-windows-10-whats-the-difference>

Digital Trends (Windows 11 vs. Linux för produktivitet och gaming) –  
<https://www.digitaltrends.com/computing/windows-11-vs-linux/>

## 6.4 Installation av Windows 11 i fysisk maskin/VM

### Kontrollfrågor

1. Vilket specifikt verktyg tillhandahåller Microsoft för att ladda ner officiella ISO-filer och skapa installationsmedia på ett USB-minne?
2. Vad behöver du göra i datorns BIOS eller UEFI-inställningar för att maskinen ska prioritera att starta från ett USB-minne istället för den interna hårddisken?
3. Varför behöver man ibland manuellt ändra boot-ordningen eller använda en specifik "Boot Menu"-tangent, även om installationsmedian redan sitter i datorn?
4. Beskriv hur man kan gå tillväga för att skapa ett lokalt offlinekonto vid installation av Windows 11, trots att installationsprogrammet som standard kräver ett Microsoft-konto.
5. Vad är den främsta fördelen med att installera och testa operativsystem i en virtuell maskin (VM) jämfört med att göra det på en fysisk dator ("bare metal")?
6. Vad är skillnaden mellan en "Uppgradering" (Upgrade) och en "Anpassad installation" (Custom) när du väljer installationstyp i Windows-guiden?
7. Hur ska du agera om inga hårddiskar visas i listan när du ska välja installationsplats, trots att du vet att en disk finns monterad (t.ex. vid saknade drivrutiner för lagringskontroller)?
8. Vad innebär begreppet "Secure Boot" och varför är det ett tekniskt krav för att kunna genomföra en standardinstallation av Windows 11?
9. Varför är det viktigt att installera tillägg som "Guest Additions" (VirtualBox) eller "VMware Tools" direkt efter att installationen i en virtuell maskin är klar?
10. Vad händer med funktionaliteten i Windows om man väljer att gå vidare med installationen utan att ange en produktnyckel (Product Key)?

## 6.5 Konfiguration och hantering av Windows

### Kontrollfrågor

1. Vad är den primära skillnaden mellan ett standardanvändarkonto och ett administratörskonto i Windows när det gäller systemförändringar?
2. Hur används grupper för att effektivisera hanteringen av rättigheter för många användare samtidigt på en arbetsplats?
3. Vad innebär det rent praktiskt att rättigheter "ärvs" (Inheritance) i en mappstruktur?
4. Beskriv hur du i det grafiska gränssnittet (Egenskaper -> Säkerhet) kontrollerar och ändrar rättigheter på en specifik fil eller mapp.
5. Ge exempel på tre inbyggda Windows-verktyg som används för felsökning eller underhåll och beskriv kort vad de används till.
6. Vad är User Account Control (UAC) och varför är det en viktig säkerhetsfunktion även för användare som är administratörer?
7. Varför anses det vara en säkerhetsrisk att använda ett administratörskonto för vardagliga sysslor som att surfa på webben eller läsa e-post?
8. Vilket verktyg (snap-in) använder du i Windows Pro/Enterprise för att hantera lokala användare och grupper mer detaljerat än i den vanliga inställningsmenyn?
9. Vad är skillnaden mellan NTFS-behörigheterna "Full kontroll" (Full Control) och "Ändra" (Modify)?
10. Hur kan Event Viewer (Loggboken) hjälpa en tekniker att identifiera orsaken till att en dator plötsligt har startat om eller kraschat?

## Fördjupningslänkar

Microsoft (Hantera användarkonton i Windows) –

<https://support.microsoft.com/en-us/windows/manage-user-accounts-in-windows-10-104dc19f-6430-4b49-6a2b-e4dbd1dcdf32>

Microsoft (Hur User Account Control - UAC fungerar) –

<https://learn.microsoft.com/en-us/windows/security/application-security/application-control/user-account-control/how-it-works>

Microsoft (Översikt av Access Control och rättigheter) –

<https://learn.microsoft.com/en-us/windows/win32/secauthz/access-control-overview>

How-To Geek (Använda Event Viewer för att felsöka problem) –

<https://www.howtogeek.com/123646/htg-explains-what-the-windows-event-viewer-is-and-how-you-can-use-it/>

Microsoft (Felsökning med Task Manager) – <https://support.microsoft.com/en-us/windows/how-to-use-task-manager-in-windows-10-86036815-5853-2d57-41fe-cfca5a9e334d>

Lifewire (Guide till Computer Management-konsolen) –

<https://www.lifewire.com/how-to-open-computer-management-in-windows-2626076>

Wikipedia (Access Control List - ACL förklarat) –

[https://en.wikipedia.org/wiki/Access-control\\_list](https://en.wikipedia.org/wiki/Access-control_list)

Microsoft (Skillnader mellan lokala konton och Microsoft-konton) –

<https://learn.microsoft.com/en-us/windows/security/identity-protection/access-control/local-accounts>

## 6.7 Workgroup, Domain och Active Directory

### Kontrollfrågor

1. Vad är den tekniska och licensmässiga huvudskillnaden mellan Windows Server Standard och Datacenter Edition?
2. I vilka specifika scenarier bör du välja en "Core"-installation framför "Desktop Experience", och vilka är fördelarna?
3. Vad är det övergripande syftet med att skapa en domän i ett företagsnätverk?
4. Hur skiljer sig en Workgroup från en domän när det gäller var användarkonton lagras och hur de hanteras?
5. Vad används Active Directory (ADDS) till och vilken roll spelar det för säkerheten i en organisation?
6. Vad är skillnaden mellan en "Server Role" (t.ex. DNS-server) och en "Feature" (t.ex. BitLocker) i Windows Server?
7. Hur fungerar Microsofts licensmodell för Windows Server (Core-based licensing) i korta drag?
8. Varför är DNS-rollen så kritisk för att en Active Directory-domän ska fungera överhuvudtaget?
9. Vilket verktyg eller kommando använder man i en Windows Server Core-miljö för att göra grundinställningar som IP-adress och datornamn?
10. Vad innebär begreppet "Single Sign-On" (SSO) och hur möjliggörs detta genom användandet av en domänstruktur?

## Fördjupningslänkar

Microsoft Learn (Windows Server Installation Overview) –

<https://learn.microsoft.com/en-us/windows-server/get-started/>

Microsoft Docs (Jämför utgåvor av Windows Server Standard och Datacenter) –

<https://learn.microsoft.com/en-us/windows-server/get-started/editions-comparison>

JumpCloud (Vad är Active Directory? – En grundläggande guide) –

<https://jumpcloud.com/blog/what-is-active-directory>

Microsoft Learn (Översikt av Group Policy och central styrning) –

<https://learn.microsoft.com/en-us/windows-server/administration/windows-commands/group-policy>

How-To Geek (Skillnaden mellan Domain, Workgroup och Homegroup) –

<https://www.how-to-geek.com/195305/whats-the-difference-between-a-domain-a-workgroup-and-a-homegroup/>

Microsoft Learn (Introduktion till Active Directory Domain Services - ADDS) –

<https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/get-started/ad-ds-getting-started>

TechTarget (Windows Server Roles och Features förklarar för tekniker) –

<https://www.techtarget.com/searchwindowsserver/tip/A-guide-to-Windows-Server-roles-and-features>

Microsoft Learn (Hårdvarukrav för Windows Server-installation) –

<https://learn.microsoft.com/en-us/windows-server/get-started/hardware-requirements>

## 7 Linux – Historia, filosofi och ekosystem

### 7.1 Vad är Linux?

#### Kontrollfrågor

1. Vem är Linus Torvalds och vad var hans ursprungliga mål när han skapade Linux 1991?
2. Vad är den tekniska skillnaden mellan Linux-kärnan (kernel) och ett komplett operativsystem som till exempel Ubuntu?
3. Förklara begreppet "Öppen källkod" (Open Source) och hur det skiljer sig fundamentalt från proprietär mjukvara som Windows eller macOS.
4. Vilken roll spelade Richard Stallman och GNU-projektet för framväxten av det vi idag kallar Linux?
5. Vad är en "Linux-distribution" (distro) och varför finns det så många olika varianter istället för bara en?
6. Varför är GPL-licensen (General Public License) så viktig för Linux-ekosystemets utveckling och fortlevnad?
7. Nämn tre områden där Linux är det helt dominerande operativsystemet idag (t.ex. superdatorer, servrar, etc.).
8. Varför föredrar vissa att använda termen "GNU/Linux" istället för att bara säga "Linux"?
9. Vilket historiskt operativsystem fungerade som den primära inspirationen för Linux arkitektur och kommandon?
10. Vad innebär det för en användare eller ett företag att de har "frihet" att modifiera källkoden i sitt operativsystem?

## Fördjupningslänkar

Linux Foundation (Organisationen som stödjer utvecklingen av Linux) – <https://www.linuxfoundation.org/>

The GNU Project (Läs mer om den fria mjukvarurörelsens rötter och filosofi) – <https://www.gnu.org/>

Linus Torvalds TED-talk (En intervju med skaparen av Linux och Git om hans drivkrafter) – [https://www.ted.com/talks/linus\\_torvalds\\_the\\_mind\\_behind\\_linux](https://www.ted.com/talks/linus_torvalds_the_mind_behind_linux)

Kernel.org (Den officiella webbplatsen för Linuxkärnans källkod och utveckling) – <https://www.kernel.org/>

DistroWatch (Översikt, nyheter och ranking av hundratals olika Linux-distributioner) – <https://distrowatch.com/>

Open Source Initiative (Definitionen av öppen källkod och dess juridiska ramverk) – <https://opensource.org/>

Linux Journey (En omfattande och pedagogisk guide för att lära sig Linux från grunden) – <https://linuxjourney.com/>

Debian (Moderdublen till många distros och ett exempel på ett helt community-drivet projekt) – <https://www.debian.org/>

TuxDigital (Nyheter och analyser kring hur Linux används i dagens IT-värld) – <https://tuxdigital.com/>

## 7.2 Linuxkärnans grenar (distributioner)

### Kontrollfrågor

1. Vad är en Linux-distribution (distro) och varför finns det så många olika "smaker"?
2. Nämn de tre stora "familjerna" av distributioner som nämns i texten och ge ett exempel på en distro i varje familj.
3. Förklara det grundläggande konceptet "Everything is a file". Vad innebär det för en tekniker?
4. Hur skiljer sig Linux hantering av hårddiskar och USB-minnen från Windows sätt med enhetsbokstäver (C:, D:)?
5. Vad innebär begreppet "mounting" (montering)?
6. Ge ett exempel på hur Case Sensitivity (skiftlägeskänslighet) kan ställa till det om man är van vid Windows.
7. Vilken mapp i filsystemet fungerar som operativsystemets "kontrollpanel" där konfigurationsfilerna ligger?
8. Om en server börjar få slut på diskutrymme, i vilken mapp är det troligast att man hittar stora loggfiler som kan raderas?
9. Vad är skillnaden mellan mappen /home och mappen /root?

## Fördjupningslänkar

DistroWatch (Den främsta sidan för att följa, jämföra och hitta nya Linux-distributioner) - <https://distrowatch.com/>

Linux Journey (En interaktiv och pedagogisk guide till hur Linux filsystem är uppbyggt) - <https://linuxjourney.com/lesson/filesystem-hierarchy>

Filesystem Hierarchy Standard (Den officiella tekniska specifikationen för hur mappar ska organiseras i Linux) - [https://refspecs.linuxfoundation.org/FHS\\_3.0/fhs/index.html](https://refspecs.linuxfoundation.org/FHS_3.0/fhs/index.html)

Explain Shell (Ett smart verktyg som visuellt förklarar vad varje del av ett terminalkommando gör) - <https://explainshell.com/>

The Linux Command Line (En komplett bok online som täcker allt från grunder till avancerad terminalanvändning) - <https://linuxcommand.org/tlcl.php>

Ryan's Tutorials (En mycket bra nybörjarguide till terminalen och grundläggande kommandon) - <https://ryanstutorials.net/linuxtutorial/>

ArchWiki (Djupgående och teknisk genomgång av Linux filsystemshierarki) - [https://wiki.archlinux.org/title/Linux\\_file\\_hierarchy](https://wiki.archlinux.org/title/Linux_file_hierarchy)

Cheat.sh (Snabbguide till tusentals Linux-kommandon direkt via webbläsaren eller terminalen) - <https://cheat.sh/>

Linux Die.net (Den klassiska samlingen av manual-sidor (man pages) för alla Linux-kommandon) - <https://linux.die.net/>

## 7.3 Fördelar och nackdelar med Linuxsystem

### Kontrollfrågor

1. Vad innebär begreppet "Open Source" (öppen källkod) och varför är det en säkerhetsfördel?
2. Förklara begreppet "uptime" och varför Linux ofta har högre uptime än Windows i servermiljöer.
3. Vad menas med att köra en server "headless" och vilken är den största prestandafördelen med det?
4. Hur påverkar bristen på licenskostnader skalbarheten i molntjänster?
5. På vilket sätt minskar Linux "attackyta" genom att vara modulärt?
6. Varför anses Linux rättighetssystem vara säkrare mot virus än traditionella användarkonton i äldre operativsystem?
7. Vad är den främsta orsaken till att vissa hårdvarutillverkare inte prioriterar drivrutiner för Linux?
8. Förklara begreppet fragmentering och hur det kan försvåra för mjukvaruutvecklare.
9. Vad är "root" och varför ska man inte använda det kontot för vardagliga uppgifter?
10. Ge exempel på en bransch eller användningsområde där Windows fortfarande är ett starkare val än Linux på grund av mjukvarustöd.

## Fördjupningslänkar

Linux Foundation (Om öppen källkod) – En djupdykning i hur open source-ekosystemet fungerar och dess betydelse för industrin.

<https://www.linuxfoundation.org/resources/open-source-guides>

Ubuntu: Linux vs Windows (Server) – En jämförelse fokuserad på serverdrift och säkerhet från en av de största distributörerna. <https://ubuntu.com/blog/linux-vs-windows-server>

DistroWatch (Översikt av fragmentering) – En sida som listar hundratals olika distributioner och visar på Linux enorma bredd. <https://distrowatch.com>

Linux Journey (Lärplattform) – En pedagogisk steg-för-steg-guide för att lära sig terminalen och systemets grunder. <https://linuxjourney.com>

The Kernel Newbies (Linuxkärnan) – För dig som vill förstå exakt hur kärnan är uppbyggd och hur den kommunicerar med hårdvaran.

<https://kernelnewbies.org>

Electronic Frontier Foundation (Säkerhet & Integritet) – Om varför transparens i mjukvara är viktigt för personlig integritet och säkerhet.

<https://www.eff.org/issues/free-software>

Phoronix (Prestandatester) – Tekniska tester och jämförelser av hur Linux presterar på olika typer av hårdvara. <https://www.phoronix.com>

Red Hat Enterprise Linux (Supportmodeller) – Exempel på hur kommersiell support fungerar inom Linux-världen.

<https://www.redhat.com/en/technologies/linux-platforms/enterprise-linux>

WineHQ (Köra Windows-program) – Databas över hur väl olika Windows-applikationer fungerar under Linux. <https://www.winehq.org>

Arch Wiki (Teknisk dokumentation) – Kanske världens mest omfattande dokumentation om hur man konfigurerar Linux in i minsta detalj.

<https://wiki.archlinux.org>

## 7.4 Installation av Ubuntu Desktop

### Kontrollfrågor

1. Vad är Ubuntu och varför är det en av de mest använda Linuxdistributionerna?
2. Vad heter organisationen som står bakom Ubuntu?
3. Hur döps Ubuntu-versioner och vad betyder till exempel "24.04"?
4. Vad innebär LTS och hur länge får en sådan version support?
5. Vad är skillnaden mellan en LTS-version och en STS-version?
6. Vilket verktyg kan du använda i Windows för att skapa ett startbart USB-minne?
7. Vad är Secure Boot, och varför behöver man känna till det vid Linuxinstallation?
8. Vad är MOK och när kan det behövas?
9. Varför bör man markera alternativet "Install third-party software..." under installationen?
10. Hur kan man aktivera proprietära drivrutiner i efterhand?

## Fördjupningslänkar

Ubuntu Desktop Download (Officiell sida för att ladda ner installationsavbildningen) - <https://ubuntu.com/download/desktop>

Canonical (Företaget bakom Ubuntu och dess kommersiella support) - <https://canonical.com>

What is Secure Boot (Teknisk genomgång av hur Ubuntu fungerar med UEFI Secure Boot) - <https://wiki.ubuntu.com/UEFI/SecureBoot>

Installing Proprietary Drivers (Guide för installation av stängda drivrutiner för t.ex. Nvidia) - <https://help.ubuntu.com/community/BinaryDriverHowto>

Ubuntu LTS vs STS (Förklaring av Ubuntus olika releaser och livscyklar) - <https://ubuntu.com/blog/ubuntu-release-cycle-explained>

BalenaEtcher (Rekommenderat verktyg för att skapa startbara USB-minnen) - <https://www.balena.io/etcher/>

Ubuntu Community Help (Samlad officiell dokumentation för installation och konfiguration) - <https://help.ubuntu.com/>

## 7.5 Konfiguration av Ubuntu Desktop

### Kontrollfrågor

1. Vad är ett repository och varför behövs det?
2. Nämn tre sätt att installera program i Ubuntu.
3. Vad är skillnaden mellan /etc och /home?
4. Hur monteras en USB-sticka in i Linuxfilsystemet?
5. Vad gör kommandot `chmod 644 fil.txt`?
6. Vad betyder `-rw-r--r--` i rättighetssträngen?
7. Hur lägger du till en användare i en grupp?
8. Hur kan du starta om nätverksanslutningen i Ubuntu?
9. Vad gör `journalctl -xe` och när är det användbart?
10. Vilket grafiskt verktyg kan du använda för backup i Ubuntu?

## Fördjupningslänkar

Ubuntu (Basic Troubleshooting Guide och felsökningsgrunder) –  
<https://help.ubuntu.com/community/LinuxQuestionsHowTo>

How-To Geek (8 dödliga kommandon du aldrig bör köra i Linux) –  
<https://www.howtogeek.com/125157/8-deadly-commands-you-should-never-run-on-linux/>

Linux Handbook (Guide till att läsa och förstå loggfiler i Linux) –  
<https://linuxhandbook.com/view-log-files-linux/>

DigitalOcean (Hur man använder fsck för att kontrollera och reparera filsystem) –  
<https://www.digitalocean.com/community/tutorials/fsck-command-linux>

Linuxize (Djupgående guide till kommandot top för processhantering) –  
<https://linuxize.com/post/linux-top-command/>

DigitalOcean (Grunderna i pakethantering med apt, yum och dnf) –  
<https://www.digitalocean.com/community/tutorials/package-management-basics-apt-yum-dnf-pkg>

Snapcraft (Officiell dokumentation för Snap-paket i Ubuntu) –  
<https://snapcraft.io/docs>

Linuxize (Hur man använder apt-kommandot för att hantera mjukvara och uppdateringar) –  
<https://linuxize.com/post/how-to-use-apt-command/>

Linux Handbook (Introduktion till systemd och systemctl för att hantera tjänster) –  
<https://linuxhandbook.com/systemd-guide/>

## 7.6 Installation av Ubuntu Server och Webmin

### Kontrollfrågor

1. Vad är skillnaden mellan Ubuntu Desktop och Ubuntu Server?
2. Vad är fördelen med att Ubuntu Server saknar grafiskt gränssnitt?
3. Vad kan du göra under installationen om servern inte får någon IP-adress automatiskt?
4. Vilken typ av användare och lösenord skapar du under installationen?
5. Vad används OpenSSH till och varför bör det installeras på en server?
6. Varför rekommenderas det att börja med en "ren" installation utan extra tjänster?
7. Vad är Webmin och varför kan det vara ett bra verktyg i en undervisningsmiljö?
8. Hur når du Webmin när det är installerat?
9. Vad betyder det att Webmin använder ett självsignerat certifikat?
10. Vilka två kommandon används för att installera Webmin med det officiella installationsscriptet?

## Fördjupningslänkar

Ubuntu Server Download (Ladda ner den senaste versionen av Ubuntu Server ISO) - <https://ubuntu.com/download/server>

Ubuntu Server Guide (Officiell teknisk dokumentation för Ubuntu Server) - <https://ubuntu.com/server/docs>

Webmin (Officiell webbplats för administrationsverktyget Webmin) - <https://www.webmin.com>

Webmin GitHub Repository (Projektets källkod och utvecklingshistorik) - <https://github.com/webmin/webmin>

Install Webmin on Ubuntu (Detaljerad installationsguide från ComputingForgeeks) - <https://computingforgeeks.com/how-to-install-webmin-on-ubuntu/>

Webmin Documentation Wiki (Omfattande manual för alla inbyggda moduler i Webmin) - [https://doxfer.webmin.com/Webmin/Main\\_Page](https://doxfer.webmin.com/Webmin/Main_Page)

DigitalOcean (Initial Server Setup med Ubuntu - viktiga säkerhetssteg efter installation) - <https://www.digitalocean.com/community/tutorials/initial-server-setup-with-ubuntu-22-04>

Linuxize (Hur man installerar och konfigurerar SSH på Ubuntu Server) - <https://linuxize.com/post/how-to-enable-ssh-on-ubuntu-22-04/>

Ubuntu Community (Guide till UFW - Uncomplicated Firewall för att säkra din server) - <https://help.ubuntu.com/community/UFW>

## 7.7 Linux grundläggande kommandon

### Kontrollfrågor

1. Vad innebär det att Linux är skiftlägeskänsligt?
2. Vilka tre sätt kan du använda för att få hjälp med kommandon i Bash?
3. Vad gör kommandot `whatis`?
4. Vad är skillnaden mellan `for`- och `while`-loopar i Bash?
5. Vad används `whiptail` till?
6. Hur skapar man ett enkelt Bash-script?
7. Varför är det viktigt att förstå terminalen även om man använder GUI?
8. Vad händer om man använder en stor bokstav i ett kommando som är skiftlägeskänsligt?
9. Ge exempel på två kommandon för att navigera i filsystemet.
10. Vad betyder kommandot `chmod +x filnamn.sh`?

## Fördjupningslänkar

Linux Journey (Interaktiv guide för Linux-grunder och terminalhantering) – <https://linuxjourney.com/>

GNU Bash Manual (Den officiella och kompletta tekniska manualen för Bash) – <https://www.gnu.org/software/bash/manual/>

Ubuntu Tutorials (Kommandoraden för nybörjare – en praktisk och stegvis introduktion) – <https://ubuntu.com/tutorials/command-line-for-beginners>

The Linux Documentation Project (Klassisk och djupgående Bash-guide för nybörjare) – <https://tldp.org/LDP/Bash-Beginners-Guide/html/>

Shellscript.sh (En omfattande guide för att lära sig skriva egna skalmanus från grunden) – <https://www.shellscript.sh/>

Ryans Tutorials (Pedagogisk genomgång av Bash-skripting, variabler och loopar) – <https://ryanstutorials.net/bash-scripting-tutorial/>

Learn Shell (Interaktiv webbmiljö för att öva på skalskript direkt i webbläsaren) – <https://www.learnshell.org/>

GeeksforGeeks (Bash Scripting – Teknisk referens med praktiska kodexempel) – <https://www.geeksforgeeks.org/bash-scripting-introduction/>

Bash Academy (En modern guide som fokuserar på att skriva säkra och effektiva skript) – <https://bash.academy/>

## 8 Systemhärdning och säkerhet

### 8.1 Säkerhet i Windowsmiljö

#### 8.1.1 Grundläggande säkerhetsprinciper och Windows Security

##### Kontrollfrågor

1. Vad innebär principen om "Minsta möjliga behörighet" i ett Windows-sammanhang?
2. Förklara begreppet Defense in Depth och ge exempel på två "lager" i Windows.
3. Vilken är den främsta skillnaden mellan Windows Security och Microsoft Defender?
4. Varför kräver Windows 11 en TPM 2.0-modul för att fungera optimalt?
5. På vilket sätt skyddar Secure Boot datorn under uppstartsprocessen?
6. Vad händer med Windows inbyggda skydd om du installerar ett annat antivirusprogram?
7. Vad är syftet med SmartScreen-filtret i Windows?
8. Var i Windows hittar du enklast en översikt över systemets aktuella säkerhetsstatus?
9. Hur samarbetar TPM med krypteringstjänster som BitLocker?
10. Varför är det en säkerhetsrisk att arbeta med ett användarkonto som har permanenta administratörsrättigheter?

## Fördjupningslänkar

Microsoft (Officiell dokumentation om Windows-säkerhet, arkitektur och strategier) – <https://learn.microsoft.com/en-us/windows/security/>

Microsoft (Supportguide till de inbyggda funktionerna i Windows säkerhetscenter) – <https://support.microsoft.com/windows/stay-protected-with-windows-security>

PCMag (Teknisk förklaring av Trusted Platform Module - TPM och dess roll i modern IT-säkerhet) – <https://www.pcmag.com/how-to/what-is-a-tpm-chip>

Ubuntu Wiki (Teknisk genomgång av hur UEFI Secure Boot skyddar uppstartsprocessen universellt) – <https://wiki.ubuntu.com/UEFI/SecureBoot>

Microsoft Learn (Core Isolation och Memory Integrity – Hur Windows använder virtualisering för att skydda kärnan) – <https://learn.microsoft.com/en-us/windows/security/threat-protection/device-guard/enable-virtualization-based-protection-of-code-integrity>

## 8.1.2 UAC och Integrity Levels

### Kontrollfrågor

1. Vad är det primära syftet med User Account Control (UAC)?
2. Förklara begreppet **Dual Tokens** – vad händer tekniskt när en administratör loggar in?
3. Varför är arkitekturen med **Integrity Levels** viktig för att stoppa skadlig kod?
4. Vilken Integrity Level har ett vanligt program som du startar, t.ex. Microsoft Word?
5. Vad innebär "Secure Desktop" (att skärmen tonas ner) när en UAC-ruta dyker upp?
6. Varför var Windows XP mer sårbart för virus jämfört med Windows 11 när det gäller användarrättigheter?
7. Vad händer om en användare med ett **Standardkonto** försöker installera ett program som kräver UAC?
8. Varför rekommenderas det inte att använda inställningen "Aldrig meddela"?
9. Vad innebär begreppet UIPI (User Interface Privilege Isolation)?
10. Ge ett exempel på en process som körs med integritetsnivån **System**.

## Fördjupningslänkar

Microsoft Learn (How UAC Works – En djupdykning i arkitekturen och processerna bakom User Account Control) –

<https://learn.microsoft.com/en-us/windows/security/application-security/application-control/user-account-control/how-it-works>

Microsoft Learn (Windows Integrity Mechanism – Detaljerad information om hur Windows tilldelar trovärdighetsnivåer till olika processer) –

[https://learn.microsoft.com/en-us/previous-versions/dotnet/articles/bb625963\(v=msdn.10](https://learn.microsoft.com/en-us/previous-versions/dotnet/articles/bb625963(v=msdn.10)

Microsoft Support (UAC Settings Guide – En praktisk guide till de olika inställningsnivåerna och vad de faktiskt gör) –

<https://support.microsoft.com/windows/how-user-account-control-works-28e78cbf-f6ed-a870-13f9-717013f97401>

Microsoft Learn (Access Tokens – Hur UAC skapar och hanterar begränsade tokens för att skydda systemet) –

<https://learn.microsoft.com/en-us/windows/win32/secauthz/access-tokens>

Microsoft Learn (Sudo for Windows – Introduktion till det nya verktyget som för in Linux-liknande privilegiehantering i Windows-terminalen) –

<https://learn.microsoft.com/en-us/windows/terminal/sudo/>

### 8.1.3 Microsoft Defender & Ransomware-skydd

#### Kontrollfrågor

- 1 Vad innebär funktionen **Tamper Protection** (Manipulationsskydd) och varför är den kritisk för att stoppa avancerad skadlig kod?
- 2 Förklara hur **molnbaserat skydd** (Cloud-delivered Protection) fungerar för att stoppa en "Zero-day"-attack som ännu inte finns i den lokala virusdatabasen.
- 3 Hur fungerar **Controlled Folder Access** (Kontrollerad mappåtkomst) rent tekniskt – bygger den på en "svartlista" eller en "vitlista"?
- 4 Beskriv den exakta sökvägen i Windows-säkerhet för att nå inställningarna där du kan aktivera ransomware-skyddet.
- 5 Vad bör du som tekniker göra om en användares legitima ritprogram blockeras från att spara filer av Windows Defender?
- 6 Vad är den största skillnaden mellan ett traditionellt antivirus (AV) och en **EDR-plattform** som Microsoft Defender for Endpoint?
- 7 Vad menas med begreppet **telemetry** i samband med säkerhetsanalys i molnet?
- 8 Nämn två specifika åtgärder en administratör kan vidta i Microsoft Defender-portalen (security.microsoft.com) vid en pågående attack.
- 9 Varför är det klokt att aktivera **Periodisk genomsökning** om man har ett annat antivirusprogram (t.ex. F-Secure) installerat?
- 10 Varför rekommenderas det att använda "Audit Mode" (Granskningsläge) innan man rullar ut kontrollerad mappåtkomst i ett helt företagsnätverk?

## Fördjupningslänkar

Microsoft Learn (Microsoft Defender Antivirus – Teknisk dokumentation om motorer, molnbaserat skydd och inställningar) – <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/microsoft-defender-antivirus-windows>

AV-TEST (Oberoende tester av Defenders prestanda och skyddsnivå för hem- och företagsanvändare) – <https://www.av-test.org/en/antivirus/home-windows/>

Microsoft Learn (Defender for Endpoint – Översikt av EDR-funktioner och avancerat skydd i större nätverk) – <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/microsoft-defender-endpoint>

Microsoft Learn (Controlled Folder Access – Officiell guide för att konfigurera skydd mot ransomware och obehöriga ändringar) – <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/controlled-folders>

Microsoft Learn (Tamper Protection – Hur man förhindrar att skadlig kod eller obehöriga användare stänger av säkerhetsfunktioner) – <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/prevent-changes-to-security-settings-with-tamper-protection>

## 8.1.4 Group policy och säkerhetsmallar

### Kontrollfrågor

1. Vad är skillnaden i användningsområde mellan gpedit.msc och gpmmc.msc?
2. Beskriv prioritetsordningen i **LSDOU**. Vilken policy vinner vid en konflikt?
3. Varför delas en GPO upp i *Computer* och *User* konfiguration?
4. Vad är fördelen med att använda en färdig .inf-mall istället för att klicka i inställningar manuellt?
5. När är det lämpligt att använda **Loopback Processing**?
6. Hur kan GPO användas för att förhindra att skadlig kod sprids via USB-minnen?
7. Vad gör verktyget *Security Configuration and Analysis*?
8. Varför finns inte lokal gruppolicy i Windows Home?
9. Vilket kommando använder du för att tvinga en dator att hämta nya policys direkt?
10. Vad innebär en "Security Baseline"?

## Fördjupningslänkar

Microsoft Learn (Group Policy Overview – En omfattande teknisk genomgång av arkitekturen bakom gruppprinciper) – [https://learn.microsoft.com/en-us/previous-versions/windows/it-pro/windows-server-2012-r2-and-2012/hh831791\(v=ws.11](https://learn.microsoft.com/en-us/previous-versions/windows/it-pro/windows-server-2012-r2-and-2012/hh831791(v=ws.11)

Microsoft Learn (Windows Security Baselines – Ladda ner och implementera Microsofts officiella säkerhetsmallar för härdning) – <https://learn.microsoft.com/en-us/windows/security/threat-protection/windows-security-baselines>

Microsoft Tech Community (Policy Analyzer – Ett kraftfullt verktyg för att jämföra GPO:er och analysera hur de avviker från säkerhetsbaselines) – <https://techcommunity.microsoft.com/t5/microsoft-security-baselines/policy-analyzer-v4-0/ba-p/462491>

Microsoft Learn (Local Group Policy Editor – Hur man konfigurerar policyer lokalt på enskilda datorer som inte ingår i en domän) – <https://learn.microsoft.com/en-us/windows/client-management/manage-windows-10-and-windows-server-2016-with-local-group-policy-editor>

CIS Benchmarks (Världsledande och oberoende standard för säker konfiguration av Windows – ett viktigt komplement till Microsofts egna mallar) – [https://www.cisecurity.org/benchmark/microsoft\\_windows\\_desktop](https://www.cisecurity.org/benchmark/microsoft_windows_desktop)

## 8.1.5 Avancerad NTFS-behörighet

### Kontrollfrågor

1. Vad är den tekniska skillnaden mellan behörigheterna **Modify** och **Full Control**?
2. Förklara vad som händer med rättigheterna om du **kopierar** en fil från en mapp till en annan.
3. Du flyttar en fil från C:\Mapp1 till C:\Mapp2 (samma volym). Kommer filen att behålla sina gamla rättigheter eller ärva nya?
4. Varför försvinner alla behörigheter om du flyttar en fil till ett USB-minne formaterat med FAT32?
5. Vilka två val har du när du väljer att inaktivera arv (inheritance) på en mapp?
6. Om en användare har "Tillåt: Modify" via en grupp, men "Neka: Modify" direkt på sitt konto – får användaren ändra filen?
7. Hur fungerar logiken när man kombinerar **Share Permissions** med **NTFS Permissions** vid nätverksåtkomst?
8. Vad innebär det att rättigheter är **kumulativa**?
9. Vilket verktyg (CLI) kan en tekniker använda för att snabbt ta backup på rättigheterna för en hel mappstruktur?
10. Vad är risken med att flytta en mapp med känsliga rättigheter mellan två olika hårddiskar (t.ex. från C: till D:)?

## Fördjupningslänkar

Microsoft Learn (Access Control Overview – Den officiella genomgången av Windows säkerhetsmodell för objekt och resurser) –

<https://learn.microsoft.com/en-us/windows/win32/secauthz/access-control-model>

NTFS.com (NTFS Permissions vs Share Permissions – En teknisk och tydlig jämförelse mellan lokala rättigheter och nätverksdelning) –

<https://www.ntfs.com/ntfs-permissions.htm>

SS64 (icacls Command Syntax – En omfattande referens för hur man hanterar och automatiserar rättigheter via kommandotolken) –

<https://ss64.com/nt/icacls.html>

Microsoft Learn (Inheritance and Effective Permissions – Hur arv fungerar och hur Windows beräknar den slutgiltiga åtkomsten för en användare) –

<https://learn.microsoft.com/en-us/windows-server/storage/file-server/ntfs-permissions-inheritance>

Varonis (NTFS Permissions Explained – En praktisk genomgång av rättighetsnivåer och vanliga fallgropar för administratörer) –

<https://www.varonis.com/blog/ntfs-permissions-everything-you-need-to-know>

## 8.1.6 BitLocker och EFS – Kryptering på disk- och filnivå

### Kontrollfrågor

1. Vad är den huvudsakliga skillnaden i användningsområde mellan BitLocker och EFS?
2. Varför föredrar tekniker ofta AES-256 framför AES-128 trots att det kräver mer beräkningskraft?
3. Förklara kort rollen för TPM-chippet vid en normal uppstart av en krypterad dator.
4. Nämn tre specifika händelser som gör att BitLocker kräver en återställningsnyckel.
5. Hur fungerar **BitLocker To Go** och varför kräver det ett lösenord istället för TPM?
6. Vad händer med EFS-krypterade filer om du flyttar dem till ett USB-minne formaterat med FAT32? (Tips: Tänk på kravet för EFS).
7. Var i Kontrollpanelen hanterar du BitLocker grafiskt?
8. Vilket kommando i terminalen använder du för att se en disks krypteringsstatus?
9. Vad är "brute force" och varför gör AES-kryptering det praktiskt omöjligt att använda?
10. Varför är det viktigt för en tekniker att "pausa" BitLocker innan man uppdaterar datorns BIOS/UEFI?

## Fördjupningslänkar

Microsoft Learn (BitLocker Guide – En omfattande teknisk djupdykning i arkitektur, krav och implementering) –

<https://learn.microsoft.com/en-us/windows/security/operating-system-security/data-protection/bitlocker/>

ATP Inc (AES Encryption Explained – En pedagogisk genomgång av hur AES-algoritmen fungerar matematiskt och tekniskt) –

<https://www.atpinc.com/blog/what-is-aes-256-encryption>

Microsoft Learn (Manage-bde Command Reference – En komplett guide till alla parametrar för att administrera BitLocker via kommandotolken) –

<https://learn.microsoft.com/en-us/windows-server/administration/windows-commands/manage-bde>

Microsoft Support (Hitta din BitLocker-återställningsnyckel – En kritisk resurs för att hantera låsta system och nyckelåterställning) –

<https://support.microsoft.com/windows/finding-your-bitlocker-recovery-key-in-windows-6b71ad27-0b89-ea08-f143-056f5ab347d6>

VeraCrypt (Officiell webbplats för VeraCrypt – Det mest populära öppna alternativet till BitLocker för diskryptering och dolda volymer) –

<https://www.veracrypt.fr/en/Home.html>

## 8.1.7 Windows-brandväggen med avancerad säkerhet

### Kontrollfrågor

1. Vilket snabbkommando (.msc) används för att öppna brandväggens avancerade gränssnitt?
2. När är det mer lämpligt att använda en **programbaserad regel** istället för en portbaserad?
3. Förklara hur funktionen **Scope** kan användas för att öka säkerheten för en server.
4. Vad innebär det att en brandvägg utför "Stateful Packet Inspection"?
5. Vilken port (TCP) förknippas oftast med HTTP-trafik och vilken används för HTTPS?
6. Vad är skillnaden i logik mellan **Inkommande** och **Utgående** regler i standardutförande?
7. Varför anses det vara en säkerhetsrisk att tillåta RDP (port 3389) från "Any IP address" i fältet för Scope?
8. Hur ser administratören om ett specifikt nätverkspaket har blockerats (DROPPED) av systemet?
9. Vilket protokoll (TCP eller UDP) används oftast för tillförlitlig dataöverföring som t.ex. webbsurfning?
10. Vad händer med brandväggens beteende när en dator flyttas från ett kontorsnätverk (Domän) till ett kafé (Offentlig)?

## Fördjupningslänkar

Microsoft Learn (Windows Defender Firewall with Advanced Security – Fullständig teknisk referens och arkitektur) – <https://learn.microsoft.com/en-us/windows/security/operating-system-security/network-security/windows-firewall/>

CompTIA (TCP and UDP Ports Explained – En omfattande guide till hur nätverksportar fungerar och de vanligaste portnumren) – <https://www.comptia.org/content/guides/port-numbers>

Microsoft Learn (Best Practices for Configuring Windows Defender Firewall – Officiella strategier för att skapa säkra brandväggsregler) – <https://learn.microsoft.com/en-us/windows/security/operating-system-security/network-security/windows-firewall/best-practices-configuring-windows-defender-firewall>

Microsoft Learn (Netsh Advfirewall Command-Line – Teknisk guide för att hantera och automatisera brandväggen via kommandotolken) – <https://learn.microsoft.com/en-us/windows-server/administration/windows-commands/netsh-advfirewall>

How-To Geek (Windows Network Profiles – En tydlig förklaring av skillnaderna mellan offentliga, privata och domännätverksprofiler) – <https://www.howtogeek.com/245177/whats-the-difference-between-private-and-public-networks-in-windows/>

## 8.1.8 Autentisering: Kerberos, NTLM, Windows Hello och SSO

### Kontrollfrågor

1. Vilken funktion fyller en **Key Distribution Center (KDC)** i ett Kerberos-baserat nätverk?
2. Förklara skillnaden mellan en **Ticket-Granting Ticket (TGT)** och en **Service Ticket**.
3. Varför anses NTLM vara ett osäkert protokoll jämfört med Kerberos i en modern miljö?
4. Beskriv hur en **Pass-the-Hash-attack** går till rent logiskt.
5. Hur bidrar **TPM-chippet** till säkerheten i Windows Hello for Business?
6. Vad innebär det att Windows Hello baseras på standarden **FIDO2**?
7. På vilket sätt fungerar Kerberos som en Single Sign-On-lösning (SSO)?
8. Vad är en **Primary Refresh Token (PRT)** och när används den?
9. Vilket händelse-ID i Loggboken bör en administratör leta efter för att granska lyckade inloggningar?
10. Vilket kommando används i terminalen för att se aktuella Kerberos-biljetter på en klientdator?

## Fördjupningslänkar

Microsoft Learn (Kerberos Authentication Overview – En teknisk djupdykning i hur biljetter och autentisering fungerar i en Active Directory-miljö) –

<https://learn.microsoft.com/en-us/windows-server/security/kerberos/kerberos-authentication-overview>

Microsoft Learn (Windows Hello for Business – Arkitekturen bakom nyckelbaserad och biometrisk inloggning för säkrare identifiering) –

<https://learn.microsoft.com/en-us/windows/security/identity-protection/hello-for-business/hello-identity-design>

CrowdStrike (Everything you need to know about NTLM – En genomgång av protokollets historia, dess sårbarheter och varför det fasas ut) –

<https://www.crowdstrike.com/cybersecurity-101/ntlm-windows-new-technology-lan-manager/>

Microsoft Learn (Modern Authentication – Hur Multi-Factor Authentication och lösenordslös inloggning skyddar mot identitetsstöld) –

<https://learn.microsoft.com/en-us/entra/architecture/auth-modern>

Yubico (FIDO2 and WebAuthn – En förklaring av de moderna globala standarderna för hårdvarubaserad autentisering utan lösenord) –

<https://www.yubico.com/resources/glossary/fido2/>

### 8.1.9 Revision och Loggning (Auditing)

#### Kontrollfrågor

1. Vad är den primära skillnaden mellan en preventiv säkerhetsåtgärd (som en brandvägg) och en reaktiv åtgärd (som revision)?
2. Varför är det kritiskt att logga både **Success** och **Failure** för inloggningshändelser?
3. Vilket verktyg (.msc) används för att konfigurera **Granskningsprinciper (Audit Policies)** lokalt på en dator?
4. I vilken specifik logg i **Loggboken (Event Viewer)** återfinns information om misslyckade inloggningsförsök?
5. Förklara innebörden av händelse-ID **4625**.
6. Varför krävs det manuella inställningar på en specifik mapp utöver den globala policyn för att kunna se vem som raderat en fil?
7. Vilken är den största fördelen med att använda en central logguppsamlare (**Collector**) i ett nätverk?
8. Vad innebär begreppet "Implicit Deny" i förhållande till vad operativsystemet väljer att logga som standard?
9. Hur kan loggning användas för att upptäcka en pågående brute force-attack?
10. Vilka prestandamässiga risker finns det med att ha en för omfattande loggning (t.ex. att logga varje gång en systemfil läses)?

## Fördjupningslänkar

Microsoft Learn (Security Auditing Overview – Grundläggande om hur granskning fungerar i Windows och hur loggar skapas) –

<https://learn.microsoft.com/en-us/windows/security/threat-protection/auditing/security-auditing-overview>

Ultimate Windows Security (Event Encyclopedia – En omfattande och ovärderlig databas över alla Windows Event IDs och deras betydelse för säkerhet) –

<https://www.ultimatewindowssecurity.com/securitylog/encyclopedia/>

Microsoft Learn (Windows Event Forwarding – Guide till hur man centraliserar loggar från flera datorer för att lättare upptäcka intrång) –

<https://learn.microsoft.com/en-us/windows/security/threat-protection/use-windows-event-forwarding-to-help-with-intrusion-detection>

Microsoft Learn (Advanced Audit Policy Settings – Detaljerad genomgång av hur man finjusterar vad som ska loggas för att få relevant information utan onödigt brus) –

<https://learn.microsoft.com/en-us/windows/security/threat-protection/auditing/advanced-security-audit-policy-settings>

Microsoft Learn (Sysmon Overview – Dokumentation för System Monitor, ett avancerat verktyg för att logga processer, nätverksanslutningar och filändringar) –

<https://learn.microsoft.com/en-us/sysinternals/downloads/sysmon>

## 8.1.10 Skydd mot skadlig kod (Malware) och nätfiske (Phishing)

### Kontrollfrågor

1. Vad är den huvudsakliga skillnaden mellan ett **Virus** och en **Mask (Worm)** rent spridningsmässigt?
2. Förklara hur **Beteendeanalys (Behavioral Monitoring)** kan stoppa ett Ransomware-angrepp.
3. Vilken funktion fyller **Microsoft Defender SmartScreen** när en användare laddar ner en fil från internet?
4. Beskriv begreppet **Riktat nätfiske (Spear Phishing)** och varför det är svårare att upptäcka än vanligt nätfiske.
5. Vad innebär det att en antivirusmotor använder **Heuristik (Heuristics)**?
6. Hur kan **Attackytans begränsning (ASR)** skydda en organisation mot skadliga Office-dokument?
7. Vilken är den tekniska fördelen med att använda **Application Guard** vid webbsurfning?
8. Varför anses social ingenjörskonst (Social Engineering) vara en så stor del av moderna cyberattacker?
9. Vilken roll spelar molnbaserat skydd (Cloud-delivered Protection) för att korta ner tiden mellan att ett nytt hot upptäcks och att alla datorer skyddas?
10. Vad händer med den skadliga koden i en **Sandlåda (Sandbox)** när sessionen avslutas?

## Fördjupningslänkar

Microsoft Learn (Protection against malware – En omfattande genomgång av Windows inbyggda skyddsmekanismer och arkitektur) –

<https://learn.microsoft.com/en-us/windows/security/threat-protection/>

Microsoft Learn (ASR Rules Reference – En detaljerad teknisk lista över regler som begränsar attackytan genom att stoppa riskfyllda beteenden) –

<https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/attack-surface-reduction>

MITRE ATT&CK (Global och branschledande kunskapsbas över de tekniker och taktiker som angripare använder i verkligheten) – <https://attack.mitre.org/>

Microsoft Learn (AppLocker Overview – Hur man använder vitlistning av applikationer för att effektivt förhindra att obehörig mjukvara körs) –

<https://learn.microsoft.com/en-us/windows/security/application-security/application-control/windows-defender-application-control/applocker/applocker-overview>

Microsoft Learn (Exploit Protection – Hur man konfigurerar skydd mot minnesbaserade attacker och sårbarhetsexploatering) –

<https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/enable-exploit-protection>

### 8.1.11 PowerShell – Arkitektur, användning och säkerhet

#### Kontrollfrågor

1. Vad innebär det att PowerShell är "objektorienterat" till skillnad från den äldre kommandotolken?
2. Förklara hur en "pipeline" fungerar i PowerShell och ge ett exempel på syntax.
3. Varför föredrar angripare ofta att använda PowerShell för att köra skadlig kod i minnet framför att ladda ner en .exe-fil?
4. Vad är syftet med en **Körningsprincip (Execution Policy)** och vilka är de vanligaste lägena?
5. Varför räcker det inte med att bara logga att PowerShell har startats för att upptäcka en avancerad attack?
6. Beskriv funktionen för **AMSI (Anti-Malware Scan Interface)** och hur det motverkar dolda (obfuserade) skript.
7. Vad är **Fjärrsignering (RemoteSigned)** och när är det lämpligt att använda?
8. Hur kan **Transkribering (Transcription)** hjälpa en tekniker vid en efterhandsanalys av en säkerhetsincident?
9. Vad innebär begreppet "**Living off the Land**" i ett IT-säkerhetssammanhang?
10. Vilken roll spelar WinRM för administrativt arbete i stora nätverksmiljöer?

## Fördjupningslänkar

Microsoft Learn (PowerShell Documentation – Den officiella och fullständiga guiden till allt inom PowerShell-ekosystemet) – <https://learn.microsoft.com/en-us/powershell/>

Microsoft Learn (PowerShell Security Best Practices – Officiella rekommendationer för att säkra miljön och minimera risker vid fjärrhantering) – <https://learn.microsoft.com/en-us/powershell/scripting/learn/remoting/jea/security-considerations>

Microsoft Learn (AMSI Explained – Hur Antimalware Scan Interface skyddar mot skadliga skript genom realtidsskanning i minnet) – <https://learn.microsoft.com/en-us/windows/win32/amsi/antimalware-scan-interface-portal>

Microsoft Learn (PowerShell Execution Policies – En genomgång av hur exekveringspolicyer fungerar och varför de inte är en absolut säkerhetsgräns) – [https://learn.microsoft.com/en-us/powershell/module/microsoft.powershell.core/about/about\\_execution\\_policies](https://learn.microsoft.com/en-us/powershell/module/microsoft.powershell.core/about/about_execution_policies)

Microsoft Learn (PowerShell Script Block Logging – Hur man konfigurerar detaljerad loggning för att avslöja dolda eller krypterade skadliga skript) – <https://learn.microsoft.com/en-us/powershell/scripting/learn/deep-dives/overview-of-powershell-security>

## 8.1.12 Användarkonton och grupper

### Kontrollfrågor

1. Vad innebär **Principen om minsta möjliga behörighet (PoLP)** i praktiken?
2. Varför rekommenderas det att även administratörer använder ett **Standardkonto (Standard User)** för sitt dagliga arbete?
3. Vilken är den största administrativa fördelen med att tilldela rättigheter till **Grupper (Groups)** istället för till enskilda användare?
4. Vad är den tekniska skillnaden mellan ett lokalt användarkonto och ett **Microsoft-konto (Microsoft Account)**?
5. Varför är det en säkerhetsrisk att låta ett **Gästkonto (Guest Account)** vara aktiverat?
6. Ge ett exempel på en inbyggd grupp i Windows och förklara vad den används till.
7. Vilket snabbkommando (.msc) kan användas för att öppna verktyget för lokala användare och grupper?
8. Varför är det olämpligt att dela ett och samma konto mellan flera olika personer?
9. Vilken kontotyp krävs för att kunna utföra en installation av en ny drivrutin?
10. Hur kan PowerShell underlätta hanteringen av användarkonton i en miljö med många datorer?

## Fördjupningslänkar

Microsoft Learn (Strategier för att skydda administrativa konton och privilegierad åtkomst – den så kallade "Privileged Access"-strategin) – <https://learn.microsoft.com/en-us/security/compass/privileged-access-strategy>

Microsoft Learn (Principen om minsta behörighet – En djupgående genomgång av Least Privilege-modellen) – <https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/plan/security-best-practices/implementing-least-privilege-administrative-models>

NIST (Digital Identity Guidelines – Den globala guldstandarden för hur modern autentisering och lösenordshantering bör se ut) – <https://pages.nist.gov/800-63-3/>

SANS Institute (Policy-guide för professionell lösenordshantering och kontosäkerhet i en företagsmiljö) – <https://www.sans.org/white-papers/1014/>

CISA (Officiella rekommendationer för att välja och skydda starka lösenord mot moderna knäckningsmetoder) – <https://www.cisa.gov/news-events/news/choosing-and-protecting-passwords>

## 8.2 Säkerhet i Linuxmiljö

### 8.2.1 Grundläggande säkerhetsprinciper

#### Kontrollfrågor

1. Vad är grundtanken bakom principen om "minsta möjliga behörighet" (Least Privilege)?
2. Varför används liknelsen om en lök när man beskriver begreppet *Defense in Depth*?
3. Nämn tre olika lager av skydd som kan ingå i en *Defense in Depth*-strategi.
4. Vad innebär det rent praktiskt att "minska attackytan" på en nyinstallerad server?
5. Vilket kommando använder du för att se vilka portar som lyssnar efter trafik i Linux?
6. Varför är det en säkerhetsrisk att behålla standardinställningar på tjänster efter en installation?
7. Förklara varför IT-säkerhet betraktas som en "process" snarare än en "produkt".
8. Vad är en CVE och varför är det viktigt för en systemadministratör att bevaka dessa?
9. Ge ett exempel på en tjänst som ofta stängs av eller begränsas för att minska risken för attacker.
10. Vad är syftet med att använda verktyg som *unattended-upgrades* i en Linux-miljö?

## Fördjupningslänkar

Ubuntu Security Guide (Officiell översikt över inbyggda säkerhetsfunktioner och rekommendationer i Ubuntu) – <https://ubuntu.com/security>

CIS Benchmarks (Världsledande industristandard för säker konfiguration av operativsystem och applikationer) – <https://www.cisecurity.org/benchmarks>

CVE Mitre (Den officiella globala listan över kända sårbarheter i mjukvara, hårdvara och tjänster) – <https://cve.mitre.org>

OWASP Linux Hardening (En teknisk och praktisk checklista för att säkra Linux-servrar mot moderna hot) – [https://cheatsheetseries.owasp.org/cheatsheets/Linux\\_Hardening\\_Cheat\\_Sheet.html](https://cheatsheetseries.owasp.org/cheatsheets/Linux_Hardening_Cheat_Sheet.html)

Linux Journey (En pedagogisk och grundläggande genomgång av säkerhetskoncept i Linux-kärnan och systemet) – <https://linuxjourney.com/lesson/kernel-security>

## 8.2.2 Linux root, sudo och användarbehörighet

### Kontrollfrågor

1. Vad innebär principen "**Allt är en fil**" och hur kan den användas för att begränsa åtkomst till ett specifikt program?
2. Varför anses det vara en stor säkerhetsrisk att arbeta direkt inloggad som användaren **Root**?
3. Vilka är de tre främsta fördelarna med att använda **Sudo** istället för att logga in som root?
4. Varför bör man alltid använda kommandot visudo när man ska ändra i sudo-inställningarna?
5. Förklara vad bokstäverna **u**, **g** och **o** står för i Linux rättighetssystem.
6. Beräkna det oktala värdet för rättigheten rwxr-xr-x.
7. Vad innebär specialrättigheten **SUID**, och i vilket sammanhang är den nödvändig (ge ett exempel)?
8. Vad är syftet med att sätta en **Sticky Bit** på en mapp som /tmp?
9. Förklara kortfattat hur en **Umask** fungerar och hur den påverkar nya filer som skapas.
10. I vilken situation räcker inte de vanliga UGO-rättigheterna till, och man behöver istället använda **ACL**?
11. Varför är flaggan -a så kritisk när man lägger till en användare i en ny grupp med usermod -aG?

## Fördjupningslänkar

Sudo Manual (Den officiella dokumentationen för konfiguration, säkerhet och avancerad användning av sudo) - <https://www.sudo.ws/docs/>

Linux Journey (En mycket pedagogisk genomgång av grundläggande filrättigheter, rwx-bitar och oktala värden) - <https://linuxjourney.com/lesson/file-permissions>

Arch Wiki (En djupgående teknisk genomgång av Access Control Lists (ACL) för mer finkornig rättighetsstyrning i Linux) - [https://wiki.archlinux.org/title/Access\\_Control\\_Lists](https://wiki.archlinux.org/title/Access_Control_Lists)

Red Hat (En tydlig förklaring av specialrättigheter som SUID, SGID och Sticky Bit samt deras säkerhetsrisker) - <https://www.redhat.com/sysadmin/linux-file-permissions-explained>

Linux Handbook (Guide till hantering av lösenordspolicyer och Password Aging för att tvinga fram säkrare kontohantering) - <https://linuxhandbook.com/password-aging/>

## 8.2.3 Linux OS-härdning (Operating System Hardening)

### Kontrollfrågor

1. Vad innebär begreppet "härdning" (hardening) av ett operativsystem?
2. Varför är det viktigt att följa en standard som CIS Benchmarks?
3. På vilket sätt ger AppArmor eller SELinux ett starkare skydd än vanliga filrättigheter?
4. Vad är fördelen med att använda sysctl för att ändra kernel-parametrar?
5. Hur skyddar Secure Boot systemet mot rootkits under uppstarten?
6. Vad händer med datan på en LUKS-krypterad disk om någon flyttar disken till en annan dator utan att ha lösenordet?
7. Varför anses det vara säkrare att ha /tmp på en egen partition med flaggan noexec?
8. Vad är syftet med verktyget Lynis och hur skiljer det sig från en vanlig antivirusscanning?
9. Vad innebär MOK (Machine Owner Key) i samband med Secure Boot?
10. Vilken fil i Linux används normalt för att permanent ställa in mount-alternativ för partitioner?

## Fördjupningslänkar

CIS Benchmarks (Världsledande industristandard för säker konfiguration av Linux-system) – <https://www.cisecurity.org/benchmarks>

Lynis (Dokumentation för ett av de mest använda verktygen för automatiserad säkerhetsgranskning och hårdningstestning) – <https://cisofy.com/lynis/>

AppArmor (Officiell wiki för hur man hanterar profiler som begränsar applikationers tillgång till systemresurser i Ubuntu) – <https://gitlab.com/apparmor/apparmor/-/wikis/home>

Linux Kernel Hardening (Teknisk genomgång av hur man säkrar systemkärnan och nätverksstacken via sysctl-parametrar) – <https://www.kernel.org/doc/html/latest/admin-guide/sysctl/index.html>

LUKS/cryptsetup (Den officiella guiden för hur tekniken bakom fullständig diskryptering i Linux fungerar och administreras) – <https://gitlab.com/cryptsetup/cryptsetup>

UEFI Secure Boot on Linux (Detaljerad genomgång av hur man säkrar hela uppstartsprocessen från firmware till kärna) – <https://wiki.ubuntu.com/UEFI/SecureBoot>

FSTAB Options (Teknisk förklaring av monteringsflaggor som noexec och nosuid för att säkra filsystemet) – <https://man7.org/linux/man-pages/man5/fstab.5.html>

SELinux Project Wiki (Djupdykning i Security-Enhanced Linux – det kraftfulla alternativet till AppArmor som används i t.ex. Red Hat) – <https://selinuxproject.org/>

Debian Hardening Guide (En av de mest omfattande och klassiska guiderna för operativsystemshårdning i Linux-världen) – <https://www.debian.org/doc/manuals/securing-debian-howto/>

OpenZFS Documentation (Hur kryptering på filsystems nivå fungerar i moderna filsystem som ZFS) – <https://openzfs.github.io/openzfs-docs/man/7/zfs-load-key.8.html>

## 8.2.4 Linux paketuppdatering och patchhantering

### Kontrollfrågor

1. Varför liknas ett opatchat system vid att "lämna dörren på glänt"?
2. Vad är den tekniska skillnaden mellan apt upgrade och apt full-upgrade?
3. Varför är det särskilt viktigt att uppdatera just säkerhetshål och buggar som rör behörighetsexkalering?
4. Vad är syftet med verktyget *unattended-upgrades*?
5. Vilken fil ska du kontrollera för att se historiken över installerade paket?
6. Varför kan det vara en säkerhetsrisk att lägga till många PPA:er från tredjepart?
7. Vad innebär begreppet "Zero-day exploit"?
8. Hur kan du via terminalen snabbt kontrollera om servern kräver en omstart efter en uppdatering?
9. Vilken är fördelen med *Canonical Livepatch* i en servermiljö?
10. Varför är det viktigt att även uppdatera testserverar som sällan används?

## Fördjupningslänkar

Ubuntu Security Notices (Officiella meddelanden om upptäckta säkerhetshål och tillgängliga patchar för Ubuntu) - <https://ubuntu.com/security/notices>

Debian Security Information (Information om hur Debian-projektet hanterar säkerhet och sårbarheter i sina paket) - <https://www.debian.org/security/>

Unattended-Upgrades Wiki (Teknisk guide för att konfigurera automatisk installation av säkerhetsuppdateringar utan manuell handpåläggning) - <https://wiki.debian.org/UnattendedUpgrades>

Canonical Livepatch Service (Information om hur man patchar Linux-kärnan i realtid utan att behöva starta om systemet) - <https://ubuntu.com/security/livepatch>

CVE Mitre Database (Den globala standarddatabasen för att söka efter och identifiera specifika sårbarheter i all mjukvara) - <https://cve.mitre.org/>

Linux Handbook (En tydlig förklaring av skillnaden mellan apt upgrade och apt dist-upgrade/full-upgrade) - <https://linuxhandbook.com/apt-upgrade-dist-upgrade/>

DigitalOcean (Bästa praxis för att hantera säkerhetsuppdateringar på Ubuntu och Debian-servrar) - <https://www.digitalocean.com/community/tutorials/how-to-keep-your-ubuntu-22-04-server-updated>

## 8.2.5 Linux systemövervakning och loggning

### Kontrollfrågor

1. Varför är loggar avgörande vid en säkerhetsincident?
2. Vad är den största skillnaden mellan hur journald och rsyslog lagrar data?
3. Vilket kommando använder du för att se loggar från en specifik tjänst, t.ex. SSH?
4. I vilken loggfil letar du om du misstänker att någon försökt gissa lösenordet till ett konto?
5. Vad är skillnaden mellan top och htop?
6. Förklara hur fail2ban samarbetar med systemets loggfiler och brandvägg.
7. Hur fungerar "före-och-efter"-principen i verktyget AIDE?
8. Varför är det viktigt att förvara AIDE-databasen på en säker plats?
9. Vad visar kommandot uptime utöver hur länge datorn varit igång?
10. Vilket verktyg (kommando) är mest lämpligt för att se vilka nätverksportar som är öppna just nu?

## Fördjupningslänkar

AIDE (Officiell webbplats för Advanced Intrusion Detection Environment – verktyget för att upptäcka obehöriga filändringar) – <https://aide.github.io/>

Fail2ban (Projektets officiella sida för skydd mot brute-force-attacker genom automatisk blockering av IP-adresser) – <https://www.fail2ban.org/>

Logrotate (Teknisk manual för hur Linux roterar, komprimerar och rensar gamla loggfiler för att spara diskutrymme) – <https://man7.org/linux/man-pages/man8/logrotate.8.html>

DigitalOcean (Praktisk guide till journalctl för att söka, filtrera och analysera systemd-loggar i realtid) – <https://www.digitalocean.com/community/tutorials/how-to-use-journalctl-to-view-and-manipulate-systemd-logs>

htop (Officiell genomgång av processövervakaren htop och hur man tolkar dess färger och mätvärden) – <https://htop.dev/>

Linux Auditd (Introduktion till Linux Auditing System för detaljerad spårning av systemanrop och användaraktivitet) – <https://linux-audit.com/lf/auditd/>

CrowdSec (En modern, community-driven brandvägg och IPS som fungerar som ett kraftfullt alternativ till Fail2ban) – <https://www.crowdsec.net/>

Logit.io (Genomgång av SIEM och centraliserad loggning – varför man flyttar loggar från den lokala servern) – <https://logit.io/blog/post/what-is-siem/>

## 8.2.6 Linux härdning av tjänster (SSH, brandvägg, TLS/SSL)

### Kontrollfrågor

1. Vad är det primära målet med att "härdar" en tjänst?
2. Varför rekommenderas det att byta standardport för SSH från 22 till något annat?
3. Vad innebär inställningen PermitRootLogin no i praktiken för en administratör?
4. Varför är nyckelbaserad autentisering säkrare än inloggning med lösenord?
5. Vilket kommando används för att skicka över en SSH-nyckel från en klient till en server?
6. Vad händer om du aktiverar ufw med default deny incoming utan att först ha tillåtit din SSH-port?
7. Förklara skillnaden mellan ufw allow och ufw limit.
8. Vilka tre huvudsakliga funktioner fyller TLS/SSL vid kommunikation över nätverk?
9. Vad är Certbot och vilken roll spelar det för krypterad webbtrafik?
10. Hur kontrollerar du att brandväggen är aktiv och vilka regler som gäller just nu?

## Fördjupningslänkar

Mozilla Infosec (SSH Hardening Guide – Industristandard och färdiga konfigurationsmallar för en säker OpenSSH-server) –

<https://infosec.mozilla.org/guidelines/openssh>

DigitalOcean (UFW Essentials – En praktisk guide till de vanligaste brandväggsreglerna uppdaterad för Ubuntu 24.04) –

<https://www.digitalocean.com/community/tutorials/uw-essentials-common-firewall-rules-and-commands-on-ubuntu-24-04>

Let's Encrypt (Officiell dokumentation om hur automatiserade och kostnadsfria SSL/TLS-certifikat fungerar i praktiken) – <https://letsencrypt.org/docs/>

OpenSSL (Den fullständiga tekniska dokumentationen för kryptering, certifikatssignering och hantering av publika nycklar) –

<https://www.openssl.org/docs/>

Ubuntu Server Guide (Officiell genomgång av hur man hanterar certifikat i Ubuntu 24.04 LTS) – <https://ubuntu.com/server/docs/security-certificates>

SSH.com (Public Key Authentication – En djupdykning i varför nyckelbaserad inloggning är överlägsen lösenord) – <https://www.ssh.com/academy/ssh/public-key-authentication>

DigitalOcean (Steg-för-steg-guide för att konfigurera SSH-nycklar specifikt för Ubuntu 24.04) – <https://www.digitalocean.com/community/tutorials/how-to-set-up-ssh-keys-on-ubuntu-24-04>

## 8.2.7 Linux automatisera säkerhetsuppgifter (cron, script, loggning)

### Kontrollfrågor

1. Förklara vad de fem olika positionerna (stjärnorna) i en crontab-rad representerar.
2. Vilket kommando används för att redigera din användares specifika cron-schema?
3. Varför är det viktigt att använda absoluta sökvägar (t.ex. `/usr/bin/apt` istället för bara `apt`) i ett automatiserat script?
4. Vad är syftet med verktyget *logrotate* och vad skulle hända med systemet om det inte fanns?
5. I exemplet med uppdateringsscriptet används `>>` och `2>&1`. Vad betyder dessa tecken i bash-sammanhang?
6. Vad är skillnaden mellan en användares crontab och den systemövergripande filen `/etc/crontab`?
7. Hur gör du ett bash-script körbart via terminalen?
8. Varför är automatisering av säkerhetskopiering (backup) säkrare än att göra det manuellt?
9. Nämn en säkerhetsrutin som bör köras dagligen och en som kan räcka att köra veckovis.
10. Hur kan du övervaka en loggfil i realtid medan ett automatiserat script körs?

## Fördjupningslänkar

Crontab Guru (Ett fantastiskt interaktivt verktyg för att testa, visualisera och förstå cron-scheman i realtid) – <https://crontab.guru/>

DigitalOcean (Praktisk guide till hur man använder Cron för att automatisera uppgifter i Ubuntu 24.04) – <https://www.digitalocean.com/community/tutorials/how-to-use-cron-to-automate-tasks-on-ubuntu-24-04>

LinuxConfig (Bash Scripting Tutorial – En omfattande guide för att lära sig skriva säkra och effektiva skript för automatisering) – <https://linuxconfig.org/bash-scripting-tutorial>

ShellCheck (Ett oundgängligt verktyg som analyserar dina skript och varnar för säkerhetshål, buggar och dålig praxis) – <https://www.shellcheck.net/>

Arch Wiki (Systemd Timers – En teknisk genomgång av det moderna alternativet till Cron, vilket ger bättre loggning och kontroll i moderna Linux-system) – <https://wiki.archlinux.org/title/Systemd/Timers>

## 8.2.8 Linux backup och återställning

### Kontrollfrågor

1. Varför är backup extra viktigt på Linux-servrar som saknar grafiskt gränssnitt?
2. Förklara skillnaden mellan en inkrementell och en differentierad backup.
3. Vad innebär 3-2-1-regeln i praktiken?
4. Vilken funktion fyller flaggan `-a` när du kör `rsync`?
5. Varför bör man använda `--delete` med försiktighet i vissa sammanhang?
6. Hur ser en cron-rad ut om du vill köra ett skript varje söndag klockan 04:00?
7. Vad är skillnaden mellan en "Snapshot" och en traditionell backup?
8. Varför är det viktigt att förvara minst en kopia av sin data "offsite"?
9. Vad är risken med att spara en backup på samma fysiska hårddisk som originaldatan?
10. Vad är verktyget `rclone` bra för i backupsammanhang?

## Fördjupningslänkar

Rsync Official Documentation (Teknisk referens för flaggor, parametrar och användningsområden vid filsynkronisering) – <https://rsync.samba.org/>

BorgBackup (Dokumentation för ett verktyg som hanterar deduplicering, komprimering och autentiserad kryptering av backuper) – <https://www.borgbackup.org/>

Backblaze (The 3-2-1 Backup Strategy – En genomgång av principen att ha tre kopior av data på två olika medier, varav en kopia förvaras på annan fysisk plats) – <https://www.backblaze.com/blog/the-3-2-1-backup-strategy/>

Rclone (Manual för verktyget som möjliggör synkronisering av Linux-filer mot olika molnlagringstjänster) – <https://rclone.org/docs/>

Ubuntu Server Guide (Officiell dokumentation om hantering av backuper och arkivering i Ubuntu 24.04 LTS) – <https://ubuntu.com/server/docs/backups>

## 8.2.9 Linux Säkerhetsverktyg

### Kontrollfrågor

1. Vilket verktyg i verktygslådan ger dig ett "Hardening Index" (säkerhetsbetyg) efter en skanning?
2. Förklara skillnaden i användningsområde mellan *Lynis* och *AIDE*.
3. Varför rekommenderas det att använda både *chkrootkit* och *rkhunter*?
4. Hur skiljer sig *ClamAV* från ett traditionellt antivirusprogram för Windows?
5. Vad innebär det att *Freshclam* måste köras innan en skanning med ClamAV?
6. Vilket verktyg skulle du använda för att upptäcka om en obehörig person har ändrat i filen */etc/shadow*?
7. Vad är syftet med *auditd* och hur skiljer sig dess loggar från vanliga systemloggar?
8. Vilket verktyg fokuserar specifikt på att blockera IP-adresser vid brute-force-attacker?
9. Varför räcker det inte med att bara installera dessa verktyg, utan även ha en rutin för att läsa deras rapporter?
10. Vilket verktyg är enklast att använda för en tekniker som snabbt vill konfigurera en brandvägg?

## Fördjupningslänkar

Cisofy (Lynis – Dokumentation för automatiserad säkerhetsgranskning) – <https://cisofy.com/lynis/>

Fail2Ban (Wiki för IP-blockering vid inloggningsförsök) – <https://www.fail2ban.org/>

AIDE (Manual för kontroll av filintegritet) – <https://aide.github.io/>

Rootkit Hunter (Projektsida för sökning efter rootkits) – <https://rkhunter.sourceforge.net/>

Red Hat (Genomgång av systemgranskning med auditd) – [https://docs.redhat.com/en/documentation/red\\_hat\\_enterprise\\_linux/9/html/security\\_hardening/auditing-the-system\\_security-hardening](https://docs.redhat.com/en/documentation/red_hat_enterprise_linux/9/html/security_hardening/auditing-the-system_security-hardening)

## 8.2.10 Sammanfattning: Säkerhet som rutin

### Kontrollfrågor

1. Förklara principen om **Least Privilege** med ett praktiskt exempel från Linux.
2. Vad är fördelen med att använda **sudo** istället för att logga in direkt som **root**?
3. Beräkna den oktala rättigheten för en fil där ägaren ska kunna läsa och skriva, gruppen bara läsa, och övriga inte ska ha någon åtkomst alls.
4. Varför är **Secure Boot** viktigt ur ett säkerhetsperspektiv?
5. Beskriv tre steg du bör ta för att säkra en nysatt SSH-server.
6. Vad innebär det att en partition monteras med flaggan **noexec**?
7. Hur fungerar verktyget **Fail2Ban** och varför är det effektivt mot brute-force-attacker?
8. Vilken roll spelar journalföring i ett filsystem som **ext4** för att skydda data vid ett strömavbrott?
9. Förklara **3-2-1-regeln** för backuper och varför "offsite-lagring" är kritisk.
10. Vad är syftet med att använda ett verktyg som **Lynis** regelbundet?

## Fördjupningslänkar

CIS (Säkerhetsguider för Ubuntu Linux) -

[https://www.cisecurity.org/benchmark/ubuntu\\_linux](https://www.cisecurity.org/benchmark/ubuntu_linux)

Ubuntu (Dokumentation för säkerhetsguider och certifieringar) -

<https://ubuntu.com/security/certifications/docs/usg>

Linux Journey (Genomgång av filrättigheter) -

<https://linuxjourney.com/lesson/file-permissions>

Mozilla (Guide för härdning av OpenSSH) -

<https://infosec.mozilla.org/guidelines/openssh>

Cisofy (Lynis - Dokumentation för säkerhetsgranskning) -

<https://cisofy.com/lynis/>

Fail2Ban (Wiki för skydd mot brute-force) -

[https://www.fail2ban.org/wiki/index.php/Main\\_Page](https://www.fail2ban.org/wiki/index.php/Main_Page)

AIDE (Manual för filintegritetskontroll) - <https://aide.github.io/>

Cryptsetup (Instruktioner för diskryptering med LUKS) -

<https://gitlab.com/cryptsetup/cryptsetup>

OWASP (Checklista för Linux-härdning) -

[https://cheatsheetseries.owasp.org/cheatsheets/Linux\\_Hardening\\_Cheat\\_Sheet.html](https://cheatsheetseries.owasp.org/cheatsheets/Linux_Hardening_Cheat_Sheet.html)

TLDP (Grundläggande säkerhetsguide för Linux) -

<https://tldp.org/HOWTO/Security-HOWTO/>

## 8.3 Jämförelse: Säkerhet i Windows och Linux

### 8.3.1 Säkerhetsfilosofi: Helhetslösning kontra Modulär uppbyggnad

#### Kontrollfrågor

1. Vad innebär det att Windows-säkerhet är "integrerad" i operativsystemet?
2. Hur skiljer sig administratörens roll vid uppstart av ett nytt system i Linux jämfört med Windows?
3. Ge ett exempel på hur modularitet i Linux kan vara en fördel vid härdning av en server.
4. Varför kan den grafiska enkelheten i Windows vara en nackdel för en tekniker som vill förstå exakt vad som blockerar en anslutning?
5. På vilket sätt påverkar valet av arkitektur (Policy-driven vs. Fil-driven) möjligheten att automatisera säkerhetsinställningar?
6. Hur skiljer sig filosofin kring privilegieeskalering mellan Windows UAC och Linux sudo?
7. Vilken betydelse har transparens och öppen källkod för granskning av säkerhetsfunktioner i Linux jämfört med Windows slutna modell?
8. Jämför hur Windows och Linux hanterar beroenden vid installation av säkerhetsuppdateringar.
9. Vilka är de främsta skillnaderna i hur operativsystemen hanterar filrättigheter på systemnivå (NTFS-rättigheter vs. Linux-behörigheter)?
10. Hur påverkar skillnaden mellan ett "out-of-the-box"-system (Windows) och ett system som byggs upp modulärt (Linux) den totala attackytan?

## Fördjupningslänkar

Microsoft (Designprinciper för inbyggd säkerhet i Windows) –

<https://learn.microsoft.com/en-us/windows/security/threat-protection/>

TLDP (Dokumentation om Linux säkerhetsfilosofi och arkitektur) –

<https://tldp.org/HOWTO/Security-HOWTO/>

NIST (Riktlinjer för säkerhetsmodeller och serverhärdning) –

<https://csrc.nist.gov/publications/detail/sp/800-123/final>

SANS Institute (Analys av skillnader i säkerhetsarkitekturer mellan olika operativsystem) – <https://www.sans.org/white-papers/34/>

CIS (Globala standarder för säker konfiguration av Windows och Linux) –

<https://www.cisecurity.org/cis-benchmarks/>

## 8.3.2 Behörighetsmodeller: Administrativ eskalering och filsystems rättigheter

### Kontrollfrågor

1. Vad innebär principen "Allt är en fil" (Everything is a file) i Linux och hur påverkar det säkerhetsarbetet?
2. Hur skiljer sig administratörens metod för att begränsa åtkomst till hårdvara mellan Windows och Linux?
3. Förklara varför Sudo (Substitute User Do) anses mer granulärt än Windows UAC.
4. Vad är risken med "UAC-trötthet" i en Windows-miljö?
5. Varför är arkitekturen i Linux (rwx på allt) en fördel när man ska säkra specifika program?
6. Vilken funktion fyller "Integrity Levels" i Windows som saknar en direkt motsvarighet i standardiserade Linux-behörigheter?
7. Hur skiljer sig hanteringen av "Root"-kontot i Linux från det inbyggda administratörskontot i Windows ur ett säkerhetsperspektiv?
8. På vilket sätt kan filen sudoers användas för att begränsa en användare till enbart specifika kommandon?
9. Hur fungerar Windows "Access Tokens" vid en UAC-prompt för att dela upp administrativa rättigheter?
10. Vilka är de primära skillnaderna i hur en administratör granskar (audit) vem som har använt förhöjda privilegier i respektive system?

## Fördjupningslänkar

Microsoft (Teknisk genomgång av UAC och integritetsnivåer) –

<https://learn.microsoft.com/en-us/windows/security/identity-protection/user-account-control/how-user-account-control-works>

Sudo Manual (Dokumentation för konfiguration av sudoers-filen) –

<https://www.sudo.ws/docs/man/sudoers.man/>

Red Hat (Jämförelse mellan Linux-behörigheter och Windows ACL:er) –

<https://www.redhat.com/sysadmin/linux-file-permissions-explained>

Linux Foundation (Grundläggande användarhantering och säkerhet i Linux) –

<https://training.linuxfoundation.org/resources/linux-security-fundamentals-user-management/>

Microsoft Learn (Dokumentation om Access Tokens och behörighetskontroll) –

<https://learn.microsoft.com/en-us/windows/win32/secauthz/access-tokens>

### 8.3.3 Malware och hotbild: Olika mål, olika metoder

#### Kontrollfrågor

1. Varför är Windows ett mer attraktivt mål för **Utpressningstrojaner (Ransomware)** än Linux?
2. Vad innebär begreppet "**Living off the Land**" i en Windows-kontext?
3. På vilket sätt skiljer sig en typisk attackvektor mot en Linux-server från en attack mot en Windows-klient?
4. Vad är syftet med ett **Kryptokapningsprogram (Cryptojacker)** på en server?
5. Varför anses **Nätfiske (Phishing)** vara ett mindre hot mot Linux-servrar än mot Windows-arbetsstationer?
6. Förklara kort vad ett **Rootkit (Rootkit)** försöker uppnå i ett Linux-system.
7. Hur påverkar systemens marknadsandelar (klient vs server) de verktyg angripare väljer att utveckla?

## Fördjupningslänkar

Microsoft (Digital Defense Report – Rapport om hotbilder och säkerhetstrender) – <https://www.microsoft.com/en-us/security/business/microsoft-digital-defense-report>

MITRE ATT&CK (Linux Matrix – Teknisk förteckning över angrepp mot Linux) – <https://attack.mitre.org/matrices/enterprise/linux/>

CrowdStrike (Analys av hur hotbilder skiljer sig mellan Windows och Linux) – <https://www.crowdstrike.com/cybersecurity-101/os-security/linux-vs-windows-security/>

CVE Details (Sårbarhetsstatistik för operativsystem och applikationer) – <https://www.cvedetails.com/top-50-products.php>

Trend Micro (Linux Threat Report – Analys av specifika hot mot Linux-miljöer) – <https://www.trendmicro.com/vinfo/us/security/news/cybercrime-and-digital-threats/linux-threat-report-2023-detecting-evasion-and-extending-the-kernel>

## 8.3.4 Antivirus och säkerhetsverktyg: Inbyggd automatisering kontra manuell kontroll

### Kontrollfrågor

1. Varför är **Microsoft Defender** ofta mer effektivt för en vanlig användare än vad **ClamAV** är?
2. Förklara skillnaden mellan hur man öppnar en port i **Windows-brandväggen** jämfört med i **UFW** i Linux.
3. Vilken är den främsta fördelen med att använda **AppLocker** i ett företagsnätverk?
4. På vilket sätt fungerar **AppArmor** eller **SELinux** som ett extra säkerhetslager även om en angripare får root-åtkomst till en tjänst?
5. Varför kräver Linux-system oftast mer manuell konfiguration för att hålla virusdefinitioner uppdaterade (t.ex. via kommandot `freshclam`)?
6. Vad innebär det att en brandvägg är "programbaserad" (Windows) kontra "portbaserad" (Linux)?
7. Vilket verktyg i Linux motsvarar bäst Windows-världens centraliserade uppdateringstjänst (WSUS)?

## Fördjupningslänkar

Microsoft (AppLocker – Dokumentation om vitlistning av program i Windows) – <https://learn.microsoft.com/en-us/windows/security/application-security/application-control/app-control-for-business/applocker/applocker-overview>

GitLab (AppArmor – Dokumentation om hur man begränsar programvarors befogenheter i Linux) – <https://gitlab.com/apparmor/apparmor/-/wikis/home>

Ubuntu (UFW – Manual för hantering av nätverksskydd och brandväggsregler) – <https://help.ubuntu.com/community/UFW>

Microsoft (Windows Defender Application Control – Översikt över kontroll av applikationsexekvering) – <https://learn.microsoft.com/en-us/windows/security/application-security/application-control/windows-defender-application-control/wdac>

Red Hat (Introduction to firewalld – Dokumentation för hantering av brandväggsregler i Linux-miljöer) – [https://docs.redhat.com/en/documentation/red\\_hat\\_enterprise\\_linux/9/html/configuring\\_and\\_managing\\_networking/using-and-configuring-firewalld\\_configuring-and-managing-networking](https://docs.redhat.com/en/documentation/red_hat_enterprise_linux/9/html/configuring_and_managing_networking/using-and-configuring-firewalld_configuring-and-managing-networking)

## 8.3.5 Loggning och övervakning: Loggboken mot Journalctl

### Kontrollfrågor

1. Vad är den största fördelen med att Windows lagrar loggar i ett binärt format med specifika **Händelse-ID (Event IDs)**?
2. Hur skiljer sig sökmetoden i en traditionell Linux-logg (textfil) från sökning i **Systemd Journal**?
3. Varför är **Säkerhetsloggen (Security Log)** den viktigaste källan vid en säkerhetsincident i Windows?
4. Vilket kommando används i Linux för att se de senaste händelserna i realtid (motsvarande att "följa" en logg)?
5. Förklara fördelen med **Loggcentralisering (Event Forwarding)** ur ett säkerhetsperspektiv.
6. Vilken Linux-katalog fungerar som standardplats för de flesta systemloggar?
7. Hur kan en administratör i Windows snabbt hitta alla misslyckade inloggningsförsök utan att läsa igenom hela loggen?

## Fördjupningslänkar

Microsoft (Windows Event Forwarding – Guide för centralisering av Windows-loggar) – <https://learn.microsoft.com/en-us/windows/security/threat-protection/use-windows-event-forwarding-to-help-with-intrusion-detection>

Freedesktop (Journalctl – Dokumentation för logghantering i systemd) – <https://www.freedesktop.org/software/systemd/man/journalctl.html>

Wazuh (Dokumentation för övervakning av Windows och Linux i ett SIEM-system) – <https://documentation.wazuh.com/current/index.html>

Rsyslog (Dokumentation för centraliserad loggning och loggprocessering i Linux) – <https://www.rsyslog.com/doc/>

Elastic (Guide för enhetlig loggning och övervakning av blandade IT-miljöer) – <https://www.elastic.co/guide/en/observability/current/logs.html>

## 8.3.6 Användningsområden och sårbarheter: Rätt verktyg för rätt uppgift

### Kontrollfrågor

1. Varför är Windows det dominerande valet för klientdatorer i stora organisationer?
2. Vilken är den enskilt största säkerhetsrisken i en miljö med många Windows-klienter?
3. På vilket sätt bidrar Linux minimalistiska natur (t.ex. i Server Core-liknande miljöer) till högre säkerhet?
4. Förklara hur en **Felkonfiguration (Misconfiguration)** kan göra en Linux-server sårbar trots att operativsystemet i sig är säkert.
5. Vad innebär begreppet "Attackyta" (Attack Surface) och vilket system har generellt den största ytan i ett standardutförande?
6. Varför anses det vara en god säkerhetspraxis att använda **SSH-nycklar (SSH Keys)** istället för lösenord vid fjärradministration av Linux?
7. Hur samverkar Windows och Linux i en modern hybridmiljö (ge ett exempel)?

## Fördjupningslänkar

CIS (Standarder för härdning av operativsystem och applikationer) –  
<https://www.cisecurity.org/benchmarks/>

Linux Foundation (Resurser för säkring av Linux-servrar i produktion) –  
<https://training.linuxfoundation.org/>

Microsoft (Rekommendationer för säkring av Windows Server och infrastruktur)  
– <https://learn.microsoft.com/en-us/windows-server/security/windows-server-security-best-practices>

NIST (Riktlinjer för val av säkerhetskontroller och systemhärdning) –  
<https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final>

SANS Institute (Checklista och ramverk för operativsystemshärdning) –  
<https://www.sans.org/white-papers/360/>

## 8.3.7 Sammanfattning: Perspektiv på säkerhet

### Kontrollfrågor

1. Hur skiljer sig synsättet på "standardinställningar" mellan Windows och Linux?
2. Varför anses Windows vara mer lämpat för att hantera stora mängder användarklienter?
3. Vilken är den största faran med den modulära friheten i ett Linux-system?
4. Beskriv hur begreppet "Attackyta" (Attack Surface) skiljer sig mellan en typisk Windows-installation och en minimalistisk Linux-server.
5. På vilket sätt påverkar administratörens kunskapsnivå säkerheten mer i Linux än i Windows?
6. Ge ett exempel på ett scenario där Windows är det starkaste valet ur ett säkerhetsperspektiv.
7. Ge ett exempel på ett scenario där Linux är det starkaste valet ur ett säkerhetsperspektiv.
8. Vad menas med att säkerhet är en "process" och inte en "produkt"?
9. Varför är det viktigt att inte se operativsystemen som "bra" eller "dåliga" i en professionell IT-roll?
10. Vilken roll spelar centraliserad administration (GPO) för säkerheten i stora nätverk?

## Fördjupningslänkar

NIST (Global standard och ramverk för IT-säkerhet oavsett plattform) – <https://csrc.nist.gov/>

SANS Institute (Tekniska resurser och guider för säkring av Windows och Linux) – <https://www.sans.org/security-resources/>

Palo Alto Networks (Unit 42 Cloud Threat Report – Analys av säkerhetshot och trender i molnmiljöer) – <https://www.paloaltonetworks.com/prisma/unit42-cloud-threat-report>

ENISA (EU:s cybersäkerhetsbyrå – Rapporter och riktlinjer för nätverks- och informationssäkerhet) – <https://www.enisa.europa.eu/>

CISA (Resurser och verktyg för att säkra infrastruktur och operativsystem) – <https://www.cisa.gov/resources-tools>

## 9 OSI-modellen

### 9.1 Uppkomst – Bakgrunden till OSI

#### Kontrollfrågor

1. Vad innebar begreppet **Proprietära (Proprietary)** system under 1970-talet?
2. Förklara begreppet **Vendor Lock-in** och varför det var ett hinder för nätverksutvecklingen.
3. Vilken organisation ansvarade för framtagandet av OSI-modellen och vilket år publicerades den?
4. Vad är den tekniska skillnaden mellan en **Referensmodell (Reference model)** och ett faktiskt protokoll?
5. Varför vann TCP/IP över OSI i praktisk användning, trots att OSI var den officiella standarden?
6. Varför fortsätter IT-branschen att använda OSI-modellen som referens trots att internet drivs av TCP/IP?
7. Vilka lager i OSI-modellen fokuserar denna bok främst på, och varför är dessa viktiga för en systemadministratör?
8. Vad menas med att OSI-modellen fungerar som ett "gemensamt fackspråk"?

## Fördjupningslänkar

ISO (Officiell dokumentation av OSI-modellen i standarden 7498-1) – <https://www.iso.org/standard/20269.html>

Internet Hall of Fame (Historisk genomgång av utvecklingen av nätverksstandarder) – <https://www.internethalloffame.org/blog/2012/08/21/the-protocol-wars/>

Network World (Beskrivning av OSI-modellens roll i modern IT) – <https://www.networkworld.com/article/712318/the-osi-model-explained.html>

Cloudflare (Förklaring av OSI-modellens sju lager och deras funktioner) – <https://www.cloudflare.com/learning/network-layer/what-is-the-osi-model/>

Cisco (Teknisk översikt över OSI-modellen och nätverksprotokoll) – <https://www.cisco.com/c/en/us/support/docs/ip/routing-information-protocol-rip/13769-5.html>

IEEE Standards Association (Information om standarder för Ethernet och trådlösa nätverk inom lager 1 och 2) – <https://standards.ieee.org/>

GeeksforGeeks (Teknisk jämförelse mellan OSI-modellen och TCP/IP-modellen) – <https://www.geeksforgeeks.org/difference-between-osi-and-tcp-ip-reference-model/>

CompTIA (Praktisk användning av OSI-modellen vid felsökning i nätverk) – <https://www.comptia.org/blog/osi-model-7-layers-explained>

## 9.2 Arkitektur – Lagren och PDU

### Kontrollfrågor

1. Vad innebär processen **Inkapsling (Encapsulation)** och hur fungerar en **Header (Header)**?
2. Förklara begreppet **PDU (Protocol Data Unit)** och varför det underlättar kommunikation mellan tekniker.
3. Vad kallas dataenheten i **Transportlagret (Layer 4)** respektive **Datalänklagret (Layer 2)**?
4. Beskriv skillnaden mellan ett **Paket (Packet)** och en **Ram (Frame)** gällande adresseringsinformation.
5. Vilka specifika uppgifter hanteras i **Presentationslagret (Layer 6)**?
6. Varför delas data upp i **Segment (Segments)** i lager 4 istället för att skickas som en enda stor fil?
7. Hur hjälper **Cisco Packet Tracer** en tekniker att förstå OSI-modellen praktiskt?
8. Förklara begreppet **Avkapsling (Decapsulation)** och när denna process sker.
9. Varför är det viktigt för en systemadministratör att förstå lager 5 och 6 även om de ofta klumpas ihop i andra modeller?
10. Vilken typ av information läggs till i **Nätverkslagret (Layer 3)** för att data ska hitta rätt över internet?

## Fördjupningslänkar

Cisco (Packet Tracer – Verktyg för nätverkssimulering och laborationer) –  
<https://www.netacad.com/courses/packet-tracer>

Practical Networking (Genomgång av OSI-modellen och tillhörande Protocol Data Units) – <https://www.practicalnetworking.net/series/osi-model/osi-model/>

GeeksforGeeks (Beskrivning av inkapsling och datahantering i nätverkslagren) – <https://www.geeksforgeeks.org/encapsulation-in-osi-model/>

TechTarget (Definitioner av PDU:er för de olika lagren i OSI-modellen) –  
<https://www.techtarget.com/searchnetworking/definition/Protocol-Data-Unit-PDU>

Wireshark (Verktyg för analys av nätverkstrafik och inspektion av paketstrukturer) – <https://www.wireshark.org/>

Lifewire (Översikt över skillnaderna mellan ramar, paket och segment) –  
<https://www.lifewire.com/protocol-data-unit-818139>

Network World (Teknisk genomgång av Ethernet-ramar och lager 2-PDU:er) –  
<https://www.networkworld.com/article/712330/ethernet-frame-format-explained.html>

## 9.3 Användningsområde – Felsökning och kommunikation

### Kontrollfrågor

1. Varför är OSI-modellen viktig vid kommunikation mellan olika IT-team (t.ex. utvecklare och nätverkstekniker)?
2. Beskriv felsökningsmetoden **Nedifrån och upp (Bottom-up)** och ge ett praktiskt exempel på vad man kontrollerar först.
3. Vad innebär det att "Söndra och härska" (**Divide and Conquer**) vid felsökning?
4. Om en tekniker säger "det är ett problem i Lager 1", vad bör du kontrollera då?
5. Varför är det en fördel att nätverksprotokoll är modulära enligt OSI-modellen?
6. Vilket kommando används ofta för att snabbt kontrollera om Lager 1 till 3 fungerar?
7. Ge ett exempel på ett problem som skulle kunna klassas som ett **Lager 7-problem**.
8. Varför fokuserar en systemadministratör mer på Lager 4–7 än på Lager 1–2?
9. Vad är skillnaden i fokus mellan felsökning "Uppifrån och ner" jämfört med "Nedifrån och upp"?
10. Hur hjälper OSI-modellen till att undvika **Vendor Lock-in** vid design av nätverk?

## Fördjupningslänkar

Network World (Praktisk användning av OSI-modellen vid nätverksfelsökning) – <https://www.networkworld.com/article/712318/the-osi-model-explained.html>

SolarWinds (Beskrivning av specifika feltyper kopplade till OSI-modellens olika lager) – <https://www.solarwinds.com/resources/it-glossary/osi-model>

Cisco (Metoder och ramverk för strukturerad felsökning av nätverksproblem) – <https://www.cisco.com/c/en/us/support/docs/ip/routing-information-protocol-rip/13788-3.html>

CompTIA (Genomgång av den standardiserade felsökningsmodellen i sex steg) – <https://www.comptia.org/blog/how-to-troubleshoot-it-problems-in-6-steps>

IBM (Översikt över nätverksverktyg och tekniker för felanalys) – <https://www.ibm.com/docs/en/aix/7.2?topic=management-network-troubleshooting>

GeeksforGeeks (Kommandon för analys av nätverkskommunikation i Linux och Windows) – <https://www.geeksforgeeks.org/basic-network-troubleshooting-commands/>

Cloudflare (Beskrivning av felsökningsstrategier för nätverksanslutningar och anslutningsproblem) – <https://www.cloudflare.com/learning/network-layer/network-troubleshooting/>

Microsoft Learn (Verktøy och tekniker för att diagnostisera nätverksproblem i Windows-miljöer) – <https://learn.microsoft.com/en-us/windows-server/networking/technologies/network-subsystem/net-sub-troubleshoot-tools>

## 9.4 OSI-modellen i praktiken

### Kontrollfrågor

1. Vilket lager ansvarar för att kryptera webbtrafiken med TLS/SSL?
2. Vid vilket steg delas den stora mängden data upp i mindre **Segment (Segments)**?
3. Vad händer i **Datalänklaget (Layer 2)** hos mottagaren om kontrollsumman (Footern) inte stämmer?
4. Varför behöver vi **Portnummer** i Lager 4 när vi redan har **IP-adresser** i Lager 3?
5. Förklara skillnaden i vad som händer i Lager 1 jämfört med Lager 7.
6. Vad skulle hända med webbsidan om **Lager 4 (Transport)** inte skötte ordningen på segmenten?
7. I vilket lager fattar en router beslut om vilken väg ett paket ska skickas?
8. Varför kallas processen hos mottagaren för **Avkapsling (Decapsulation)**?
9. Vilket lager "pratar" din webbläsare direkt med?
10. Hur samarbetar Lager 2 och Lager 3 för att leverera data från din dator till en server på andra sidan jorden?

## Fördjupningslänkar

HubSpot (Beskrivning av processerna bakom en webbegäran och nätverkskommunikation) - <https://blog.hubspot.com/marketing/how-the-web-works>

Mozilla (Teknisk genomgång av webbens funktion och kommunikationsprotokoll) - [https://developer.mozilla.org/en-US/docs/Learn/Getting\\_started\\_with\\_the\\_web/How\\_the\\_Web\\_works](https://developer.mozilla.org/en-US/docs/Learn/Getting_started_with_the_web/How_the_Web_works)

Cloudflare (Beskrivning av hur data färdas över internet och genom olika nätverksslager) - <https://www.cloudflare.com/learning/performance/how-does-the-internet-work/>

W3C (Arkitektur för World Wide Web och tekniska standarder för kommunikation) - <https://www.w3.org/TR/webarch/>

AWS (Förklaring av klient-server-modellen och dess praktiska tillämpning i molnmiljöer) - <https://aws.amazon.com/what-is/client-server-model/>

Google (Översikt över hur infrastruktur och protokoll samverkar vid hantering av webbtrafik) - <https://www.google.com/search/howsearchworks/our-approach/>

Cisco (Teknisk artikel om applikationslagrets funktioner och protokoll i praktiken) - <https://www.cisco.com/c/en/us/support/docs/ip/routing-information-protocol-rip/13769-5.html>

## 9.5 Sammanfattning: OSI-modellen som kompass

### Kontrollfrågor

1. Varför kallas OSI-modellen för en **Referensmodell (Reference model)** snarare än ett protokoll?
2. Hur hjälpte OSI-modellen till att bryta tidsålderns **Vendor Lock-in**?
3. Förklara kortfattat vad som händer med en **PDU** under processen **Avkapsling (Decapsulation)**.
4. Vilka två lager i OSI-modellen är mest kritiska för en nätverkstekniker som arbetar med kablar och switchar?
5. Varför är **TCP** (Lager 4) så viktigt för integriteten hos en webbsida som skickas över nätverket?
6. Ge ett exempel på hur fackspråket "ett Lager 3-problem" underlättar kommunikation mellan tekniker.
7. Vad är den främsta fördelen med att nätverkskommunikation är **Modulär**?
8. Vilken roll spelar **Presentationslagret (Layer 6)** i en värld där säkerhet (kryptering) blir allt viktigare?
9. Beskriv fördelen med felsökningsmetoden **Söndra och härska (Divide and Conquer)**.
10. Varför klumpar TCP/IP-modellen ofta ihop de tre översta lagren i OSI-modellen till ett enda?

## Fördjupningslänkar

GeeksforGeeks (Jämförelse mellan TCP/IP- och OSI-modellen) –

<https://www.geeksforgeeks.org/tcp-ip-model-vs-osi-model/>

Wireshark Foundation (Officiell webbplats för verktyget som möjliggör analys av nätverkstrafik i realtid) – <https://www.wireshark.org/>

Cloudflare (Genomgång av OSI-modellen och dess koppling till molntjänster och nätverkssäkerhet) – <https://www.cloudflare.com/learning/ddos/glossary/open-systems-interconnection-model-osi/>

Microsoft Learn (Dokumentation om nätverksprotokoll och deras funktioner i moderna operativsystem) –

<https://learn.microsoft.com/en-us/windows-server/networking/technologies/network-subsystem/net-sub-performance-topologies>

TechTarget (Sammanfattning av nätverkslager och standardiserade protokoll) –

<https://www.techtarget.com/searchnetworking/definition/OSI>

Guru99 (Jämförelsetabell och teknisk sammanfattning av nätverksmodeller) –

<https://www.guru99.com/difference-tcp-ip-vs-osi-model.html>

Cisco (Översikt över nätverksmodeller och arkitektur för certifieringsstudier) –

<https://www.cisco.com/c/en/us/support/docs/ip/routing-information-protocol-rip/13769-5.html>

# 10 Dataöverföring och Fjärradministration

## 10.1 Filöverföring i praktiken (FTP, SFTP och SCP)

### Kontrollfrågor

1. Vad är den huvudsakliga uppgiften för ett filöverföringsprotokoll?
2. Vilken port används som standard för vanlig FTP-trafik?
3. Förklara vad det innebär att data skickas i "klartext".
4. Hur kan en programvara som Wireshark användas för att stjäla information från en FTP-anslutning?
5. Vilken teknik bygger både SFTP och SCP på för att skapa säkerhet?
6. Vilken port används som standard för SFTP och SCP?
7. Beskriv skillnaden i funktionalitet mellan SFTP och SCP.
8. Varför är det säkrare att använda SFTP än FTP när man sitter på ett publikt Wi-Fi?
9. Vad ser en angripare som försöker avlyssna en krypterad SFTP-överföring?
10. Ge ett exempel på ett program (klient) man kan använda för att utföra säkra filöverföringar grafiskt.

## Fördjupningslänkar

FileZilla Project (Populär öppen källkod-klient för säkra filöverföringar) –  
<https://filezilla-project.org/>

WinSCP: SFTP vs FTP (En teknisk jämförelse av säkerhet och prestanda) –  
<https://winscp.net/eng/docs/introduction>

IETF RFC 959 (Den officiella, historiska specifikationen för FTP) –  
<https://datatracker.ietf.org/doc/html/rfc959>

SSH.com: What is SFTP? (En djupdykning i hur SFTP fungerar tekniskt) –  
<https://www.ssh.com/academy/ssh/sftp>

Cyberciti: SCP Command Examples (Praktisk guide för hur man flyttar filer via terminalen) – <https://www.cyberciti.biz/faq/scp-command-examples/>

NIST SP 800-123 (Riktlinjer för säker konfiguration av servrar och protokoll) –  
<https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-123.pdf>

## 10.2 Webbens protokoll (HTTP och HTTPS)

### Kontrollfrågor

1. Vad är huvudsyftet med protokollet HTTP?
2. Vilken port används normalt för osäker HTTP-trafik?
3. Förklara risken med att skicka data i "klartext".
4. Hur kan en angripare använda programvaran Wireshark för att skada en användare som surfar via HTTP?
5. Vad är den tekniska skillnaden mellan HTTP och HTTPS?
6. Vilken port använder HTTPS som standard?
7. Vad är ett självsignerat certifikat och i vilka situationer kan det vara användbart?
8. Vilken är den största faran med att lita på självsignerade certifikat på publika webbplatser?
9. Nämn en tjänst som man kan använda för att skaffa ett gratis, betrott certifikat till sin server.
10. Varför är det ett misstag att tro att en webbplats är helt säker bara för att den har ett hänglås i adressfältet?

## Fördjupningslänkar

Cloudflare: What is HTTP? –

<https://www.cloudflare.com/learning/ddos/glossary/hypertext-transfer-protocol-http/>

DigiCert: How does SSL/TLS work? – <https://www.digicert.com/dc/blog/how-does-ssl-tls-work/>

Let's Encrypt: Getting Started – <https://letsencrypt.org/getting-started/>

SSL Labs: SSL Server Test (Ett verktyg för att testa hur säkert en webbplats certifikat faktiskt är) – <https://www.ssllabs.com/ssltest/>

OWASP: Transport Layer Protection Cheat Sheet – [https://cheatsheetseries.owasp.org/cheatsheets/Transport\\_Layer\\_Protection\\_Cheat\\_Sheet.html](https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Protection_Cheat_Sheet.html)

## 10.3 Fjärrstyrning av system (SSH och RDP)

### Kontrollfrågor

1. Varför är fjärrstyrning nödvändigt i moderna datacenter?
2. Vilket protokoll är standard för textbaserad fjärrstyrning av Linux?
3. Varför är SSH säkrare än det äldre protokollet Telnet?
4. Vilken port använder RDP som standard i Windows?
5. Vad är den största tekniska skillnaden mellan SSH och grafiska lösningar som RDP?
6. Nämn en fördel och en nackdel med protokollet VNC.
7. Hur skiljer sig TeamViewer från RDP när det gäller att ta sig igenom brandväggar?
8. Varför är Chrome Remote Desktop en populär lösning för hemanvändare?
9. Vad är en "Brute Force-attack" och varför är öppna fjärrportar ett mål för detta?
10. Vad ser en person som avlyssnar en SSH-session med programmet Wireshark?

## Fördjupningslänkar

SSH.com: What is SSH? – <https://www.ssh.com/academy/ssh/protocol>

Microsoft Learn: How Remote Desktop works – <https://learn.microsoft.com/en-us/windows/win32/termserv/how-remote-desktop-works>

RealVNC: What is VNC? (Förklaring av protokollet bakom skärmdelning) – <https://www.realvnc.com/en/news/what-is-vnc/>

TeamViewer: How it works (Om tekniken bakom brandväggsgenomträngning) – <https://www.teamviewer.com/en/res/pdf/TeamViewer-Security-Statement-en.pdf>

Chrome Remote Desktop Help – <https://support.google.com/chrome/answer/1649523>

AnyDesk: Security Features – <https://anydesk.com/en/features/security>

## 10.4 Filutdelning i lokala nätverk (SMB och NFS)

### Kontrollfrågor

1. Vilket protokoll är standard för filutdelning i Windows-miljöer?
2. Vilken port använder modernt SMB (port 445)?
3. Nämn två typer av kringutrustning, utöver filer, som SMB kan dela ut i ett nätverk.
4. Varför anses den gamla versionen SMBv1 vara en säkerhetsrisk idag?
5. Förklara skillnaden mellan autentisering och behörighet i SMB-sammanhang.
6. Vilket protokoll används främst för att dela filer mellan Linux-servrar?
7. Vad innebär det att en NFS-utdelning "monteras" i filsystemet?
8. Vad är Samba och vilken nytta gör det i ett nätverk med både Windows och Linux?
9. Vad står förkortningen CUPS för och vad är dess primära uppgift?
10. Vilket protokoll och vilken port använder CUPS vanligtvis för att hantera utskrifter?

## Fördjupningslänkar

Microsoft Learn: Server Message Block overview –  
<https://learn.microsoft.com/en-us/windows-server/storage/file-server/file-server-smb-overview>

Red Hat: What is NFS? (En genomgång av Network File System för administratörer) – <https://www.redhat.com/en/topics/data-storage/what-is-nfs>

Samba.org: What is Samba? (Officiell sida för projektet som förenar Windows och Linux) – <https://www.samba.org/samba/whatisadot.html>

OpenPrinting: CUPS Documentation (Allt om hur utskrifter fungerar i Unix-miljöer) – <https://openprinting.github.io/cups/>

Wireshark Wiki: SMB2 (Teknisk information om hur man analyserar SMB-trafik) – <https://wiki.wireshark.org/SMB2>

Ubuntu Documentation: NFS Client Setup (Praktisk guide för att montera utdelningar i Linux) – <https://ubuntu.com/server/docs/service-nfs>

CISA: Security Best Practices for SMB –  
<https://www.cisa.gov/news-events/news/securing-network-infrastructure-devices-smb>

## 10.5 E-postens infrastruktur (SMTP, IMAP och POP3)

### Kontrollfrågor

1. Vilket protokoll används uteslutande för att *skicka* e-post?
2. Vilken port användes förr för SMTP och varför har man gått ifrån den?
3. Förklara den största skillnaden mellan hur POP3 och IMAP hanterar meddelanden.
4. Varför är IMAP bättre lämpat än POP3 om du använder flera olika enheter för att läsa din e-post?
5. Vilka portar förknippas vanligtvis med säkra (krypterade) IMAP-anslutningar?
6. Vad händer med ett mejl på servern när det hämtas via POP3 med standardinställningar?
7. Vad är risken med att skicka e-post över okrypterade portar (t.ex. port 25 eller 110)?
8. Vad innebär begreppet "synkronisering" i samband med IMAP?
9. Vilket verktyg kan en angripare använda för att läsa ett mejl som skickas i klartext?
10. Varför räcker det inte med krypterad överföring för att ett mejl ska anses vara helt privat?

## Fördjupningslänkar

Google Workspace Support: SMTP, IT-administratörens översikt –

<https://support.google.com/a/answer/176600>

Microsoft Learn: POP3 and IMAP4 in Exchange Server –

<https://learn.microsoft.com/en-us/exchange/clients/pop3-and-imap4/pop3-and-imap4>

Mozilla Support: Glossary of Email terms (SMTP, IMAP, POP) –

<https://support.mozilla.org/en-US/kb/glossary-terms-including-protocols>

IETF RFC 5321 (Den officiella tekniska specifikationen för SMTP) –

<https://datatracker.ietf.org/doc/html/rfc5321>

Fastmail Blog: Why IMAP is better than POP (En enkel men tydlig jämförelse) –

<https://www.fastmail.com/blog/imap-vs-pop/>

Cloudflare: What is a DNS MX record? (Hur internet hittar rätt e-postserver) –

<https://www.cloudflare.com/learning/dns/dns-records/dns-mx-record/>

## 10.6 VPN (Virtual Private Network)

### Kontrollfrågor

1. Nämn tre olika syften med att använda ett VPN.
2. Vad innebär "IP-maskering" i praktiken?
3. Varför är det viktigt att noga välja vilken VPN-leverantör man använder?
4. Vad ser en VPN-leverantör som inte din internetleverantör kan se?
5. Förklara huvudsyftet med Tor jämfört med ett vanligt VPN.
6. Varför kallas Tor för "lök-routern"?
7. Beskriv de tre olika noderna i ett Tor-nätverk och vilken information de har tillgång till.
8. Vad är den största nackdelen med att använda Tor för vardagligt surfande?
9. Kan man vara helt säker på att vara anonym bara för att man använder VPN? Motivera.
10. Återknyt till kapitel 10.2: Varför är det fortfarande viktigt att använda HTTPS även om du surfar genom Tor?

## Fördjupningslänkar

The Tor Project: How Tor Works – <https://community.torproject.org/onion-services/overview/>

Electronic Frontier Foundation (EFF): Surveillance Self-Defense – <https://ssd.eff.org/en/module/choosing-vpn-thats-right-you>

CISA: Security Tip on Virtual Private Networks – <https://www.cisa.gov/news-events/news/virtual-private-networks>

WireGuard: Protocol Overview – <https://www.wireguard.com/protocol/>

Cloudflare: How does a VPN work? – <https://www.cloudflare.com/learning/network-layer/how-does-a-vpn-work/>

## 10.7 Peer-to-Peer (P2P) och BitTorrent

### Kontrollfrågor

1. Vad är den principiella skillnaden mellan en Client-Server-modell och Peer-to-Peer (P2P)?
2. Varför blir ett P2P-nätverk ofta snabbare ju fler användare som ansluter?
3. Vad innebär det att en fil delas upp i "chunks"?
4. Förklara begreppet "Swarm" i BitTorrent-sammanhang.
5. Vad är skillnaden mellan en "Seed" och en "Leech"?
6. Varför är det tekniskt omöjligt att slutföra en nedladdning om det finns noll "Seeds" i nätverket?
7. Hur används hashing för att säkerställa att en fil inte har manipulerats under en P2P-överföring?
8. Vad kallas den funktion i Windows som använder P2P för att sprida uppdateringar lokalt?
9. Vilken är den främsta fördelen för ett företag att använda Windows Leveransoptimering?
10. Varför är P2P-teknik särskilt lämpad för att distribuera stora filer som t.ex. installationsfiler för operativsystem?

## Fördjupningslänkar

Official BitTorrent Specification (Den tekniska beskrivningen av protokollet) –  
[https://www.bittorrent.org/beps/bep\\_0003.html](https://www.bittorrent.org/beps/bep_0003.html)

Microsoft Learn: Windows Update Delivery Optimization (Hur Windows använder P2P) –  
<https://learn.microsoft.com/en-us/windows/deployment/update/waas-delivery-optimization>

The Register: How BitTorrent Works (En pedagogisk genomgång av tekniken) –  
[https://www.theregister.com/2012/11/09/how\\_bittorrent\\_works/](https://www.theregister.com/2012/11/09/how_bittorrent_works/)

Academic Earth: Peer-to-Peer Systems (Föreläsning om nätverksarkitekturer) –  
<https://academicearth.org/computer-science/>

Cloudflare: What is P2P? –  
<https://www.cloudflare.com/learning/network-layer/what-is-p2p/>

# 11 Introduktion till IT-säkerhet

## Kontrollfrågor

1. Varför fungerar inte den gamla "slottsmodellen" (enbart brandvägg) i dagens IT-miljöer?
2. Vad är kärnan i begreppet Zero trust
3. Vad menas med påståendet att "säkerhet är en process, inte en produkt"?
4. Förklara skillnaden mellan att vara en tekniker och att vara en säkerhetsarkitekt.
5. Varför är det omöjligt att uppnå 100 % säkerhet, och vad bör målet vara istället?
6. Vilken roll spelar riskvärdering i en systemadministratörs dagliga arbete?
7. Hur har digitaliseringen och molntjänster förändrat sättet vi ser på systemets "gränser"?

## Fördjupningslänkar

MSB (Information om cybersäkerhet och skydd av samhällsviktig verksamhet) – <https://www.msb.se/sv/amnesomraden/informationssakerhet-cybersakerhet/>

NCSC (Ramverk i tio steg för att bygga och underhålla ett systematiskt IT-försvaret) – <https://www.ncsc.gov.uk/collection/10-steps>

ENISA (Europeiska unionens resurser och rapporter om det aktuella hotlandskapet) – <https://www.enisa.europa.eu/>

NIST (Definition av CIA-triaden och grundläggande säkerhetsmål) – [https://csrc.nist.gov/glossary/term/cia\\_triad](https://csrc.nist.gov/glossary/term/cia_triad)

CISA (Vägledning för riskhantering och identifiering av hot i digitala miljöer) – <https://www.cisa.gov/topics/risk-management>

OWASP (Förteckning över kritiska sårbarheter och metoder för att säkra applikationer) – <https://owasp.org/www-project-top-ten/>

MITRE ATT&CK (Matris för kartläggning och analys av angripares tekniker och taktiker) – <https://attack.mitre.org/>

SANS Institute (Handbok för metodik vid hantering och respons på säkerhetsincidenter) – <https://www.sans.org/white-papers/33901/>

Microsoft Learn (Principer för Zero Trust-arkitektur och moderna skyddsmetoder) – <https://learn.microsoft.com/en-us/security/zero-trust/zero-trust-overview>

## 11.1 Vad är IT-säkerhet?

### Kontrollfrågor

1. Förklara de tre delarna i CIA-triaden och ge ett praktiskt exempel på varje del.
2. I exemplet med servern på torget, vilken del av CIA-triaden drabbas hårdast och varför?
3. Varför hjälper inte MFA och en säker bunker om man använder osäkra protokoll som FTP?
4. Vad innebär begreppet Asset i säkerhetssammanhang?
5. Hur kan en säkerhetsåtgärd som stärker Confidentiality samtidigt skada Availability?
6. Vad menas med Risk Appetite och hur påverkar det en organisations säkerhetsbeslut?
7. Vilket begrepp i CIA-triaden handlar om att kunna lita på att informationen är korrekt och omanipulerad?
8. Ge ett eget exempel på en situation där man har hög Confidentiality men låg Availability.
9. Vilken är den tekniska skillnaden mellan ett hot (Threat) och en sårbarhet (Vulnerability)?
10. Varför är det nödvändigt att prioritera sina Assets innan man implementerar säkerhetskontroller?

## Fördjupningslänkar

SANS Institute (Beskrivning av hur CIA-modellen används i säkerhetsarbete) – <https://www.sans.org/white-papers/2114/>

CISA (Information om integritet, konfidentialitet och tillgänglighet) – <https://www.cisa.gov/news-events/news/understanding-integrity-confidentiality-and-availability>

OWASP (Principer för att bygga säkra system) – [https://owasp.org/www-community/Security\\_Principles](https://owasp.org/www-community/Security_Principles)

MSB (Vägledning för systematiskt informationssäkerhetsarbete) – <https://www.msb.se/sv/amnesomraden/informationssakerhet-cybersakerhet/systematiskt-informationssakerhetsarbete/>

NIST (Teknisk definition av risk och tillgångar) – <https://csrc.nist.gov/glossary/term/risk>

Cloudflare (Översikt av CIA-triaden inom cybersäkerhet) – <https://www.cloudflare.com/learning/security/what-is-the-cia-triad/>

ISO (Introduktion till ISO/IEC 27001-standarden för informationssäkerhet) – <https://www.iso.org/isoiec-27001-information-security.html>

## 11.2 Grundläggande arkitekturprinciper

### Kontrollfrågor

1. Förklara principen **Defense in Depth** och ge exempel på tre olika lager.
2. Vad är syftet med en **Mantrap** i en fysisk säkerhetsmiljö?
3. Varför är **Nätverkssegmentering** avgörande för att stoppa "Lateral Movement"?
4. Beskriv skillnaden mellan en traditionell brandvägg och ett **IDS/IPS-system**.
5. Varför räcker det inte med starka lösenord om man inte tillämpar **Least Privilege**?
6. Förklara begreppet **Zero Trust** och hur det skiljer sig från den gamla "slottsmodellen".
7. Ge ett exempel på när ett system bör vara **Fail Secure** respektive **Fail Safe**.
8. Varför används gas istället för vatten som brandsläckning i en serverhall?
9. Vad innebär det att arbeta med **RBAC** (Role-Based Access Control)?
10. Vilken roll spelar **EDR** i skyddet av enskilda servrar jämfört med ett vanligt antivirus?

## Fördjupningslänkar

Uptime Institute (Klassificering av tillförlitlighet och redundans i datacenter) – <https://uptimeinstitute.com/tiers>

NIST (Dokumentation av arkitekturprinciper för Zero Trust) – <https://csrc.nist.gov/publications/detail/sp/800-207/final>

CIS (Prioriterad lista över tekniska säkerhetsåtgärder för organisationer) – <https://www.cisecurity.org/controls/cis-controls-list/>

Microsoft (Översikt av strategier för Defense in Depth och lagerbaserat skydd) – <https://learn.microsoft.com/en-us/security/zero-trust/defense-in-depth>

Cloudflare (Teknisk genomgång av Zero Trust-modellen och dess komponenter) – <https://www.cloudflare.com/learning/security/glossary/what-is-zero-trust/>

NCSC (Principer för säker nätverksdesign och systemarkitektur) – <https://www.ncsc.gov.uk/collection/design-principles>

SANS Institute (Riktlinjer för fysisk säkerhet och kontroll av tillträde till IT-miljöer) – <https://www.sans.org/white-papers/117/>

## 11.3 Autentisering och auktorisering

### Kontrollfrågor

1. Förklara skillnaden mellan autentisering och auktorisering med ett eget exempel från vardagen.
2. Varför anses MFA vara så mycket säkrare än bara ett starkt lösenord?
3. Ge ett exempel på en situation där en PIN-kod är mer praktisk än ett långt lösenord.
4. Vad innebär "Principle of Least Privilege" och varför är det viktigt i en företagsmiljö?
5. Vilka är de tre faktorerna (boxarna) man pratar om inom MFA? *Kontrollera dina kunskaper på:* <https://www.skolverket.se/it-sakerhet-grund>

## Fördjupningslänkar

MSB (Tänk säkert – Handfasta råd för privatpersoner och företag) –  
<https://www.msb.se/sv/amnesomraden/informationssakerhet-cybersakerhet/tank-sakert/>

Internetkunskap (Allt om lösenord och hur du skapar säkra inloggningar) –  
<https://internetkunskap.se/snabbkurser/losenord-och-sakerhet/>

NCSC-UK (Guide till multifaktorautentisering och varför det behövs) –  
<https://www.ncsc.gov.uk/guidance/multi-factor-authentication-mfa>

IDG (Vad är biometri? En genomgång av teknikerna bakom ansiktsgenkänning och fingeravtryck) – <https://www.idg.se/2.1085/1.534567/vad-ar-biometri>

CISA (Fördjupning i Principle of Least Privilege för systemadministratörer) –  
<https://www.cisa.gov/news-events/alerts/2019/12/10/principle-least-privilege>

## 11.4 Riskhantering – Sårbarhet, Hot och Risk

### Kontrollfrågor

1. Vad är skillnaden mellan en sårbarhet (Vulnerability) och ett hot (Threat)?
2. Förklara begreppet RTO och ge ett exempel på en verksamhet med mycket lågt RTO-krav.
3. Vad innebär RPO och hur påverkar det hur ofta vi bör ta backup?
4. Varför är ett sjukhus journalsystem mer kritiskt i en BIA än en e-handels blogg?
5. Vilka är de fem vanligaste kolumnerna i ett riskregister?
6. Hur räknar man ut ett riskvärde (Score) i ett riskregister?
7. Ge ett exempel på när man skulle välja strategin "Överföra" (Transfer) för en risk.
8. Varför är det viktigt att ledningen godkänner om en IT-avdelning väljer att "Acceptera" en risk?
9. Beskriv ett scenario där sannolikheten är hög (5) men konsekvensen är låg (1). Hur prioriteras denna risk?
10. Hur hjälper BIA oss att bestämma vilken budget vi behöver för IT-säkerhet?

## Fördjupningslänkar

NIST (Guide för genomförande av riskbedömningar inom IT-system) –  
<https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-30r1.pdf>

ISO (Internationell standard för principer och riktlinjer gällande riskhantering) –  
<https://www.iso.org/iso-31000-risk-management.html>

MSB (Vägledning för genomförande av verksamhetsanalys och konsekvensbedömning) –  
<https://www.msb.se/sv/amnesomraden/informationssakerhet-cybersakerhet/systematiskt-informationssakerhetsarbete-sisa/analysera/verksamhetsanalys/>

Cloudflare (Förklaring av mätvärdena RTO och RPO vid katastrofplanering och återställning) – <https://www.cloudflare.com/learning/dr/rto-vs-rpo/>

MITRE (CVE – Den officiella listan över offentligt kända sårbarheter i mjukvara och system) – <https://cve.mitre.org/>

FIRST (CVSS – Standardiserat system för att bedöma och poängsätta sårbarheters allvarlighetsgrad) – <https://www.first.org/cvss/>

SANS Institute (Beskrivning av metodik för att identifiera och hantera IT-risker) – <https://www.sans.org/white-papers/1199/>

IBM (Översikt av strategier för riskhantering och prioritering av säkerhetsåtgärder) – <https://www.ibm.com/topics/cybersecurity-risk-management>

## 11.5 IT-säkerhet ur ett verksamhetsperspektiv

### Kontrollfrågor

1. Varför betraktas IT-säkerhet idag som en ledningsfråga snarare än enbart en teknikfråga?
2. Förklara skillnaden mellan en Policy och en Procedure.
3. Vad innebär begreppet Privacy by Design inom GDPR?
4. Vilken är den huvudsakliga skillnaden i syfte mellan GDPR och NIS2?
5. Varför är ledningens personliga ansvar i NIS2 en så viktig förändring?
6. Hur fungerar rapporteringsskyldigheten vid en incident enligt NIS2?
7. Vad är ett ISMS och vilken roll spelar det i ISO 27001?
8. Vad är skillnaden på en intern och en extern revision vid ISO-certifiering?
9. Vad är ett SLA och vilken roll spelar det vid upphandling av molntjänster?
10. Varför är Supply Chain Security ett så stort fokus i moderna regelverk?

## Fördjupningslänkar

IMY (Information om GDPR och dataskydd) –

<https://www.imy.se/verksamhet/dataskydd/dataskyddsförordningen/>

MSB (Vägledning om NIS2-direktivet) –

<https://www.msb.se/sv/amnesomraden/informationssakerhet-cybersakerhet/nis-direktivet/>

ISO (Standard för ledningssystem, ISO/IEC 27001) – <https://www.iso.org/isoiec-27001-information-security.html>

NCSC (IT-säkerhet för ledningsgrupper) –

<https://www.ncsc.gov.uk/collection/board-toolkit>

NIST (Ramverk för riskhantering) – <https://www.nist.gov/cyberframework>

SANS (Mallar för säkerhetspolicyer) – <https://www.sans.org/information-security-policy/>

Cloudflare (Compliance kontra faktisk säkerhet) –

<https://www.cloudflare.com/learning/security/what-is-cyber-compliance/>

## 11.6 Vanliga angrepp mot klienter och system

### Kontrollfrågor

1. Vad är den tekniska skillnaden mellan Man-in-the-Middle och Man-on-the-Side?
2. Varför är en Man-in-the-Browser-attack så svår att upptäcka för en vanlig användare?
3. Förklara scenariot för en Evil Maid-attack och vilka delar av systemet den siktar på.
4. Hur kan en keylogger användas i kombination med en Evil Maid-attack?
5. Varför hjälper inte HTTPS-kryptering mot en Man-in-the-Browser-attack?
6. Vad är skillnaden mellan ett virus och en mask (Worm) när det gäller spridning?
7. Beskriv hur en SQL Injection kan leda till att en hel databas läcks.
8. Vad innebär begreppet Zero-day och varför är det så kritiskt för en säkerhetsansvarig?
9. Vilken roll spelar "Input Validation" i försvaret mot SQLi och XSS?
10. Hur kan fysisk säkerhet i en serverhall förhindra en Evil Maid-attack?

## Fördjupningslänkar

OWASP (Sårbarheter i webbapplikationer) – <https://owasp.org/www-project-top-ten/>

MITRE ATT&CK (Ramverk för angreppstekniker) – <https://attack.mitre.org/>

The Register (Säkerhetsnyheter och Zero-days) – <https://www.theregister.com/security/>

BleepingComputer (Nyheter om ransomware och malware) – <https://www.bleepingcomputer.com/>

Krebs on Security (Djupdykning i dataintrång) – <https://krebsonsecurity.com/>

Have I Been Pwned? (Sökverktyg för dataläckor) – <https://haveibeenpwned.com/>

Dark Reading (Analys av IT-säkerhetstrender) – <https://www.darkreading.com/>

CISA (Katalog över kända och utnyttjade sårbarheter) – <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>

## 11.7 Säkerhetskultur och den operativa vardagen

### Kontrollfrågor

1. Varför räcker det inte med tekniska skydd om personalen saknar Security Awareness?
2. Vad är syftet med en Acceptable Use Policy (AUP)?
3. Förklara begreppet Shadow IT och ge ett exempel på varför en anställd kan frestas att använda det.
4. Vilka är de största riskerna med Shadow IT ur ett säkerhetsperspektiv?
5. Vad innebär BYOD och vilken teknisk lösning används ofta för att hantera det?
6. Varför är en "Post-it-lapp med lösenord" ett brott mot både Clean Desk och grundläggande säkerhetsprinciper?
7. Hur fungerar "Secure Print" och vilken del av CIA-triaden skyddar det främst?
8. Varför är det viktigt att ha en kultur där anställda vågar rapportera om de råkat klicka på en misstänkt länk?
9. Ge ett exempel på en regel som kan finnas i en AUP gällande installation av mjukvara.
10. Hur kan MDM hjälpa till att upprätthålla Confidentiality på en privatägd mobiltelefon?

## Fördjupningslänkar

SANS Institute (Material för att bygga en säkerhetskultur) –

<https://www.sans.org/security-awareness-training/>

Computer Weekly (Hantering av risker med skugg-IT/Shadow IT) –

<https://www.computerweekly.com/feature/How-to-manage-the-risks-of-shadow-IT>

Microsoft Learn (Översikt av MDM för styrning av enheter) –

<https://learn.microsoft.com/en-us/windows/client-management/mdm/>

NCSC (Vägledning för att förhindra nätfiske och social engineering) –

<https://www.ncsc.gov.uk/guidance/phishing>

KnowBe4 (Resurser om mänskliga faktorer och säkerhetsmedvetenhet) –

<https://www.knowbe4.com/resources>

MSB (Vägledning för säkra lösenord och multifaktorautentisering) –

<https://www.msb.se/sv/rad-till-privatpersoner/informationssakerhet/skydda-dina-konton-och-enheter/>

## 11.8 Moderna hot och skydd: En digital kapprustning

### Kontrollfrågor

1. Resonera kring varför identiteten har ersatt nätverksgränsen som den viktigaste säkerhetsnivån i en modern miljö.
2. Hur förändrar **Micro-segmentation** förutsättningarna för en angripare som lyckats ta sig in i nätverket?
3. Beskriv hur AI kan användas för att både skapa mer trovärdiga attacker och mer effektiva försvar.
4. Vad är den vanligaste missuppfattningen kring **Shared Responsibility Model** i molnet?
5. Förklara skillnaden i arbetssätt mellan ett traditionellt antivirus och en modern **EDR-lösning**.
6. Varför räcker det inte med enbart tekniska lösningar när angripare börjar använda **Deepfakes**?
7. Vilken funktion fyller en **SIEM** i en organisation som hanterar stora mängder loggdata?
8. Ge ett exempel på en händelse som skulle kunna klassas som en "anomali" i ett nätverk.
9. Hur bidrar **Continuous Monitoring** till att upprätthålla Zero Trust-principen?
10. Vad innebär det praktiskt för en tekniker att molnleverantören ansvarar för "säkerhet av molnet" medan teknikern ansvarar för "säkerhet i molnet"?

## Fördjupningslänkar

Microsoft Security (Arkitektur och ramverk för Zero Trust) –

<https://www.microsoft.com/en-us/security/business/zero-trust>

Cloud Security Alliance (Branschstandard för säkerhet i molnmiljöer) –

<https://cloudsecurityalliance.org/artifacts/security-guidance-v4/>

Wazuh (Dokumentation för modern SIEM- och EDR-plattform) –

<https://documentation.wazuh.com/current/index.html>

CrowdStrike (Teknisk genomgång av moderna ransomware-hot) –

<https://www.crowdstrike.com/cybersecurity-101/malware/ransomware/>

Mandiant (Rapporter om avancerade hot och statsunderstödda attacker) –

<https://www.mandiant.com/resources/insights>

VirusTotal (Verktyg för analys av filer och misstänkta länkar) –

<https://www.virustotal.com/>

Malwarebytes (Uppslagsverk över olika typer av skadlig kod) –

<https://www.malwarebytes.com/glossary>

Cisco (Förklaring av rootkits och avancerade dolda hot) –

<https://www.cisco.com/c/en/us/products/security/advanced-malware-protection/what-is-a-rootkit.html>

AV-TEST (Oberoende jämförelser av skyddsmjukvara) – <https://www.av-test.org/>

## 11.9 Verktyg, övervakning och loggning

### Kontrollfrågor

1. Vad är huvudsyftet med en dashboard i en IT-miljö?
2. Jämför dashboarden i Webmin med ett verktyg som Grafana. När räcker Webmin till och när behöver man mer kraftfulla lösningar?
3. Varför är centraliserad loggning en kritisk säkerhetsåtgärd vid ett intrångsförsök?
4. Förklara hur övervakning med verktyg som Zabbix stödjer pelaren **Availability** i CIA-triaden.
5. Vilken typ av information förväntar du dig att hitta på en dashboard i Wazuh jämfört med en i Grafana?
6. Vad innebär begreppet **Retention** och varför är det viktigt ur ett juridiskt perspektiv?
7. Hur kan en dashboard hjälpa en tekniker att upptäcka en anomali (avvikelse) innan det blir ett kritiskt fel?
8. Varför är det viktigt att loggar skickas till en central server i realtid istället för att bara sparas ner en gång per dygn?
9. Ge ett exempel på en händelse som skulle loggas som **Critical** på en dashboard.
10. Vilken roll spelar en NOC (Network Operations Center) i användandet av dashboards?

## Fördjupningslänkar

Grafana Labs (Visualisering av nätverks- och systemdata) -

<https://grafana.com/docs/grafana/latest/introduction/>

Zabbix (Övervakning av infrastruktur och tjänster) -

<https://www.zabbix.com/documentation/current/en/manual/introduction/about>

Wazuh (Tolkning av säkerhetsdata i SIEM-dashboards) -

<https://documentation.wazuh.com/current/user-manual/wazuh-dashboard/index.html>

Splunk (Plattform för SIEM och storskalig logganalys) -

[https://www.splunk.com/en\\_us/products/enterprise-security.html](https://www.splunk.com/en_us/products/enterprise-security.html)

Elastic (Logghantering och sökning med ELK-stacken) -

<https://www.elastic.co/what-is/elk-stack>

Microsoft Learn (Hantering av loggar i Windows Event Viewer) -

<https://learn.microsoft.com/en-us/windows/win32/wes/windows-event-log-portal>

Nagios (Grundläggande övervakning av systemstatus) -

<https://www.nagios.org/projects/nagios-core/>

SolarWinds (Guide till logghantering och regelefterlevnad) -

<https://www.solarwinds.com/solutions/log-management-software>

## 11.10 Incidenthantering och katastrofplanering

### Kontrollfrågor

1. Varför är det viktigt att följa en förbestämd process (Incident Response) istället för att bara agera på instinkt när larmet går?
2. Beskriv fasen **Inneslutning (Containment)** och ge ett praktiskt exempel på en sådan åtgärd.
3. Varför anses fasen **Lärdomar (Lessons Learned)** vara den viktigaste för att förbättra säkerheten på sikt?
4. Förklara skillnaden mellan **Business Continuity (BC)** och **Disaster Recovery (DR)** med hjälp av exemplet om logistikföretaget.
5. Hur påverkar måtvärdena **RTO** och **RPO** den tekniska återställningen vid en katastrof?
6. Vad innebär det att en backup är "**immutable**" (icke-förändringsbar) och varför är det viktigt vid ett ransomware-angrepp?
7. Varför ska en tekniker undvika att ändra filer eller starta om en hackad server om man planerar en forensisk undersökning?
8. Vilket verktyg använder du för att se vad en angripare gjort direkt i nätverkstrafiken, och vilket använder du för att analysera innehållet i RAM-minnet?
9. Vad är syftet med **Chain of Custody** och hur används **hashes** (kontrollsummor) för att säkra bevis?
10. Varför är digital forensik extra viktigt för företag som omfattas av lagar som **NIS2** eller **GDPR**?

## Fördjupningslänkar

NIST (Internationell standard för incidenthantering, SP 800-61) –  
<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r2.pdf>

MSB (Vägledning för incidentrapportering och hantering i Sverige) –  
<https://www.msb.se/sv/amnesomraden/informationssakerhet-cybersakerhet/it-incidentrapportering/>

Autopsy (Verktyg och dokumentation för diskforensik) –  
<https://www.autopsy.com/resource-center/>

Volatility (Ramverk för analys av skadlig kod i arbetsminnet) –  
<https://www.volatilityfoundation.org/>

SANS (Praktiska lathundar för teknisk incidenthantering) –  
<https://www.sans.org/blog/incident-handling-cheat-sheets/>

Cloudflare (Skillnader mellan Business Continuity och Disaster Recovery) –  
<https://www.cloudflare.com/learning/dr/business-continuity-vs-disaster-recovery/>

NCSC (Principer för effektiv hantering av IT-incidenter) –  
<https://www.ncsc.gov.uk/collection/incident-management>

IBM (Översikt av katastrofplanering och strategier för återställning) –  
<https://www.ibm.com/topics/disaster-recovery-plan>

# 12 Etisk hacking och hackingkultur

## 12.1 Introduktion och etik: Hackingens hjärta

### Kontrollfrågor

1. Hur skiljer sig den ursprungliga betydelsen av ordet "hacking" (från t.ex. MIT på 60-talet) från hur media ofta framställer det idag?
2. Beskriv den moraliska skillnaden mellan en "vit hatt" och en "grå hatt".
3. Varför anses den grå hatten fortfarande vara problematisk?
4. Vilken specifik lag i den svenska Brottsbalken är mest relevant när man pratar om obehörig åtkomst till datasystem, och vad innebär den i praktiken?
5. Varför räcker det inte med ett muntligt "ja" från en IT-chef för att påbörja ett penetrationstest?
6. Vad kan konsekvenserna bli om en etisk hackare råkar utföra tester på en IP-adress som ligger utanför det överenskomna omfånget (scope)?
7. Vilken är den främsta fördelen för ett företag att använda en Bug Bounty-plattform istället för att bara förlita sig på sina egna säkerhetstekniker?
8. Texten nämner att hacking är 90 % efterforskning. Ge exempel på vad en hackare gör under denna tid innan de faktiskt försöker "ta sig in".
9. Vad är syftet med en ansvarsfriskrivning i ett RoE-dokument i händelse av att ett system kraschar under ett lagligt test?
10. Varför förväntas i princip alla som jobbar med IT idag ha koll på grundläggande säkerhetsprinciper?

## Fördjupningslänkar

Sveriges Riksdag (Brottsbalken: Läs direkt i lagtexten om dataintrång i 4 kap. 9c §) - [https://www.riksdagen.se/sv/dokument-lagar/dokument/svensk-forfattningssamling/brottsbalk-1962700\\_sfs-1962-700#K4](https://www.riksdagen.se/sv/dokument-lagar/dokument/svensk-forfattningssamling/brottsbalk-1962700_sfs-1962-700#K4)

HackerOne (Hacker 101: En omfattande guide för att förstå hur man börjar som etisk hackare lagligt) - <https://www.hackerone.com/hacker101>

EC-Council (Code of Ethics: De etiska reglerna som certifierade etiska hackare måste följa) - <https://www.eccouncil.org/code-of-ethics/>

MIT News (Hacking History: En tillbakablick på hackingens rötter och kultur vid MIT) - <https://news.mit.edu/2003/hackers>

Darknet Diaries (Podcast: Sanna historier från nätets mörka hörn för att förstå olika hackares vardag) - <https://darknetdiaries.com/>

IAPP (Privacy Ethics: Om de etiska utmaningarna med personlig integritet i en digital värld) - <https://iapp.org/resources/topics/ethics/>

Bugcrowd (Vulnerability Disclosure Policy: Hur företag sätter upp ramverk för att ta emot rapporter) - <https://www.bugcrowd.com/resource/what-is-a-vulnerability-disclosure-policy/>

SANS Institute (Legal issues in IT Security: En djupdykning i juridiska risker för säkerhetspersonal) - <https://www.sans.org/white-papers/644/>

Krebs on Security (En av världens främsta journalister som skriver om konsekvenserna av kriminell hacking) - <https://krebsonsecurity.com/>

Google Online Security Blog (Exempel på hur techbolag jobbar med etisk hacking och Bug Bounties) - <https://security.googleblog.com/>

## 12.2 Penetrationstestning som yrke

### Kontrollfrågor

1. Vilken huvudsaklig skillnad finns mellan målsättningen för ett vanligt penetrationstest och ett Red Team-uppdrag?
2. Vad fokuserar en webbstestare på att manipulera när de använder verktyg som Burp Suite?
3. Förklara skillnaden mellan interna och externa infrastrukturtester.
4. Vilka specifika tekniska protokoll och språk bör en webbstestare ha djup förståelse för?
5. Vad är syftet med att en fysisk pentestare placerar ut en så kallad Dropbox i en lokal?
6. Nämn två vanliga tekniker som används för att kringgå fysiska passerkontrollsystem.
7. Vad letar en molnspecialist främst efter när de granskar miljöer i AWS eller Azure?
8. Varför delas infrastrukturtester ofta upp i olika segment som nätverksprotokoll och Active Directory?
9. Hur skiljer sig tidsperspektivet för ett Red Team-uppdrag jämfört med ett standardiserat penetrationstest?
10. Vilket är huvudmålet för ett Blue Team i relation till ett pågående Red Team-scenario?

## Fördjupningslänkar

PortSwigger Academy (Gratis utbildning i webbsäkerhet och användning av Burp Suite) - <https://portswigger.net/web-security>

OWASP Web Security Testing Guide (Den mest omfattande guiden för testning av webbapplikationer) - <https://owasp.org/www-project-web-security-testing-guide/>

HackTricks (En enorm kunskapsdatabas för infrastrukturtester och privilege escalation) - <https://book.hacktricks.xyz/>

Microsoft Learn (Teknisk dokumentation om säkerhet i Active Directory och Windows Server) - <https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/plan/security-best-practices/>

PhysSec (Resurser och bloggar om metodik vid fysiska penetrationstester) - <https://www.redteamtools.com/university>

Cloud Security Alliance (Branschstandard för att säkra och testa molnmiljöer) - <https://cloudsecurityalliance.org/artifacts/security-guidance-v4/>

OWASP Mobile Security Project (Allt du behöver veta om att testa iOS- och Android-appar) - <https://mas.owasp.org/>

RedTeam.guide (En introduktion till metodiken och strategierna bakom Red Teaming) - <https://redteam.guide/>

MITRE ATT&CK (Matris för att förstå hur Red Teams mappar sina attacker mot verkliga hot) - <https://attack.mitre.org/>

SANS Institute (Artikel om skillnaderna mellan penetrationstester och Red Teaming) - <https://www.sans.org/white-papers/38535/>

## 12.3 Metodik: Cyber Kill Chain & PTES

### Kontrollfrågor

1. Vad är huvudsyftet med att använda en linjär modell som Cyber Kill Chain för en försvarare?
2. Förklara skillnaden mellan fasen Weaponization och fasen Exploitation.
3. Vad innebär Command & Control (C2) i en pågående attack?
4. Varför anses Intelligence Gathering vara den mest tidskrävande delen av PTES-standarden?
5. Ge ett exempel på information som kan samlas in via OSINT.
6. Vad är syftet med fasen Post Exploitation för en penetrationstestare?
7. Hur skiljer sig PTES-metodiken från en angripares okontrollerade framfart?
8. Vad innebär det att "bryta kedjan" i en Cyber Kill Chain-modell?
9. Varför är fasen Vulnerability Analysis viktig att genomföra innan Exploitation påbörjas?
10. Vilken roll spelar rapportering i PTES-standarden?

## Fördjupningslänkar

Lockheed Martin (Originalbeskrivningen av Cyber Kill Chain och dess sju steg) - <https://www.lockheedmartin.com/en-us/capabilities/cyber/cyber-kill-chain.html>

PTES Standard (Den officiella guiden för penetrationstestare och deras arbetsprocess) - [http://www.pentest-standard.org/index.php/Main\\_Page](http://www.pentest-standard.org/index.php/Main_Page)

MITRE ATT&CK (En omfattande matris över verkliga attacktekniker som kompletterar Kill Chain) - <https://attack.mitre.org/>

Shodan (Sökmotorn för internetuppkopplade enheter, ett kraftfullt OSINT-verktyg) - <https://www.shodan.io/>

SANS Institute (Artikel om hur man mappar attacker mot Kill Chain-modellen) - <https://www.sans.org/white-papers/36240/>

OSINT Framework (En interaktiv karta över resurser för informationsinsamling) - <https://osintframework.com/>

Microsoft Security (Förklaring av hur Kill Chain används i moderna säkerhetsverktyg) - <https://learn.microsoft.com/en-us/security/zero-trust/zero-trust-overview>

FireEye (Rapporter om avancerade hotaktörer och deras specifika metodiker) - <https://www.mandiant.com/resources/insights>

OWASP (Metodik för hur man specifikt testar webbapplikationer) - <https://owasp.org/www-project-web-security-testing-guide/>

BleepingComputer (Aktuella exempel på hur Ransomware-grupper följer attackkedjan) - <https://www.bleepingcomputer.com/>

## 12.4 Social Engineering – Den mänskliga vektorn

### Kontrollfrågor

1. Vad är den grundläggande skillnaden mellan en teknisk attack och social engineering?
2. Varför anses "människan" ofta vara den svagaste länken i en organisations säkerhetsarbete?
3. Förklara skillnaden mellan Phishing och Spear Phishing.
4. Vilket är det främsta målet med en så kallad Whaling-attack?
5. Hur fungerar en Vishing-attack i praktiken?
6. Beskriv scenariot vid en Tailgating-attack och hur den kan förhindras.
7. Vad är den psykologiska drivkraften bakom en USB-drop-attack?
8. Ge ett exempel på hur en angripare kan använda Pretexting för att få tag på en MFA-kod.
9. Vad innebär Typo-squatting och hur kan det användas för att stjäla lösenord?
10. Vilka mänskliga egenskaper eller beteenden utnyttjar en social engineer oftast för att lyckas?

## Fördjupningslänkar

Social-Engineer.org (En omfattande resurs och ramverk för att förstå social ingenjörskonst) - <https://www.social-engineer.org/>

NCSC (Vägledning om hur man upptäcker och skyddar sig mot nätfiske) - <https://www.ncsc.gov.uk/guidance/phishing>

KnowBe4 (Resurser och bloggar om den mänskliga faktorn inom cybersäkerhet) - <https://www.knowbe4.com/resources>

FBI - IC3 (Rapporter och varningar om Business Email Compromise och Whaling) - <https://www.ic3.gov/>

SANS Institute (Artikel om psykologin bakom social engineering) - <https://www.sans.org/white-papers/36382/>

Have I Been Pwned (Verktyg för att se om dina uppgifter läckt, vilket ofta används i spear phishing) - <https://haveibeenpwned.com/>

Google Safe Browsing (Information om hur webbläsare skyddar mot typo-squatting och falska domäner) - <https://safebrowsing.google.com/>

MSB (Svenska myndighetens råd för att öka säkerhetsmedvetenheten hos personal) - <https://www.msb.se/sv/rad-till-privatpersoner/informationssakerhet/>

The Social Engineering Framework (En teknisk genomgång av metoderna som används vid attacker) - <https://www.social-engineer.org/framework/se-framework-introduction/>

NIST (Riktlinjer för att bygga upp ett effektivt program för säkerhetsmedvetande) - <https://csrc.nist.gov/publications/detail/sp/800-50/final>

## 12.5 Tekniska angrepp: Från Webb till Kod

### Kontrollfrågor

1. Vad är den grundläggande principen bakom en injection-attack?
2. Hur kan en SQL-injection leda till att en angripare loggar in utan lösenord?
3. Vilken roll spelar JavaScript i en Cross-Site Scripting (XSS) attack?
4. Beskriv vad som händer rent fysiskt i datorns minne vid en Buffer Overflow.
5. Vad är "shellcode" och vad används det till?
6. Varför anses Zero-day sårbarheter vara så farliga för en organisation?
7. Vad är målet med Privilege Escalation efter att en angripare har tagit sig in i ett system?
8. Förklara hur en Man-in-the-Middle-attack fungerar i ett oskyddat nätverk.
9. Vad innebär IP-spoofing och vad är syftet med det?
10. Vilken är den viktigaste defensiva åtgärden för att förhindra de flesta injection-attacker?

## Fördjupningslänkar

OWASP Top 10 (Den officiella listan över de mest kritiska säkerhetsriskerna för webbapplikationer) - <https://owasp.org/www-project-top-ten/>

PortSwigger Academy (Interaktiva labbar för att lära sig SQL-injection och XSS i praktiken) - <https://portswigger.net/web-security/sql-injection>

Exploit Database (Ett arkiv med riktiga exploits för att förstå hur koden ser ut) - <https://www.exploit-db.com/>

Computerphile (Video som förklarar Buffer Overflow på ett pedagogiskt sätt) - <https://www.youtube.com/watch?v=1S0aKyirvuo>

CVE Mitre (Den officiella listan över offentligt kända sårbarheter och Zero-days) - <https://cve.mitre.org/>

Cloudflare (Teknisk genomgång av Man-in-the-Middle-attacker och hur de stoppas) - <https://www.cloudflare.com/learning/security/threats/man-in-the-middle-attack/>

TryHackMe (Praktiska rum för att öva på Privilege Escalation i Windows och Linux) - <https://tryhackme.com/path/outline/privesc>

Microsoft Security (Information om hur man skyddar mjukvara mot minnesrelaterade sårbarheter) - <https://learn.microsoft.com/en-us/windows/security/threat-protection/>

First.org (Dokumentation om hur sårbarheter poängsätts tekniskt) - <https://www.first.org/cvss/>

CISA (Katalog över kända och utnyttjade sårbarheter i världen) - <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>

## 12.6 Trådlös säkerhet (WLAN-hacking)

### Kontrollfrågor

1. Varför är det viktigt att särskilja på WLAN som infrastruktur och de säkerhetsprotokoll som skyddar trafiken?
2. Vilken är den största risken med att en telefon automatiskt ansluter till kända SSID-namn?
3. Förklara hur en angripare kan använda en Evil Twin för att stjäla inloggningsuppgifter på applikationsnivå.
4. Vad innebär det att "fånga en handskakning" (handshake) och vad kan en angripare använda den till?
5. Hur skyddar WPA3 mot de ordlisteattacker som fungerar mot WPA2?
6. Varför anses deauthentication-attacker vara ett förberedande steg snarare än själva slutmålet för ett hack?
7. Vad är den främsta anledningen till att WEP inte längre bör användas?
8. Hur kan man som användare skydda sin trafik på Layer 7 (applikationslagret) även om man är ansluten till ett osäkert WLAN?
9. Ge ett exempel på hur social ingenjörskonst används i samband med en Rogue Access Point.
10. Vad är den största fördelen med att utföra trådlösa attacker jämfört med att attackera ett trådbundet nätverk?

## Fördjupningslänkar

Aircrack-ng Documentation (Officiell guide för säkerhetsanalys av WLAN) - <https://www.aircrack-ng.org/doku.php>

Wi-Fi Alliance (Teknisk information om WPA3-standarden och SAE) - <https://www.wi-fi.org/discover-wi-fi/security>

Hak5 WiFi Pineapple (Information om verktyg för att simulera Rogue Access Points) - <https://docs.hak5.org/wifi-pineapple/>

OWASP Wireless Security Testing (Metodik för att testa trådlös säkerhet) - [https://cheatsheetseries.owasp.org/cheatsheets/Wireless\\_Flagship\\_Guide.html](https://cheatsheetseries.owasp.org/cheatsheets/Wireless_Flagship_Guide.html)

NIST (Riktlinjer för säker konfiguration av trådlösa nätverk) - <https://csrc.nist.gov/publications/detail/sp/800-153/final>

Tumi (Detaljerad genomgång av WPS-sårbarheten och Pixie Dust-attacken) - <https://forums.kali.org/showthread.php?24286-WPS-Pixie-Dust-Attack-Offline-WPS-Attack>

Krack Attacks (Den officiella sidan för KRACK-sårbarheten som påverkade nästan all WPA2-utrustning) - <https://www.krackattacks.com/>

Dragonblood (Information om sårbarheter i de tidiga implementeringarna av WPA3) - <https://wpa3.mathyvanhoef.com/>

Kismet Wireless (Dokumentation för ett annat industristandardverktyg för nätverksdetektering och sniffing) - <https://www.kismetwireless.net/docs/>

Cybersecurity & Infrastructure Security Agency (CISA - Tekniska råd för att säkra trådlösa nätverk i offentliga miljöer) - <https://www.cisa.gov/news-events/news/securing-wireless-networks>

## 12.7 Reverse Engineering & Forensik

### Kontrollfrågor

1. Vad är huvudmålet med Reverse Engineering när man analyserar skadlig kod?
2. Förklara skillnaden mellan statisk och dynamisk analys av ett program.
3. Vilken roll spelar en disassembler i analysprocessen?
4. Varför är det kritiskt att arbeta på en kopia (image) istället för på originalet vid en forensisk utredning?
5. Vad innebär begreppet Chain of Custody och varför är det viktigt?
6. Ge tre exempel på digitala artefakter som en forensiker kan leta efter i ett operativsystem.
7. Varför anses Memory Forensics vara mer utmanande men ofta mer givande än analys av en hårddisk?
8. Hur kan hash-värden användas för att säkerställa bevisens integritet?
9. Vad är syftet med att använda en debugger under Reverse Engineering?
10. Hur kan loggfiler från olika system hjälpa till att skapa en tidslinje över ett intrång?

## Fördjupningslänkar

Ghidra (Ett kraftfullt verktyg för Reverse Engineering utvecklat av NSA) - <https://ghidra-sre.org/>

The Sleuth Kit (En samling kommandoradsverktyg för digital forensisk analys) - <https://www.sleuthkit.org/>

SANS Digital Forensics Blog (Nyheter och djupdykningar inom forensik och incidentrespons) - <https://www.sans.org/blog/topics/digital-forensics/>

MalwareTech (Blogg som förklarar Reverse Engineering av kända malware, t.ex. WannaCry) - <https://www.malwaretech.com/>

Volatility Foundation (Det ledande ramverket för analys av arbetsminne/RAM-forensik) - <https://www.volatilityfoundation.org/>

NIST Computer Forensics Tool Testing Program (Standarder och tester för forensisk mjukvara) - <https://www.nist.gov/itl/ssd/software-quality-group/computer-forensics-tool-testing-program-cftt>

Forensics Focus (Ett community och kunskapsbank för yrkesverksamma inom digital forensik) - <https://www.forensicfocus.com/>

Reverse Engineering Stack Exchange (Frågor och svar för avancerade tekniska problem inom RE) - <https://reverseengineering.stackexchange.com/>

Autopsy (Ett användarvänligt grafiskt gränssnitt för forensiska utredningar) - <https://www.autopsy.com/>

OSINT Framework - Digital Forensics (Resurser för att hitta verktyg relaterade till utredningar) - <https://osintframework.com/>

## 12.8 Molnsäkerhet (Cloud Pentesting)

### Kontrollfrågor

1. Varför säger man att "identitet är den nya perimetern" i molnet?
2. Ge ett konkret exempel på vad kunden ansvarar för enligt den delade ansvarsmodellen när de kör en virtuell maskin (IaaS).
3. Hur kan en angripare använda en läckt API-nyckel för att utföra "Privilege Escalation" i en IAM-miljö?
4. Beskriv tekniskt hur en SSRF-attack kan användas för att stjäla inloggningsnycklar från en Metadata-tjänst.
5. Vad är skillnaden mellan en "Public" och en "Private" S3 Bucket, och hur testas detta vid ett pentest?
6. Varför är "Privileged Mode" i Docker en stor säkerhetsrisk?
7. Vad är en "Service Account" och hur kan det missbrukas om det har för höga rättigheter?
8. Hur skiljer sig nätverksanalys (sniffing) i molnet från ett traditionellt lokalt nätverk?
9. Vad innebär "Data at Rest" kontra "Data in Transit" i en molnkontext?
10. Vilken roll spelarloggning (t.ex. AWS CloudTrail) för att upptäcka ett pågående intrång i molnet?

## Fördjupningslänkar

Hacking the Cloud (En omfattande encyklopedi över attackmetoder specifika för molnmiljöer) - <https://hackingthe.cloud/>

Prowler (Ett ledande open-source verktyg för att granska säkerheten i AWS, Azure och GCP) - <https://prowler.com/>

Cloud Security Alliance (CSA - Global organisation som sätter standarder och utbildningar för molnsäkerhet) - <https://cloudsecurityalliance.org/>

AWS Security Blog (Amazons officiella blogg med djupdykningar i nya säkerhetsfunktioner och hot) - <https://aws.amazon.com/blogs/security/>

Rhino Security Labs (Bloggartiklar och verktyg, som Pacu, för avancerad moln-exploitation) - <https://rhinosecuritylabs.com/blog/>

Azure Security Benchmark (Microsofts tekniska checklista för att säkra resurser i Azure) - <https://learn.microsoft.com/en-us/security/benchmark/azure/introduction>

OWASP Cloud-Native Top 10 (De mest kritiska riskerna för moderna molnapplikationer och containrar) - <https://owasp.org/www-project-cloud-native-application-security-top-10/>

AppSecco: Capital One Breach Analysis (En detaljerad teknisk genomgång av SSRF-attacken mot Capital One) - <https://blog.appsecco.com/an-objective-analysis-of-the-capital-one-data-breach-822cf4a290d>

Kubernetes Security Best Practices (Officiell dokumentation om hur man säkrar kluster mot attacker) - <https://kubernetes.io/docs/concepts/security/>

Microsoft Cloud Adoption Framework (Strategier för säker molnmigrering och styrning) - <https://learn.microsoft.com/en-us/azure/cloud-adoption-framework/>

## 12.9 Rapportering och åtgärdsförslag

### Kontrollfrågor

1. Varför delas en penetrationsrapport ofta upp i en sammanfattning för ledningen och en teknisk del?
2. Vad är syftet med CVSS-skalan i en rapport?
3. Vad bör ingå i en "Executive Summary"?
4. Varför är ett "Proof of Concept" (PoC) så viktigt i den tekniska specifikationen?
5. Vilken skillnad är det på en sårbarhetsbeskrivning och dess konsekvens?
6. Ge ett exempel på ett tekniskt åtgärdsförslag för en Cross-Site Scripting (XSS).
7. Vad menas med begreppet "Attack Vector" inom riskbedömning?
8. Varför räcker det inte med att bara skicka rapporten via e-post till kunden?
9. Vad är syftet med ett omtest (re-test)?
10. Hur kan en rapport hjälpa en organisation att prioritera sin budget för säkerhet?

## Fördjupningslänkar

FIRST.org CVSS Calculator (Det officiella verktyget för att räkna ut allvarlighetsgrad på sårbarheter) - <https://www.first.org/cvss/calculator/3.1>

Offensive Security Report Writing Guide (Tips och mallar för hur man skriver professionella rapporter) - <https://www.offensive-security.com/pwk-online/PWK-Example-Report-v1.pdf>

SANS Institute: Writing a Good Penetration Testing Report (En djupdykning i vad som gör en rapport effektiv) - <https://www.sans.org/white-papers/33342/>

OWASP Reporting Cheat Sheet (En snabbguide till vad som bör ingå i säkerhetsrapporter) - [https://cheatsheetseries.owasp.org/cheatsheets/Abuse\\_Case\\_Cheat\\_Sheet.html](https://cheatsheetseries.owasp.org/cheatsheets/Abuse_Case_Cheat_Sheet.html)

TCM Security: Report Samples (Exempel på riktiga penetrationsrapporter från industrin) - <https://tcm-sec.com/sample-penetration-testing-reports/>

Bugcrowd VRT (Vulnerability Rating Taxonomy - ett alternativt sätt att klassificera sårbarheter) - <https://bugcrowd.com/vulnerability-rating-taxonomy>

Infosec Institute: Penetration Testing Reports (En genomgång av rapportens livscykel) - <https://resources.infosecinstitute.com/topic/penetration-testing-reports/>

The Art of the Executive Summary (Hur man kommunicerar komplexa tekniska risker till beslutsfattare) - <https://www.csoonline.com/article/2124612/security-reporting-how-to-write-an-executive-summary.html>

## 12.10 Lagar, etik och dataskydd

### Kontrollfrågor

1. Vilken är den viktigaste skillnaden mellan GDPR och Brottsbalken för en penetrationstestare?
2. Varför är ett PUB-avtal nödvändigt vid ett säkerhetstest?
3. Vad innebär det amerikanska justitiedepartementets förtydligande av CFAA från 2022 för säkerhetsforskare?
4. Hur kan DMCA påverka en person som arbetar med Reverse Engineering?
5. Varför räcker det inte med ett muntligt godkännande för att utföra ett penetrationstest?
6. Vad är risken med att utföra tester mot servrar som står i USA om man inte har stämt av det juridiska?
7. Förklara principen bakom "Responsible Disclosure".
8. Vad innebär begreppet "Scope" i ett RoE-dokument?
9. Hur snabbt måste en allvarlig dataläcka enligt GDPR rapporteras till tillsynsmyndigheten?
10. Vilken roll spelar etik när man hittar sårbarheter i system man inte har tillstånd att testa?

## Fördjupningslänkar

Brottsbalken 4 kap. (Svensk lagstiftning rörande dataintrång) -  
[https://www.riksdagen.se/sv/dokument-lagar/dokument/svensk-forfattningssamling/brottsbalk-1962700\\_sfs-1962-700#K4](https://www.riksdagen.se/sv/dokument-lagar/dokument/svensk-forfattningssamling/brottsbalk-1962700_sfs-1962-700#K4)

Integritetsskyddsmyndigheten (IMY) - Guide om personuppgiftsincidenter -  
<https://www.imy.se/verksamhet/dataskydd/personuppgiftsincidenter/>

Department of Justice (DOJ) - Policy om CFAA och säkerhetsforskning -  
<https://www.justice.gov/opa/pr/departments-justice-announces-revision-computer-fraud-and-abuse-act-enforcement-policy>

Electronic Frontier Foundation (EFF) - Guide till DMCA för säkerhetsforskare -  
<https://www.eff.org/issues/dmca>

EC-Council Code of Ethics (Etiska regler för certifierade hackare) -  
<https://www.eccouncil.org/code-of-ethics/>

Google Project Zero - Disclosure Policy (Exempel på hur branschledare hanterar sårbarhetsavslöjanden) -  
<https://googleprojectzero.blogspot.com/p/vulnerability-disclosure-policy.html>

## 12.11 Verktyg och specialiserade operativsystem

### Kontrollfrågor

1. Varför föredrar penetrationstestare ofta att använda en specialiserad Linux-distribution istället för Windows eller en vanlig Linux-version?
2. Vilken är den största skillnaden i fokus mellan Kali Linux och Parrot Security OS?
3. Förklara kortfattat vad Nmap används till i början av ett test.
4. Vad är skillnaden mellan en "exploit" och en "payload" i Metasploit?
5. I vilken fas av en penetrationstestning är Burp Suite som mest användbart?
6. Varför är Wireshark ett viktigt verktyg även för försvarsinriktade säkerhetstekniker?
7. Hur fungerar en ordlisteattack i verktyg som Hashcat eller John the Ripper?
8. Vad innebär det att sätta ett nätverkskort i "Monitor Mode" (vilket krävs för många av dessa verktyg)?
9. Varför är det viktigt att köra dessa verktyg i en isolerad miljö (t.ex. en virtuell maskin)?
10. Vilket verktyg skulle du använda för att kontrollera om en webbapplikation skickar känslig information okrypterat?

## Fördjupningslänkar

Kali Linux Official Site (Nedladdning och officiell dokumentation) - <https://www.kali.org/>

Metasploit Unleashed (En omfattande gratis kurs i hur man använder Metasploit) - <https://www.offsec.com/metasploit-unleashed/>

Nmap Network Scanning (Den officiella boken/guiden skriven av Nmaps skapare Fyodor) - <https://nmap.org/book/>

Burp Suite Academy (Interaktiva övningar för att lära sig webbsäkerhet i praktiken) - <https://portswigger.net/web-security>

Wireshark Docs (Resurser för att lära sig avancerad paketanalys och filtrering) - <https://www.wireshark.org/docs/>

Parrot Security (Officiell webbplats för Parrot OS och dess olika versioner) - <https://www.parrotsec.org/>

Hashcat Wiki (Information om hur man optimerar lösenordsknäckning med GPU) - <https://hashcat.net/wiki/>

BlackArch Guide (Instruktioner för att komma igång med det mest verktygstunga operativsystemet) - <https://blackarch.org/guide.html>

ArchWiki (En ovärderlig resurs för att förstå hur Linux-system är uppbyggda på djupet) - <https://wiki.archlinux.org/>

TryHackMe: Tool-specific rooms (Praktiska övningar där man får använda Nmap, Metasploit och Burp Suite i en säker miljö) - <https://tryhackme.com/>

## 12.12 Historiska attacker och deras betydelse

### Kontrollfrågor

1. Varför räknas Morris-masken som en milstolpe i internethistorien trots att målet inte var att förstöra?
2. På vilket sätt skilde sig Stuxnet från tidigare kända virus och trojaner när det gäller dess mål?
3. Vilken teknisk sårbarhet (exploit) gjorde att WannaCry kunde spridas så extremt snabbt utan mänsklig interaktion?
4. Förklara begreppet "Supply Chain-attack" med utgångspunkt i SolarWinds-incidenten.
5. Vilken roll spelar "Zero-day"-sårbarheter i en avancerad attack som Stuxnet?
6. Varför var Log4Shell-sårbarheten så svår att åtgärda för världens företag?
7. Vad är ett "air-gap" och hur lyckades Stuxnet övervinna detta hinder?
8. Vilken organisatorisk funktion skapades som ett direkt resultat av Morris-masken?
9. Hur förändrade WannaCry synen på vikten av säkerhetsuppdateringar och gamla operativsystem?
10. Vad innebär principen "Zero Trust" som blev högaktuell efter SolarWinds-attacken?

## Fördjupningslänkar

SANS Institute: History of Cyber Attacks (En interaktiv tidslinje och analys av stora incidenter) - <https://www.sans.org/blog/history-of-cyber-attacks/>

MITRE ATT&CK Framework (En kunskapsbas som mappar de tekniker som kända hackergrupper har använt historiskt) - <https://attack.mitre.org/>

The CyberWire: Hacking Humans Podcast (Berättelser om de mänskliga och tekniska aspekterna bakom kända attacker) - <https://thecyberwire.com/podcasts/hacking-humans>

Darknet Diaries (En mycket populär podcast som går på djupet med historiska hackerattacker, inklusive Stuxnet och WannaCry) - <https://darknetdiaries.com/>

# 13 Incidenthantering och digitalt försvar

## Kontrollfrågor

1. Varför är begreppet "resiliens" ofta viktigare än "prevention" för en stor organisation?
2. Beskriv hur LogiScan använde "Isolering" för att rädda sin verksamhet i scenariot.
3. Vilken roll spelar en Incident Response Plan (IRP) för att motverka panik?
4. Varför är det problematiskt att bara dra ut alla sladdar omedelbart vid ett angrepp?
5. Nämn tre olika yrkesroller som bör ingå i ett Incident Response Team (IRT) och vad deras huvudansvar är.
6. Vad är syftet med fasen "Lärdomar" efter att en incident är avslutad?
7. Hur påverkar GDPR arbetet för det juridiska ombudet i en incidentgrupp?
8. Vad innebär det att en Incident Response Plan är ett "levande dokument"?
9. På vilket sätt kan en lyckad incidenthantering faktiskt stärka förtroendet för ett företag?
10. Vad är en "Tabletop Exercise" och hur hjälper den teamet att förbereda sig för verkliga attacker?

## Fördjupningslänkar

NIST Computer Security Incident Handling Guide (Den globala standarden för incidenthantering) -

<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r2.pdf>

SANS Institute: Incident Handler's Handbook (En praktisk och teknisk guide) -

<https://www.sans.org/white-papers/33901/>

CISA: Incident Response Training & Resources (Verktyg och checklistor från

USA:s säkerhetsmyndighet) - <https://www.cisa.gov/incident-response-training>

MSB: Hantera it-incidenter (Vägledning för svenska organisationer och

myndigheter) - <https://www.msb.se/sv/amnesomraden/informationssakerhet-cybersakerhet/hantera-it-incidenter/>

ENISA: Strategies for Incident Response (Europeiska unionens samlade råd för

medlemsstaterna) - <https://www.enisa.europa.eu/topics/incident-response>

## 13.1 Grunderna i incidenthantering

### Kontrollfrågor

1. Vad innebär begreppet "resiliens" i ett säkerhetssammanhang?
2. Varför är det viktigt att skilja på en händelse och en incident?
3. Ge ett exempel på en händelse som initialt ser ut som en incident men som visar sig vara harmlös.
4. Vilket internationellt ramverk är mest känt för att definiera incidentens livscykel?
5. Varför anses "Förberedelse" vara den viktigaste fasen i livscykeln?
6. Vad är målet med fasen "Identifiering"?
7. Förklara skillnaden mellan isolering (containment) och eliminering (eradication).
8. Vad innebär det att utföra en "Lessons Learned"-analys?
9. Hur kan en incident som inte hanteras enligt livscykeln skada en organisation mer än själva attacken?
10. Vilken roll spelar dokumentation under hela incidentens livscykel?

## Fördjupningslänkar

NIST SP 800-61 Rev. 2 (Computer Security Incident Handling Guide) - <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r2.pdf>

SANS Incident Handling Process (En snabbguide till de sex stegen) - <https://www.sans.org/white-papers/33901/>

ISO/IEC 27035 (Internationell standard för incidenthantering) - <https://www.iso.org/standard/60803.html>

FIRST.org (Globalt nätverk för incidenthanteringsteam) - <https://www.first.org/>

ENISA: Incident Management Handbooks (Europeiska unionens resurser för incidenthantering) - <https://www.enisa.europa.eu/topics/incident-response/incident-management>

CISA: Federal Government Cybersecurity Incident & Vulnerability Response Playbooks - <https://www.cisa.gov/resources-tools/resources/federal-government-cybersecurity-incident-and-vulnerability-response-playbooks>

MSB: Vägledning för it-incidentrapportering (Svenska riktlinjer) - <https://www.msb.se/sv/amnesomraden/informationssakerhet-cybersakerhet/hantera-it-incidenter/>

MITRE ATT&CK for Incident Response (Hur man mappar attacker mot kända mönster) - <https://attack.mitre.org/resources/incident-response/>

Incident Response Consortium (Mallar och verktyg för IRP) - <https://www.incidentresponse.com/>

The CyberWire: Incident Response 101 (Podcasts och artiklar för nybörjare) - <https://thecyberwire.com/glossary/incident-response>

## 13.2 Planering och organisation (IRP & IRT)

### Kontrollfrågor

1. Varför är en IRP viktig för att minska mänskliga fel under en kris?
2. Vad är skillnaden mellan en generell incidentplan och en "playbook"?
3. Varför bör en IRP innehålla instruktioner för kommunikation utanför företagets ordinarie e-postsystem?
4. Vilken roll i IRT-teamet har sista ordet vid ett strategiskt beslut, till exempel att stänga ner en tjänst?
5. Varför är det viktigt att inkludera en juridisk expert i ett incident-team?
6. Vad innebär begreppet "eskaleringsmatris"?
7. Ge ett exempel på en extern part som bör finnas med i kontaktlistan i en IRP.
8. Vad är syftet med en Tabletop Exercise?
9. Hur ofta bör en IRP uppdateras för att förbli relevant?
10. Vad är risken med att ha en "Executive Sponsor" som inte förstår de tekniska riskerna?

## Fördjupningslänkar

NIST: Guide to Integrating Forensic Techniques into Incident Response - <https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-86.pdf>

SANS: Six Steps of Incident Response (Poster/Cheat sheet) - <https://www.sans.org/white-papers/33901/>

ENISA: CSIRT Setting up Guide (Hur man bygger upp ett team från grunden) - <https://www.enisa.europa.eu/publications/csirt-setting-up-guide>

CISA: Federal Government Cybersecurity Incident & Vulnerability Response Playbooks - <https://www.cisa.gov/resources-tools/resources/federal-government-cybersecurity-incident-and-vulnerability-response-playbooks>

Ready.gov: IT Disaster Recovery Plan (Mallar för mindre organisationer) - <https://www.ready.gov/it-disaster-recovery-plan>

## 13.3 Detektering och övervakning

### Kontrollfrågor

1. Vad är den principiella skillnaden mellan ett IDS och ett IPS?
2. Varför räcker det inte med enbart signaturbaserad detektering i dagens säkerhetslandskap?
3. Återknyt till kapitel 9.4: Varför placeras ofta ett IDS bakom en brandvägg snarare än framför?
4. Förklara begreppet "baselining" inom anomalibaserad detektering.
5. Vad är huvudsyftet med ett SIEM-system i förhållande till de loggar vi läste om i kapitel 8?
6. Ge ett exempel på en korreleringsregel som kombinerar en nätverkshändelse med en operativsystemshändelse.
7. Vad innebär begreppet "dwell time" och varför vill man minimera det?
8. Varför är centraliserad loggning (kapitel 8.2.3) en förutsättning för ett fungerande SIEM?
9. Vad är en "falsk positiv" och varför är det en utmaning för ett SOC?
10. Vilken roll spelar nätverksprotokoll (lager 3 och 4) när man konfigurerar ett IDS?

## Fördjupningslänkar

Splunk: What is SIEM? (Grundläggande genomgång av tekniken) -  
[https://www.splunk.com/en\\_us/data-insights/what-is-siem.html](https://www.splunk.com/en_us/data-insights/what-is-siem.html)

Snort (Världens mest kända open-source IDS/IPS) - <https://www.snort.org/>

Wazuh (Den öppna plattformen för SIEM och EDR som nämns i bokens ordlista)  
- <https://wazuh.com/>

Microsoft Sentinel (Dokumentation om ett modernt molnbaserat SIEM) -  
<https://learn.microsoft.com/en-us/azure/sentinel/overview>

Suricata (Ett modernt alternativ till Snort för nätverksövervakning) -  
<https://suricata.io/>

## 13.4 Logganalys – Spåren i snön

### Kontrollfrågor

1. Varför är det viktigt att korrelera loggar från olika lager (t.ex. nätverk och operativsystem) istället för att bara titta på en källa?
2. Återknyt till kapitel 8.1.5: Ge ett exempel på ett händelse-ID i Windows som är kritiskt att bevaka vid misstänkt intrång.
3. På vilket sätt hjälper kunskapen om OSI-modellen (kapitel 9.1) en analytiker att förstå var i loggkedjan en attack har skett?
4. Vad innebär begreppet "impossible travel" och hur kan det upptäckas via logganalys?
5. Varför kan en applikationslogg se en SQL-injektion som en vanlig brandvägg missar?
6. Beskriv hur loggmönstret skiljer sig mellan en automatiserad brute force-attack och en manuell angripare.
7. Varför är tids-synkronisering via NTP avgörande när man pusslar ihop en tidslinje från olika servrar?
8. Återknyt till kapitel 10.8: Varför är det kritiskt att loggar skickas till en extern server istället för att bara lagras lokalt?
9. Vilken roll spelar "filtrering" för att en analytiker ska kunna hitta faktiska hot i stora datamängder?
10. Hur kan logganalys användas för att inte bara upptäcka ett intrång, utan även för att bevisa vad som stulits (exfiltration)?

## Fördjupningslänkar

Microsoft Learn (Detaljerad lista över ID-nummer och deras betydelse vid intrång) – <https://learn.microsoft.com/en-us/windows/security/threat-protection/auditing/view-the-security-log>

Logz.io: Complete Guide to Linux Logging (En praktisk genomgång av loggsystemet och filerna i /var/log) – <https://logz.io/blog/linux-logging-complete-guide/>

MSB: Vägledning för loggning (Svenska myndighetsriktlinjer för säkerhetsloggning och lagkrav) – <https://www.msb.se/sv/publikationer/vagledning-for-loggning/>

NIST SP 800-92 (Den globala standarden för loggstrategi och integritet) – <https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-92.pdf>

Wazuh Documentation: Log Data Analysis (Lär dig hur den öppna SIEM-plattformen analyserar loggar i realtid) – <https://documentation.wazuh.com/current/user-manual/capabilities/log-data-analysis/index.html>

The DFIR Report (Analys av verkliga attacker där du kan se exakta loggutdrag och tidslinjer från incidenter) – <https://thedfirreport.com/>

TryHackMe: Log Operations Room (Interaktiv och praktisk träning i att hitta spår i loggfiler) – <https://tryhackme.com/module/log-operations>

OWASP: Logging Cheat Sheet (Bäst praxis för hur applikationer bör logga för att underlätta säkerhetsgranskning) – [https://cheatsheetseries.owasp.org/cheatsheets/Logging\\_Cheat\\_Sheet.html](https://cheatsheetseries.owasp.org/cheatsheets/Logging_Cheat_Sheet.html)

SANS Institute: Log Management and Analysis (Teknisk vitbok om strategier för att hantera stora loggvolymer) – <https://www.sans.org/white-papers/34860/>

CrowdStrike: Log Analysis for Incident Response (Ett modernt perspektiv på hur loggar används för proaktiv hotjakt) – <https://www.crowdstrike.com/cybersecurity-101/threat-hunting/log-analysis/>

## 13.5 Isolering och begränsning (Containment)

### Kontrollfrågor

1. Vad är det primära målet med isoleringsfasen (Containment)?
2. Återknyt till kapitel 9.4.2: Hur kan VLAN användas praktiskt för att isolera en smittad dator?
3. Varför föredrar man ofta digital isolering (via EDR) framför att fysiskt dra ut strömsladden?
4. Vilken risk finns det med att isolera ett system för aggressivt?
5. Hur hänger isolering av ett användarkonto ihop med begreppet "Privilege Escalation" i kapitel 11.4?
6. Vad innebär det att "frysa" en maskin digitalt?
7. Ge ett exempel på en situation där det är bättre att stänga ner en specifik tjänst än att isolera hela servern.
8. Varför är dokumentation extra viktig just under isoleringsfasen?
9. Vilken roll spelar incidentledaren (kapitel 12.2) när beslut om isolering ska fattas?
10. Återknyt till kapitel 11.7: Hur kan isoleringsfasen påverka möjligheten att utföra digital forensik senare?

## Fördjupningslänkar

NIST SP 800-61: Containment, Eradication, and Recovery (Detaljerade strategier för att stoppa spridning) –

<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r2.pdf>

SANS Institute: Containment Strategies (En vitbok om olika sätt att isolera attacker beroende på typ) – <https://www.sans.org/white-papers/33901/>

Cisco: Network Segmentation Best Practices (Hur man bygger nätverk som är lätta att isolera vid kris) – <https://www.cisco.com/c/en/us/solutions/enterprise-networks/what-is-network-segmentation.html>

CrowdStrike: What is Endpoint Isolation? (Förklaring av hur moderna EDR-verktyg isolerar hot) –

<https://www.crowdstrike.com/cybersecurity-101/endpoint-security/endpoint-isolation/>

Microsoft Learn: Isolate devices from the network (Praktisk instruktion för hur man isolerar maskiner i en Windows-miljö) – <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/respond-machine-alerts>

Wazuh Documentation: Active Response (Lär dig hur systemet automatiskt kan isolera en host vid larm) – <https://documentation.wazuh.com/current/user-manual/capabilities/active-response/index.html>

IT-Säkerhetspodden: Avsnitt om Ransomware (Diskuterar ofta praktisk isolering och "att dra ur sladden") – <https://itsakerhetspodden.se/>

## 13.6 Eliminering och återställning

### Kontrollfrågor

1. Varför anses det ofta säkrare att installera om ett system från grunden än att försöka "rensa" det från virus?
2. Återknyt till kapitel 10.1: Hur kan VM-snapshots underlätta elimineringsfasen?
3. Vad är den största risken med att återställa data från en backup direkt efter en attack?
4. Varför är det kritiskt att installera säkerhetspatchar *innan* man öppnar upp nätverkstrafiken till en återställd server?
5. Vad innebär det att återställa system i en "staging-miljö"?
6. Återknyt till kapitel 11.3.1: Vilken roll spelar MFA (Flerfaktorsautentisering) under återställningsfasen?
7. Hur hänger elimineringsfasen ihop med begreppet "bakdörr" från kapitel 11.4?
8. Varför är det viktigt att utföra extra noggrann logganalys (se kapitel 12.4) direkt efter en återställning?
9. Vad innebär begreppet "Golden Image" och hur kan det användas vid återställning?
10. Vilken roll spelar de "Lärdomar" man drar (se kapitel 12.1) för att förhindra att samma incident upprepas under återställningen?

## Fördjupningslänkar

NIST SP 800-61: Eradication and Recovery (Officiella riktlinjer för säker återställning) –

<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r2.pdf>

SANS Institute: Eradication and Recovery (En praktisk checklista för incidenthanterare) – <https://www.sans.org/white-papers/33901/>

Microsoft Learn: Recovering from a ransomware attack (Steg-för-steg guide för Windows-miljöer) –

<https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/recover-from-ransomware>

Veeam: The 3-2-1-1-0 Backup Rule (En modern strategi för att säkerställa att backuper är rena och tillgängliga) – <https://www.veeam.com/blog/321-backup-rule.html>

CISA: Ransomware Recovery Guide (Myndighetens vägledning för att komma tillbaka efter en total nedläsning) –

<https://www.cisa.gov/resources-tools/resources/ransomware-recovery-guide>

CrowdStrike: Remediation vs Eradication (Förklaring av skillnaden mellan att fixa symptomen och att ta bort orsaken) –

<https://www.crowdstrike.com/cybersecurity-101/incident-response/remediation-vs-eradication/>

IBM: Best practices for data recovery after a cyber attack –

<https://www.ibm.com/flashsystem/data-resilience/recovery-best-practices>

Google Cloud: Disaster Recovery Planning Guide (Hur man planerar för återställning i molnet, se kapitel 10.1) –

<https://cloud.google.com/architecture/disaster-recovery>

KnowBe4: Post-Infection Checklist (En användbar lista för att säkerställa att inget glöms bort vid återställning) –

<https://www.knowbe4.com/hubfs/Ransomware-Hostage-Rescue-Manual.pdf>

Backblaze (Praktiska tips för mindre organisationer) –

<https://www.backblaze.com/blog/how-to-recover-from-ransomware/>

## 13.7 Digital Forensik vid incidenter

### Kontrollfrågor

1. Vad är den största skillnaden mellan logganalys och digital forensik?
2. Återknyt till kapitel 1.3: Varför är RAM-minnet det första en forensiker försöker säkra?
3. Förklara begreppet "volatilitetsordning".
4. Vad är syftet med en "Chain of Custody"?
5. Återknyt till kapitel 11.3.1: Hur används hash-funktioner för att garantera bevisens integritet?
6. Varför utför man aldrig analys direkt på originalhårdvaran?
7. Vad gör en "Write Blocker" och varför är den viktig?
8. Återknyt till kapitel 8.1.1: Varför kan man ofta återskapa filer som en angripare har raderat?
9. Ge ett exempel på information som kan hittas i en minnesdump men inte på en hårddisk.
10. Vilken roll spelar tidslinjeanalys i en forensisk utredning?

## Fördjupningslänkar

NIST SP 800-86: Guide to Integrating Forensic Techniques into Incident Response (Den officiella guiden för forensik i IT-miljöer) – <https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-86.pdf>

SANS Digital Forensics and Incident Response (DFIR) Poster (En klassisk sammanställning av verktyg och metoder) – <https://www.sans.org/posters/windows-forensic-analysis/>

Autopsy (Ett av världens mest använda open-source verktyg för digital forensik) – <https://www.sleuthkit.org/autopsy/>

Volatility Foundation (Hemsidan för det främsta verktyget för att analysera RAM-minnesdumpar) – <https://www.volatilityfoundation.org/>

FTK Imager (Ett standardverktyg för att skapa bit-för-bit kopior av hårddiskar) – <https://www.exterro.com/ftk-imager>

Magnet Forensics Blog (Djuplodande artiklar om moderna forensiska utmaningar, t.ex. kryptering och moln) – <https://www.magnetforensics.com/blog/>

Digital Forensics Magazine (Nyheter och forskning inom området) – <https://digitalforensicsmagazine.com/>

Forensics Focus (Ett stort community och forum för professionella forensiker) – <https://www.forensicfocus.com/>

Guidance Software: EnCase (Information om ett av de mest använda kommersiella verktygen i rättsliga sammanhang) – <https://www.opentext.com/products/encase-forensic>

## 13.8 Kriskommunikation och lagstadgad rapportering

### Kontrollfrågor

1. Varför är kommunikationsansvariga en viktig del av ett tekniskt incident-team?
2. Återknyt till kapitel 11.10: Vad är det främsta lagkravet i GDPR som rör incidentrapportering?
3. Vilka är de potentiella konsekvenserna av att missa 72-timmarsfönstret för rapportering till IMY?
4. Varför är det viktigt att ge anställda tydliga instruktioner om vad de får säga externt under en pågående kris?
5. Vad är skillnaden mellan en "incidentanmälan" till IMY och en "brottsanmälan" till Polisen?
6. Återknyt till kapitel 12.2: Hur kan färdiga kommunikationsmallar i en IRP påskynda arbetet?
7. Vilken roll spelar CERT-SE vid en större nationell it-incident?
8. Varför kan "mörkning" av en incident vara mer skadligt än själva dataintrånget?
9. När måste man informera de enskilda personerna vars data kan ha läckt, utöver myndigheterna?
10. Hur hänger kriskommunikation ihop med organisationens övergripande rykte (brand)?

## Fördjupningslänkar

IMY: Anmäla personuppgiftsincident (Officiell guide och formulär för GDPR-rapportering) –

<https://www.imy.se/verksamhet/dataskydd/personuppgiftsincidenter/>

CERT-SE: Rapportera it-incident (Information om hur och varför man rapporterar till Sveriges nationella CSIRT) – <https://www.cert.se/rapportera-incident>

MSB: Vägledning för kriskommunikation (Generella råd för hur myndigheter och företag bör kommunicera i kris) –

<https://www.msb.se/sv/amnesomraden/krisberedskap--civilt-forsvar/kriskommunikation/>

Polisen: Anmäl it-brott (Instruktioner för hur man polisanmäler dataintrång och bedrägerier) – <https://polisen.se/utsatt-for-brott/olika-typer-av-brott/it-brott/>

ENISA: Incident Reporting (Europeiska unionens översikt över rapporteringskrav och praxis) – <https://www.enisa.europa.eu/topics/incident-response/incident-reporting>

NIST SP 800-61: Coordination and Information Sharing (Kapitel om hur man delar information med externa parter) –

<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r2.pdf>

Edelman Trust Barometer: Cybersecurity & Trust (Rapport om hur säkerhetsincidenter påverkar konsumenters förtroende) –

<https://www.edelman.com/research/trust-and-cybersecurity>

## 13.9 Business Continuity & Disaster Recovery (BCDR)

### Kontrollfrågor

1. Vad är den principiella skillnaden mellan Business Continuity (BC) och Disaster Recovery (DR)?
2. Förklara begreppet RTO och ge ett exempel på varför ett sjukhus behöver ett mycket lågt RTO.
3. Återknyt till kapitel 10.7: Hur påverkar realtidsspeglning av data organisationens RPO?
4. Ge ett exempel på en analog Business Continuity-åtgärd i sjukhusexemplet.
5. Varför är redundanta PSU:er (kapitel 1.5) en förutsättning för en fungerande BCDR-strategi?
6. Vad innebär det att en organisation har en "Hot Site" och vilka fördelar ger det vid en katastrof?
7. Återknyt till kapitel 9.4: Varför är nätverksredundans nödvändigt för att kunna använda en fjärrstyrd DR-site?
8. Vad är den största nackdelen med en "Cold Site" när det gäller RTO?
9. Hur kan virtualisering (kapitel 10.1) underlätta en snabb Disaster Recovery?
10. Vem bör ha huvudansvaret för att bestämma nivån på RTO och RPO – IT-chefen eller verksamhetsledningen?

## Fördjupningslänkar

FEMA: Business Continuity Planning Suite (Verktyg och mallar för BCP) – <https://www.ready.gov/business-continuity-planning-suite>

NIST SP 800-34: Contingency Planning Guide for Federal Information Systems – <https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-34r1.pdf>

MSB: Kontinuitetshantering (Svensk vägledning för att upprätthålla samhällsviktig verksamhet) – <https://www.msb.se/sv/amnesomraden/informationssakerhet-cybersakerhet/kontinuitetshantering/>

SANS Institute: Disaster Recovery Plan Strategies – <https://www.sans.org/white-papers/564/>

IBM: Business Continuity vs Disaster Recovery – <https://www.ibm.com/topics/business-continuity-disaster-recovery>

Veeam: The 3-2-1-1-0 Backup Rule for DR – <https://www.veeam.com/blog/321-backup-rule.html>

ISO 22301: Business Continuity Management System – <https://www.iso.org/standard/75106.html>

Cloudflare: What is Disaster Recovery-as-a-Service (DRaaS)? – <https://www.cloudflare.com/learning/network-layer/what-is-draas/>

British Journal of Anaesthesia: Impact of IT failures on patient safety (Vetenskaplig artikel om vikten av BCDR i vården) – <https://academic.oup.com/bja>

## 13.10 Post-incident och ständiga förbättringar

### Kontrollfrågor

1. Varför anses fasen "Lessons Learned" vara den viktigaste för att höja organisationens resiliens?
2. Återknyt till kapitel 12.1: Hur stänger denna fas livscykeln för en incident?
3. Vilka dokument bör uppdateras efter att en incident har analyserats?
4. Ge ett exempel på en teknisk förbättring som kan bli resultatet av en utvärdering.
5. Återknyt till kapitel 12.8: Varför är det viktigt att utvärdera hur kommunikationen fungerade under krisen?
6. Vad är syftet med att arkivera loggar och bevis även efter att incidenten är avslutad?
7. Hur kan resultatet från ett "Lessons Learned"-möte påverka nästa **Tabletop Exercise** (se kapitel 12.2)?
8. Varför är det viktigt att utvärderingen sker utan att "peka finger" eller fördela skuld?
9. Återknyt till kapitel 12.9: Vad händer om utvärderingen visar att de uppsatta RTO-målen inte gick att nå?
10. Vilken roll spelar slutrapporten för företagets ledning?

## Fördjupningslänkar

NIST SP 800-61: Post-Incident Activity (Detaljerade råd om hur man genomför utvärderingar) –

<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r2.pdf>

SANS Institute: The Importance of Post-Incident Reviews (Varför och hur man lär sig av kriser) – <https://www.sans.org/white-papers/33901/>

ISACA: Post-Incident Review Template (Exempel på hur en slutrapport kan struktureras) – <https://www.isaca.org/resources/news-and-trends/isaca-now-blog/2020/how-to-conduct-a-post-incident-review>

ENISA: Post-incident analysis and reporting (Europeiska unionens riktlinjer för struktur och innehåll) –

<https://www.enisa.europa.eu/topics/incident-response/post-incident-analysis>

MSB: Att lära av it-incidenter (Vägledning för ett systematiskt förbättringsarbete) – <https://www.msb.se/sv/publikationer/att-lara-av-it-incidenter/>

CISA: Lessons Learned from Real-World Incidents (Fallstudier och lärdomar från stora attacker) – <https://www.cisa.gov/resources-tools/resources/lessons-learned-real-world-incidents>

Microsoft Learn: Post-incident review in Azure (Hur man automatiserar och dokumenterar lärdomar i molnet) – <https://learn.microsoft.com/en-us/azure/site-recovery/site-recovery-post-incident-review>

Google SRE Book: Postmortem Culture (En djupdykning i hur världens största it-bolag hanterar fel utan att skuldbelägga) – <https://sre.google/sre-book/postmortem-culture/>

# 14 Framtidens teknik och hållbarhet

## 14.1 Artificiell Intelligens (AI) och Maskininlärning

### Kontrollfrågor

1. Hur skiljer sig maskininlärning från traditionell programmering när det gäller att lösa ett tekniskt problem?
2. Analysera hur införandet av AI i ett SOC (Security Operations Center) påverkar kraven på den personal som arbetar där.
3. På vilket sätt har efterfrågan på AI-tjänster påverkat utvecklingen av datorhårdvara under de senaste åren?
4. Resonera kring riskerna med att låta ett AI-system sköta automatiska säkerhetsuppdateringar utan mänsklig översyn.
5. Vad innebär begreppet "Explainable AI" och varför är det kritiskt i ett yrkesmässigt sammanhang?
6. Hur kan AI bidra till att göra stora datacenter mer energieffektiva?
7. Diskutera förhållandet mellan datakvalitet och AI-modellens tillförlitlighet i ett administrativt system.
8. På vilket sätt kan AI användas av angripare för att göra cyberattacker mer effektiva, och hur bör försvaret svara?
9. Vilka fördelar finns det med att använda en dedikerad NPU jämfört med en vanlig CPU för AI-beräkningar?
10. Hur tror du att rollen som "it-support" förändras när användare får tillgång till avancerade AI-assistenter för felsökning?

## 14.2 Kvantdatorer och framtidens beräkningskraft

### Kontrollfrågor

1. Resonera kring varför den traditionella miniatyriseringen av transistorer når en gräns och hur kvantdatorer erbjuder en alternativ väg framåt.
2. Förklara på ett analytiskt sätt skillnaden i beräkningskapacitet mellan en bit och en qubit när antalet enheter ökar.
3. Vilka specifika delar av den it-säkerhet vi gått igenom i kapitel 11 blir mest sårbara vid genombrottet för kvantdatorer?
4. Varför är det problematiskt för företag och myndigheter att vänta med att implementera kvantsäker kryptering tills kvantdatorerna faktiskt är här?
5. Diskutera varför kvantdatorer troligen kommer att förbli en molnbaserad resurs istället för att bli personliga datorer.
6. På vilket sätt kan sammanflätning (entanglement) förändra hur vi ser på dataöverföring och kommunikationshastighet?
7. Analysera hur kvantberäkningar kan påverka utvecklingen av den artificiella intelligens vi diskuterade i avsnitt 14.1.
8. Vilka miljömässiga utmaningar ser du med driften av kvantdatorer med tanke på de extrema kylkrav som finns?
9. Hur bör en it-arkitekt tänka idag för att "kvantsäkra" ett nätverk som ska fungera i minst tio år framåt?
10. Om kvantdatorer kan knäcka dagens kryptering, vilka blir de etiska konsekvenserna för rätten till digitalt privatliv?

## Fördjupningslänkar

IBM Quantum (Plattform för att lära sig och testa kvantprogrammering) – <https://www.ibm.com/quantum>

Google Quantum AI (Senaste nyheterna om Googles kvantforskning) – <https://quantumai.google/>

MIT Technology Review: Quantum Computing – <https://www.technologyreview.com/topic/computing/quantum-computing/>

NIST Post-Quantum Cryptography (Standardiseringsarbetet för ny kryptering) – <https://csrc.nist.gov/projects/post-quantum-cryptography>

Microsoft Azure Quantum (Ett ekosystem för kvantberäkningar i molnet) – <https://azure.microsoft.com/en-us/products/quantum/>

Intel Labs: Quantum Computing (Om utvecklingen av kvantprocessorer) – <https://www.intel.com/content/www/us/en/research/quantum-computing.html>

Quanta Magazine: Quantum Computing (Vetenskaplig fördjupning i kvantmekanik och beräkning) – <https://www.quantamagazine.org/tag/quantum-computing/>

Quantum Computing Report (Analys av marknaden och teknikutvecklingen) – <https://quantumcomputingreport.com/>

Cloudflare: What is Post-Quantum Cryptography? – <https://www.cloudflare.com/learning/security/post-quantum-cryptography/>

CERN Quantum Technology Initiative (Hur världens största partikelfysiklab använder kvantteknik) – <https://quantum.cern/>

## 14.3 Hållbar IT och den cirkulära ekonomin

### Kontrollfrågor

1. Resonera kring begreppet PUE och förklara varför ett värde nära 1.0 är eftersträvaransvärt men svårt att nå i praktiken.
2. Analysera hur en övergång till cirkulär ekonomi förändrar it-avdelningens roll när det gäller inköp och inventariehantering.
3. Vilka miljömässiga och etiska problem är kopplade till utvinningen av råmaterial för moderna komponenter som SSD och batterier?
4. På vilket sätt kan virtualisering (se kapitel 10) bidra till en mer hållbar it-miljö i ett stort företag?
5. Diskutera utmaningarna med att balansera kravet på hög säkerhet (t.ex. destruktions av lagringsmedier) mot målet att återanvända hårdvara.
6. Hur påverkar valet av operativsystem och mjukvaruoptimering den fysiska hårdvarans energiförbrukning över tid?
7. Resonera kring fördelarna och nackdelarna med modulär hårdvarudesign jämfört med dagens integrerade konsumentelektronik.
8. Vilket ansvar har en it-tekniker personligen när det gäller att motverka "slit-och-släng"-kulturen inom en organisation?
9. Hur kan spillvärme från stora datacenter användas som en resurs i ett urbant samhälle?
10. Analysera sambandet mellan molntjänster och global energiförbrukning – blir det mer hållbart när vi flyttar datakraften från lokala rum till molnet?

## Fördjupningslänkar

TCO Certified (Global hållbarhetscertifiering för it-produkter) –

<https://tcocertified.com/sv/>

Sveriges Miljömål: Begränsad klimatpåverkan –

<https://www.sverigesmiljomal.se/miljomalen/begransad-klimatpaverkan/>

The Restart Project (En organisation som arbetar för rätten att reparera elektronik) – <https://therestartproject.org/>

Greenpeace: Guide to Greener Electronics –

<https://www.greenpeace.org/international/act/greener-electronics/>

Ellen MacArthur Foundation: Circular Economy in the Digital Sector –

<https://ellenmacarthurfoundation.org/topics/circular-economy-introduction/overview>

Naturvårdsverket: Elektronikavfall –

<https://www.naturvardsverket.se/vagledning-och-stod/avfall/farligt-avfall/elektronikavfall/>

Fairphone (Exempel på ett företag som arbetar med etisk och modulär elektronik) – <https://www.fairphone.com/en/>

IEEE Sustainable Computing (Vetenskaplig forskning kring energieffektiv beräkning) – <https://www.computer.org/communities/special-technical-communities/sustainable-computing>

European Commission: Circular Electronics Initiative –

[https://ec.europa.eu/environment/strategy/circular-economy-action-plan\\_en](https://ec.europa.eu/environment/strategy/circular-economy-action-plan_en)

Global E-waste Monitor (Statistik och analys av världens e-avfall) –

<https://ewastemonitor.info/>

## 14.4 Edge Computing och sakernas internet (IoT)

### Kontrollfrågor

1. Analysera varför Edge Computing är en nödvändighet för införandet av självkörande fordon i stor skala.
2. Resonera kring de säkerhetsrisker som uppstår när "dumma" föremål i ett hem eller på en industri blir uppkopplade.
3. På vilket sätt förändras behovet av bandbredd i ryggradsnätet (backbone) när vi går från en ren molnmodell till en Edge-modell?
4. Diskutera utmaningarna med att underhålla och uppdatera mjukvara på tusentals geografiskt spridda IoT-enheter jämfört med servrar i ett datacenter.
5. Hur påverkar 5G-utbyggnaden möjligheterna att använda VR (Virtual Reality) och AR (Augmented Reality) inom it-support och service?
6. Resonera kring integritetsfrågorna som uppstår när allt fler sensorer i vår fysiska miljö ständigt samlar in och analyserar data.
7. Vilka krav ställs på hårdvaran i en Edge-nod jämfört med en traditionell server när det gäller miljöfaktorer som temperatur och vibrationer?
8. Analysera begreppet "Shadow IT" i relation till IoT – vad händer när anställda tar med egna smarta prylar till arbetsplatsens nätverk?
9. Hur kan en digital tvilling användas för att förutsäga hårdvarufel innan de faktiskt inträffar (predictive maintenance)?
10. Diskutera hur yrkesrollen för en nätverkstekniker förändras när nätverket inte längre bara består av kablar och switchar utan även tusentals sensorer.

## Fördjupningslänkar

The Things Network (Ett globalt öppet community för IoT) –

<https://www.thethingsnetwork.org/>

Microsoft Azure IoT Central (Plattform för hantering av IoT-enheter) –

<https://azure.microsoft.com/en-us/products/iot-central/>

AWS IoT Greengrass (Information om hur Edge-enheter kan köra kod lokalt) –

<https://aws.amazon.com/greengrass/>

Linux Foundation: Edge Computing (Öppna projekt för Edge-infrastruktur) –

<https://www.lfedge.org/>

IEEE Internet of Things Journal (Vetenskapliga artiklar om den senaste IoT-forskningen) – <https://iee-iotj.org/>

Ericsson: 5G for IoT (Teknisk genomgång av hur mobilnätet möjliggör sakernas internet) – <https://www.ericsson.com/en/5g/iot>

IoT Security Foundation (Organisation som arbetar för säkrare uppkopplade enheter) – <https://www.iotsecurityfoundation.org/>

Post- och telestyrelsen (PTS): 5G i Sverige –

<https://www.pts.se/sv/bransch/radio/5g/>

Gartner: Top Strategic Technology Trends - Edge Computing –

<https://www.gartner.com/en/information-technology/glossary/edge-computing>

Industrial Internet Consortium (Standarder och ramverk för IoT inom industrin)

– <https://www.iiconsortium.org/>

## 14.5 Den föränderliga yrkesrollen och livslångt lärande

### Kontrollfrågor

1. Resonera kring begreppet "livslångt lärande" – varför är det mer kritiskt inom it-sektorn än i många andra branscher?
2. Analysera hur övergången från lokal hårdvaruservice till molnbaserad systemadministration påverkar it-teknikerns vardag.
3. Diskutera varför kommunikationsförmåga och pedagogik har blivit centrala kompetenser för en modern it-administratör.
4. På vilket sätt kan en bred grundförståelse för hårdvara (kapitel 1–7) hjälpa dig även om du i framtiden bara arbetar med mjukvarubaserad säkerhet?
5. Resonera kring de etiska utmaningar man möter när man har högsta behörighet (root/admin) i ett företags nätverk.
6. Hur tror du att balansen mellan formella utbildningar (som examen) och praktiska certifieringar kommer att se ut i framtiden?
7. Diskutera begreppet "T-formad kompetens" och identifiera vilka områden du själv skulle vilja ha som din "vertikala" fördjupning.
8. På vilket sätt påverkar automatisering och AI (se kapitel 14.1) risken för att vissa tekniska yrkesroller försvinner?
9. Resonera kring vikten av nätverkande och kunskapsdelning inom it-communityn (t.ex. genom Open Source-projekt).
10. Vilket råd skulle du ge till en elev som just ska börja kapitel 1 i denna bok, nu när du själv har tagit dig igenom hela materialet?

## Fördjupningslänkar

Top IT Skills for the Future (En översikt av vilka tekniska färdigheter som kommer att efterfrågas mest framöver) - <https://www.coursera.org/articles/it-skills>

LinkedIn Learning: The Evolution of IT Roles (Utforska hur yrkesroller inom IT förändras i takt med teknikutvecklingen) - <https://www.linkedin.com/learning/topics/information-technology>

Microsoft Learn: Career Paths in IT (En guide till olika karriärvägar och certifieringar inom Microsofts ekosystem) - <https://learn.microsoft.com/en-us/credentials/browse/>

CompTIA: IT Industry Outlook (Årlig rapport om trender, tillväxt och jobbmarknaden i IT-branschen) - <https://www.comptia.org/content/research/it-industry-outlook-2024>

World Economic Forum: The Future of Jobs Report (Djupgående rapport om hur automatisering och AI påverkar framtidens arbetsmarknad) - <https://www.weforum.org/reports/the-future-of-jobs-report-2023/>

ACM Code of Ethics and Professional Conduct (De etiska regler och riktlinjer som styr hur ett IT-proffs bör agera) - <https://www.acm.org/code-of-ethics>

EdX: Computer Science and Professional Development (Kurser på universitetsnivå för den som vill fördjupa sig inom datavetenskap) - <https://www.edx.org/school/computer-science>

Pluralsight: Technology Skills Report (Insikter om hur snabbt tekniker blir föråldrade och vikten av ständig kompetensutveckling) - <https://www.pluralsight.com/resource-center/state-of-upskilling-2023>

Dice: Tech Salary Report & Career Trends (Statistik om löner och förmåner för olika roller inom tekniksektorn) - <https://www.dice.com/recruiters/insights/salary-report/>

Myndigheten för yrkeshögskolan: Utbildningar inom IT (Sökbara utbildningar i Sverige för dig som vill gå vidare efter gymnasiet) - <https://www.myh.se/>